

PROJET DE FIN D'ÉTUDES

DIPLÔME NATIONAL D'INGÉNIEUR

SPÉCIALITÉ : Cycle ingénieur

Socle GCP sécurisé Zero Trust, DevSecOps et détection enrichie par IA

Hébergement et sécurisation des applications MENAL

Réalisé par : **Mansour HABIBOULLAH**

Encadré par :

Encadrant ESPRIT : **Rihem Matoussi**

Encadrant Entreprise : **Houssein Ezzedine**

Année universitaire : 2025–2026



Remerciements

Je tiens à remercier Mme Rihem Matoussi, mon encadrante académique à ESPRIT, pour son suivi et ses recommandations tout au long de ce projet de fin d'études. Mes remerciements s'adressent également à M. Houssein Ezzedine, mon encadrant au sein de MENAL-SARL, pour la confiance accordée, la disponibilité et les échanges qui ont accompagné la réalisation de ce travail.

Je remercie l'équipe de MENAL-SARL pour son accueil, ainsi que l'ensemble du corps enseignant d'ESPRIT pour les connaissances et les méthodes acquises durant ma formation. Enfin, j'adresse mes remerciements aux membres du jury pour le temps consacré à l'évaluation de ce mémoire.

Résumé

Ce mémoire présente la conception, la réalisation et l'évaluation d'un socle d'hébergement sécurisé sur Google Cloud pour MENAL-SARL. Le point de départ était une application pilote hébergée sur un serveur unique, sans reproductibilité complète ni chaîne de détection de sécurité. La démarche associe un audit technique, une analyse de risque, vingt exigences vérifiables, une architecture Zero Trust, une infrastructure as code et des portes de contrôle DevSecOps. Le socle obtenu sépare les identités de service, déploie sans clé permanente, centralise une collecte filtrée de journaux et exécute sept règles de détection. Un modèle spécialisé enrichit les alertes par rapprochement avec MITRE ATT&CK ; cette information reste distincte du score d'incident. Le 19/08/2026, un scénario de bout en bout a produit treize requêtes malveillantes, toutes bloquées en HTTP 403 et retrouvées dans les journaux ; la règle R2 les a agrégées environ quinze minutes plus tard. Le contrôle d'isolation des données du locataire a réussi six vérifications sur six, dont une connexion croisée réellement refusée. La restauration de la base a été mesurée à 32 min 45 s, sans perte de données. Les limites principales sont l'absence de segmentation réseau entre locataires, un motif de traversée de chemin encore partiellement filtré et l'absence de mesures complètes de coût et de qualité sémantique. Le travail établit un socle reproductible et exploitable en recette, et délimite les contrôles restant à renforcer.

Mots-clés :

Zero Trust, DevSecOps, Google Cloud, infrastructure as code, SIEM, MITRE ATT&CK, sécurité multi-locataire

Abstract

This thesis presents the design, implementation, and evaluation of a secure Google Cloud hosting foundation for MENAL-SARL. The starting point was a pilot application hosted on a single server, without full reproducibility or a security detection pipeline. The approach combines a technical audit, a risk analysis, twenty verifiable requirements, a Zero Trust architecture, infrastructure as code, and blocking DevSecOps gates. The resulting foundation separates service identities, deploys without permanent keys, centralizes filtered log collection, and runs seven detection rules. A domain-specific model enriches alerts by mapping them to MITRE ATT&CK; this information remains separate from the incident score. On 19 August 2026, an end-to-end scenario generated thirteen malicious requests: all were blocked with HTTP 403 and found in the logs, and rule R2 aggregated them about fifteen minutes later. The tenant data-isolation control passed all six checks, including an actual rejected cross-database connection. Database restoration was measured at 32 min 45 s, with no data loss. The main limitations are the lack of per-tenant network segmentation, one partially filtered path traversal pattern, and incomplete cost and semantic quality measurements. The work establishes a reproducible foundation, operable in the staging environment, and delimits the controls that remain to be strengthened.

Keywords:

Zero Trust, DevSecOps, Google Cloud, infrastructure as code, SIEM, MITRE ATT&CK, multi-tenant security

Liste des acronymes

Sigle	Signification
ADR	Architecture Decision Record — registre de décisions d’architecture
ALB	Application Load Balancer
API	Application Programming Interface
BQ	BigQuery (service d’entrepôt de données GCP)
CI/CD	Continuous Integration / Continuous Deployment
CMEK	Customer-Managed Encryption Keys
CVE	Common Vulnerabilities and Exposures
DevSecOps	Development, Security and Operations
DNS	Domain Name System
GCP	Google Cloud Platform
GKE	Google Kubernetes Engine
HA	Haute disponibilité (High Availability)
IAM	Identity and Access Management
IaC	Infrastructure as Code
JWT	JSON Web Token
KMS	Key Management Service
NAT	Network Address Translation
NIST	National Institute of Standards and Technology
OIDC	OpenID Connect
ONNX	Open Neural Network Exchange
PITR	Point-In-Time Recovery
PSA	Private Service Access
RBAC	Role-Based Access Control
RGPD	Règlement général sur la protection des données
SA	Service Account (compte de service)
SAST	Static Application Security Testing
SIEM	Security Information and Event Management
SLO	Service Level Objective
TLS	Transport Layer Security
VPC	Virtual Private Cloud
VPC-SC	VPC Service Controls
WAF	Web Application Firewall
WIF	Workload Identity Federation
ZTA	Zero Trust Architecture

Un glossaire technique complémentaire (définitions de concepts, au-delà des sigles) figure en annexe G.

Table des matières

Remerciements	i
Résumé	ii
Abstract	iii
Liste des acronymes	iv
Table des figures	x
Liste des tableaux	xii
Liste des graphiques	xiv
Introduction générale	1
1 Contexte du projet, étude de l'existant et problématique	3
1.1 Cadre du projet	3
1.1.1 L'entreprise d'accueil	3
1.1.2 Le service d'accueil et son organisation	3
1.1.3 Mission confiée et rôle de l'élève-ingénieur	4
1.2 Étude de l'existant	4
1.2.1 L'application pilote (ELSON) et son hébergement initial	4
1.2.2 Méthode de l'audit technique	5
1.2.3 Résultats de l'audit	5
1.3 Critique de l'existant	6
1.3.1 Cinq carences structurantes	6
1.3.2 Distinction entre l'application et le socle	7
1.3.3 Positionnement par rapport aux modèles existants	7
1.4 Problématique et objectifs	7
1.4.1 Problématique et questions dérivées	7
1.4.2 Objectifs et critères de succès	8
1.5 Périmètre, contraintes et démarche	9
1.5.1 Périmètre et hypothèses assumées	9
1.5.2 Contraintes du projet	10
1.5.3 Démarche méthodologique	10
Conclusion du chapitre	11
2 État de l'art et choix technologiques	12
2.1 L'architecture Zero Trust	12
2.1.1 Du modèle périmétrique au Zero Trust	12
2.1.2 Les sept principes directeurs	12
2.1.3 Limites reconnues du modèle	13

2.2	L'approche DevSecOps	13
2.2.1	Principe et portes de contrôle automatisées	13
2.2.2	Provenance, intégrité et référentiels	13
2.3	Supervision et ingénierie de la détection	14
2.3.1	Système de supervision acheté ou construit	14
2.3.2	La détection comme code	14
2.3.3	La matrice des techniques d'attaque	14
2.3.4	Étude comparative et solution retenue	14
2.4	Enrichissement sémantique des alertes	15
2.4.1	Approches disponibles	15
2.4.2	Modèles de langue spécialisés	15
2.4.3	Travail le plus proche et différences	16
2.5	Choix de la plateforme d'hébergement	16
2.5.1	Critères d'évaluation et options écartées	16
2.5.2	Critère décisif et prix du choix	16
2.6	Méthodes d'analyse de risque	17
2.7	Synthèse : verrous identifiés et positionnement	17
2.7.1	Verrous identifiés	17
2.7.2	Positionnement de la contribution	18
	Conclusion du chapitre	18
3	Analyse des besoins et modélisation des menaces	19
3.1	Acteurs et cas d'utilisation	19
3.1.1	Acteurs légitimes et acteurs hostiles	19
3.1.2	Cas d'utilisation du socle	20
3.2	Spécification des besoins	20
3.2.1	Besoins fonctionnels	20
3.2.2	Besoins non fonctionnels	21
3.3	Analyse de risque	22
3.3.1	Valeurs métier, biens supports et sources de risque	22
3.3.2	Scénarios stratégiques	23
3.3.3	Scénarios opérationnels	23
3.3.4	Appréciation et traitement du risque	23
3.4	Exigences de sécurité et traçabilité	24
3.4.1	Les vingt exigences de sécurité	24
3.4.2	Matrice menace → exigence → contrôle → test	24
3.5	Rattachement aux référentiels	25
	Conclusion du chapitre	26
4	Conception de l'architecture	27
4.1	Principes directeurs de conception	27
4.2	Architecture générale	27
4.2.1	Modèle en couches	28
4.2.2	Justification des deux plans transversaux	28
4.2.3	Vue de déploiement	28

4.3	Vue dynamique : les sept flux	29
4.4	De l'attaque à l'incident : fonctionnement de bout en bout	31
4.5	Conception par couche	32
4.6	Le plan d'identité : la segmentation réelle	32
4.6.1	Matrice des identités et des droits	32
4.6.2	Fédération de la chaîne d'intégration	34
4.6.3	Secrets et chiffrement	34
4.7	Couverture des exigences de sécurité	34
4.8	Décisions d'architecture	34
4.8.1	Registre des décisions	34
4.8.2	Composants évalués puis écartés	35
4.9	Écarts entre la conception et l'implémentation	35
	Conclusion du chapitre	37
5	Réalisation et industrialisation	38
5.1	Environnement de travail	38
5.1.1	Environnements et organisation du dépôt	38
5.1.2	Frontière entre le code et l'exploitation	39
5.2	Infrastructure as code	39
5.2.1	Mise en œuvre et sécurité de l'état	39
5.2.2	Détection de dérive et limites constatées	39
5.3	Chaîne de livraison applicative	40
5.3.1	Étapes et portes bloquantes	40
5.3.2	Authentification sans secret permanent	41
5.3.3	Refus vérifiables	41
5.4	Chaîne de provisionnement de l'infrastructure	41
5.5	Chaîne de détection	42
5.5.1	Collecte filtrée et modèle de données	42
5.5.2	Traduction des règles de détection	43
5.6	Couche d'enrichissement sémantique	44
5.6.1	Préparation et exécution du modèle	44
5.6.2	État d'avancement réel de la couche	44
5.7	Interface de supervision	45
5.7.1	Rôles, flux et second facteur	46
5.7.2	Le logiciel écrit : structure, tests et dette assumée	46
5.8	Boucle entre livraison et détection	47
5.9	Accueil d'un second locataire : preuve vivante et limites	48
5.9.1	Mise en œuvre concrète	48
5.9.2	Limites à signaler	49
5.10	Conduite du projet	49
5.10.1	Déroulement et tâches quotidiennes	49
5.10.2	Difficultés rencontrées	49
5.10.3	Changements apportés aux objectifs initiaux	50
5.10.4	Planning de travail	51
	Conclusion du chapitre	51

6	Validation, résultats et démonstration	52
6.1	Stratégie de validation	52
6.2	Résultats de la campagne de tests	52
6.2.1	Synthèse des vingt tests	52
6.2.2	Analyse des non-conformités	54
6.3	Évaluation de la détection	55
6.3.1	Couverture obtenue	55
6.3.2	Ce que le système ne détecte pas	55
6.3.3	Qualité et délai de détection	55
6.4	Évaluation de l'enrichissement sémantique	56
6.4.1	Comparaison aux méthodes de référence	56
6.4.2	Boucle entre livraison et détection	56
6.5	Performance, résilience et coût	56
6.5.1	Objectifs de service	56
6.5.2	Reproductibilité et résilience	57
6.5.3	Coût réel	58
6.5.4	Ordre de grandeur des postes de coût	59
6.6	Conformité aux référentiels	59
6.7	Démonstration du fonctionnement global	59
6.7.1	Scénario exécuté	59
6.7.2	Contrôles complémentaires exécutés en direct	60
6.7.3	Correspondance avec les preuves de soutenance	60
6.7.4	Ce que le scénario ne couvre pas	60
6.8	Limites et menaces à la validité	61
6.9	Réponse aux objectifs du projet	61
	Conclusion du chapitre	62
	Conclusion générale	63
	Bibliographie/Netographie	65
A	Études comparatives détaillées	68
A.1	Audit de l'existant et positionnement (issus du chapitre 1)	68
A.2	État de l'art et choix technologiques (issus du chapitre 2)	69
A.2.1	Les sept principes du NIST SP 800-207	69
A.2.2	Référentiels mobilisés	71
A.2.3	Familles de contrôles automatisés de sécurité	71
A.2.4	Comparaison des solutions de supervision	71
A.2.5	Comparaison des modes d'exécution	72
A.3	Choix de la plateforme et des briques techniques	72
A.3.1	Les six options d'hébergement sur dix critères	72
A.3.2	Les douze briques retenues à l'intérieur de la plateforme	73
A.3.3	Sources et dates de consultation	74
B	Extraits techniques de la réalisation	75
B.1	Organisation réelle du dépôt d'infrastructure	75

B.2	Trois extraits représentatifs	75
B.2.1	Deux rôles du compte applicatif	75
B.2.2	Prévention de l'accès public au média	76
B.2.3	Fenêtre et cadence de la règle R2	76
B.3	Sécurité de l'état d'infrastructure	76
C	Modèle de menaces détaillé	78
C.1	Rappel des flux et de la méthode	78
C.2	Échelles employées	78
C.3	Scénarios opérationnels	78
C.4	Cartographie du risque	80
C.5	Décisions de traitement	81
C.6	Formulation complète des vingt exigences de sécurité	82
D	Conception détaillée	83
D.1	Conception détaillée par couche	83
D.2	Registre complet des décisions d'architecture	87
D.3	Composants évalués puis écartés	89
D.4	Prise en charge des vingt exigences par la conception	89
E	Protocoles et preuves de validation	91
E.1	Paramètres de la campagne	91
E.2	Modèle de fiche de test	91
E.3	Protocoles détaillés	91
E.4	Synthèse	93
F	Jeu d'évaluation de l'enrichissement sémantique	94
F.1	Constitution du jeu d'évaluation	94
F.2	Méthodes comparées	94
F.3	Métriques	94
F.4	Résultats par méthode	95
F.5	Validation distincte déjà exécutée — porte de qualité sur le modèle	96
G	Glossaire technique complémentaire	97
H	Preuves d'exécution complémentaires	98
H.1	Preuves complémentaires disponibles	98
H.2	Preuves à produire au rejeu des protocoles	98
H.3	Règles de production et de masquage	100

Table des figures

1	Modèle de sécurité avant le projet : périmètre unique en entrée, confiance implicite à l'intérieur.	5
2	Diagramme de cas d'utilisation du socle	22
3	Vue de contexte : le socle, ses acteurs et les systèmes extérieurs dont il dépend .	28
4	Modèle en couches : cinq couches empilées (L1, L3, L4, L5, L6) et deux plans transversaux (L2, L7). Pointillés : collecte F4 ; tirets : vérification d'identité à chaque saut.	29
5	Vue de déploiement : composants, liens réseau et flux F1 à F5. Le tableau de bord n'atteint les données que par l'API, avec autorisation par rôles (JWT). Le trait tireté vers l'entrepôt ne traverse pas le réseau privé : il est autorisé par l'identité seule (écart É11). Le provisionnement de l'infrastructure (F7) et la boucle de priorisation (F6) sont traités au chapitre 5.	30
6	Séquence du flux nominal F1–F2 et points de vérification d'identité (L2). . . .	31
7	De l'attaque à l'incident : cinq repères et budget de latence par segment	31
8	Plan d'identité : droits accordés et interdictions structurantes (cinq identités) . .	33
9	Planification de l'infrastructure sans différence détectée sur l'environnement de recette, le 19/08/2026 : la configuration déclarée correspond à l'état réellement provisionné.	40
10	Chaîne de livraison applicative : huit étapes et trois portes bloquantes	40
11	Chaîne de détection et d'enrichissement : deux cycles indépendants	43
12	Architecture interne des deux logiciels écrits : composants, frontières de déploiement et points d'application du contrôle d'accès	45
13	Vue des incidents de l'interface de supervision, sous un compte analyste, le 23/08/2026 : alerte de la règle R2 rattachée à la technique T1498 et attribuée au locataire concerné.	46
14	Boucle F6 : rapprochement des vulnérabilités livrées et des techniques observées	48
15	Contrôle d'isolation entre locataires exécuté en recette le 19/08/2026 : six vérifications sur six réussies et connexion croisée entre bases effectivement refusée.	48
16	Chaîne d'intégration avant et après correction de la porte d'analyse statique, environnement de recette	50
17	Planning consolidé du stage, du 03/03/2026 au 07/09/2026. Les barres sont une reconstruction macroscopique ; les losanges signalent les jalons exactement datés.	51
18	Refus obtenus au périmètre de l'environnement de recette, tests T1 et T2	54

19	Cloisonnement de l'identité du second locataire, vérifié en direct le 23/08/2026 : deux rôles exactement attribués, et refus de l'usurpation d'identité depuis un compte d'administration.	54
20	Scénario de bout en bout du 19/08/2026 : de l'attaque à l'alerte qualifiée	60
21	Alerte de la règle R2 produite le 19/08/2026 à 16:56:08 UTC : treize requêtes bloquées comptées sur la fenêtre de quinze minutes et attribuées au locataire. .	60
22	Indicateurs de l'enrichissement sémantique en recette, le 19/08/2026 : dernier rattachement automatique produit à 12:16:15 UTC, technique T1556.003, similarité 0,698.	98
23	Retour arrière applicatif par bascule de révision, mesuré le 07/08/2026 : 11,6 s pour la bascule vers la révision précédente, 16,5 s pour le retour vers la dernière révision.	99

Liste des tableaux

1	Objectifs et critères de succès du projet.	8
2	Approches d'association alerte → technique ATT&CK	15
3	Acteurs légitimes et hostiles du modèle	19
4	Besoins fonctionnels	20
5	Besoins non fonctionnels	21
6	Synthèse valeur métier, biens supports et sources de risque	22
7	Matrice de traçabilité menace → exigence → contrôle → test	24
8	Rattachement des exigences aux référentiels	26
9	Chemin réseau effectif des flux, reconstitué depuis le code d'infrastructure. . .	29
10	Les sept flux de l'architecture.	30
11	Matrice des identités et des droits.	33
12	Registre synthétique des décisions d'architecture (justification complète en annexe D).	35
13	Écarts entre conception et implémentation.	36
14	Modèle de données de l'entrepôt de supervision : dix tables, un écrivain chacune	43
15	État d'avancement de la couche d'enrichissement sémantique	45
16	Caractérisation quantifiée des deux logiciels écrits, dépôt vérifié le 25/08/2026.	47
17	Synthèse de la campagne de vingt tests	53
18	Causes connues de non-couverture	55
19	Restauration de la base de données — test réel exécuté le 3 août 2026	58
20	Constats de coût datés, statut à la date de la dernière mesure	58
21	Postes de coût et dimensionnement déclaré (reconstitution, non facturation) . .	59
22	Correspondance entre les preuves du scénario et les sections du rapport	61
23	Limites du dispositif de mesure et de l'évaluation sémantique	61
24	Réponse aux six objectifs mesurables du projet	62
25	Grille complète des 41 critères de préparation au déploiement, par catégorie. . .	68
26	Positionnement complet des trois modèles sur quinze critères.	68
27	Les sept principes du NIST SP 800-207 et leur traduction pour le projet	70
28	Rôle et limite des référentiels retenus	70
29	Familles de contrôles automatisés de sécurité	71
30	Comparaison détaillée des cinq options de supervision	71

31	Comparaison des trois modes d'exécution étudiés	72
32	Comparaison des six options d'hébergement sur dix critères	72
33	Briques techniques retenues, critère décisif et prix payé	73
34	Sécurité du fichier d'état d'infrastructure	77
35	Échelle de gravité	78
36	Échelle de vraisemblance	79
37	Scénarios opérationnels	79
38	Cartographie du risque avant traitement	81
39	Décisions de traitement du risque	81
40	Formulation complète des exigences de sécurité	82
41	Topologie et règles de filtrage réellement déclarées.	85
42	Prise en charge des exigences par la conception et état de validation	90
43	Conditions de mesure de la campagne	91
44	Spécification du jeu d'évaluation	94
45	Méthodes de rattachement comparées	95
46	Résultats détaillés par méthode — cellules non mesurées à ce jour, cf. note . . .	95
47	Captures à produire au rejeu des protocoles	99

Liste des graphiques

1	Répartition des 41 critères de préparation au déploiement, par catégorie et par statut (audit du 29/07/2026).	6
2	Démarrage à froid du service d'encodage : moyenne et pic mesurés début août 2026, comparés au budget de la sonde de disponibilité.	57

Introduction générale

Sujet. La sécurité des systèmes d'information repose traditionnellement sur un modèle périmétrique : filtrer en entrée, faire confiance à l'intérieur. Ce modèle a fait ses preuves quand les ressources étaient centralisées et les utilisateurs sur le réseau local. Il ne les fait plus aujourd'hui. Les applications migrent dans le cloud, les données sont accessibles de n'importe où, et les attaques les plus coûteuses exploitent un accès légitime détourné plutôt qu'une intrusion frontale.

MENAL-SARL, entreprise de services informatiques implantée en Mauritanie et en France, a identifié ce risque sur l'une de ses applications clientes : ELSON, une plateforme de collecte participative pour les langues nationales de Mauritanie. Cette application collecte des données d'identité officielle et des enregistrements vocaux, qui constituent des données biométriques. Elle fonctionne, mais elle repose sur un serveur unique, avec confiance implicite entre tous ses composants et sans mécanisme de reproductibilité.

Problématique. Comment concevoir, déployer et surtout *prouver* un socle d'hébergement cloud aligné sur les principes Zero Trust et sur une chaîne de livraison DevSecOps ? La question se pose dans les conditions réelles d'une entreprise émergente : une seule personne pour l'exploitation, un budget de quelques dizaines d'euros par mois, aucune solution de supervision commerciale. Et quel prix faut-il payer, en faux positifs, en latence de détection et en complexité, pour atteindre ce résultat ?

La question n'est pas seulement technique. Elle comporte un coût : une architecture qui ne mesure pas ce qu'elle coûte n'est pas une architecture d'ingénieur. Elle comporte aussi une exigence de preuve. Chaque contrôle doit être associé à un test qui établit son efficacité, plutôt qu'à une simple déclaration de conformité.

Démarche. Le projet suit une démarche en cinq phases. Un audit technique a d'abord établi l'état réel de l'existant. L'analyse de risque a ensuite identifié les scénarios d'attaque les plus critiques, traduits en vingt exigences vérifiables. L'architecture a été conçue autour de quatre principes directeurs : justification obligatoire de chaque composant, identité comme plan de contrôle, intégrité de la chaîne de preuve, description exclusive de l'infrastructure sous forme de code. La réalisation a construit le socle en infrastructure as code, avec deux chaînes de livraison et une chaîne de détection enrichie par un modèle de représentation sémantique. Une campagne de validation confronte enfin les résultats aux objectifs mesurables fixés au départ.

Objectifs. Six objectifs mesurables structurent le projet : supprimer la confiance implicite du réseau (O1), rendre l'infrastructure reproductible (O2), contrôler la chaîne de livraison (O3), détecter les événements de sécurité (O4), enrichir les alertes de façon déterministe (O5), rester exploitable et économiquement soutenable (O6). Chaque objectif est associé à un indicateur, une cible et un moyen de vérification. Le chapitre 6 y répond point par point.

Plan du mémoire. Le chapitre 1 établit le contexte et la problématique sur des faits vérifiés. Le chapitre 2 examine l'état de l'art et justifie les choix technologiques. Le chapitre 3 modélise

les menaces et en déduit les exigences de sécurité. Le chapitre 4 présente l'architecture Zero Trust qui les réalise. Le chapitre 5 rend compte de la réalisation : infrastructure en code, chaînes de livraison et de détection, interface de supervision. Le chapitre 6 confronte l'ensemble à l'épreuve de la mesure : tests adverses, évaluation de la détection, performance, résilience et coût.

Le volume de ce mémoire dépasse le format le plus courant. Ce choix est assumé : le document documente une chaîne complète, du besoin à la preuve, avec sa matrice de traçabilité et son registre des écarts. Ces éléments d'ingénierie sont ce qui distingue un socle vérifiable d'une architecture décrite.

Chapitre 1 Contexte du projet, étude de l'existant et problématique

De l'audit d'une plateforme en exploitation à la formulation d'un besoin de socle

Un projet de sécurité ne se justifie pas par les technologies qu'il emploie, mais par le risque qu'il fait disparaître. Ce chapitre établit sur des faits vérifiés pourquoi ce projet devait être mené. Il présente l'entreprise d'accueil et sa stratégie (section 1.1), puis l'application qui sert de cas réel (section 1.2) et la critique qui en découle (section 1.3). Il formule ensuite la problématique, les objectifs mesurables, le périmètre, les contraintes et la démarche retenue (sections 1.4 et 1.5). Fil directeur : l'application existante fonctionne, mais repose sur un modèle de sécurité périmétrique et un environnement non reproductible. Le projet construit le socle qui corrige ces deux défauts.

1.1 Cadre du projet

1.1.1 L'entreprise d'accueil

MENAL-SARL est une entreprise de droit mauritanien, également implantée en France et fondée en 2025. Elle est spécialisée dans les services informatiques, les technologies numériques et la fourniture de solutions IT. Son siège est à Nouakchott et l'encadrant entreprise de ce projet est M. Houssein Ezzedine. Elle s'est constituée pour répondre à une demande croissante des organisations mauritaniennes en matière de digitalisation, de sécurité des systèmes d'information et de gestion d'infrastructures.

Son activité s'organise en deux axes. Le premier regroupe les services informatiques : architectures cloud sur Google Cloud Platform et AWS, solutions DevSecOps et Zero Trust, applications et API sécurisées, pipelines de données, audit de systèmes existants. Le second couvre la fourniture de matériels et de solutions IT : équipements, installation, déploiement et maintenance. MENAL-SARL se positionne comme un prestataire global, avec l'ambition de devenir un acteur de référence en Mauritanie dans les technologies de l'information.

Le projet relève directement du premier axe. Il vise à doter l'entreprise d'un socle d'hébergement standardisé et réutilisable, capable d'accueillir plusieurs applications clientes. L'application décrite en section 1.2.1 en est le premier cas d'usage, non la finalité.

1.1.2 Le service d'accueil et son organisation

Le projet a été mené dans le périmètre cloud et sécurité de MENAL-SARL, sous l'encadrement de M. Houssein Ezzedine. Ce périmètre couvre les architectures cloud, la sécurité des systèmes d'information et l'exploitation des infrastructures. Le projet est mono-porteur : l'élève-ingénieur est le seul intervenant technique sur le socle, dont il assure la conception, la

réalisation et l'exploitation. C'est l'origine de la contrainte humaine formulée en section 1.5.2. L'interlocuteur métier est le responsable de l'application pilote, qui exprime les besoins et valide les effets sur le service rendu. Les livrables sont revus par l'encadrant entreprise et par l'encadrante académique. Aucun organigramme formel n'existe dans cette structure fondée en 2025 : c'est un fait de terrain et non une lacune de ce rapport.

1.1.3 Mission confiée et rôle de l'élève-ingénieur

La mission effectivement réalisée comporte cinq volets : auditer l'application pilote, formaliser les risques, concevoir un socle Zero Trust et DevSecOps, l'implémenter en infrastructure as code, puis confronter ses contrôles à des tests et à des mesures. En tant qu'élève-ingénieur, j'ai assuré la continuité entre ces étapes. J'ai analysé le dépôt existant, défini les exigences et arrêté les choix d'architecture. J'ai ensuite automatisé le provisionnement et la livraison, instrumenté la détection, documenté les écarts et préparé la validation. L'encadrement a été assuré par M. Houssein Ezzedine pour l'entreprise et Mme Rihem Matoussi pour l'école. La formulation initiale de la lettre de mission n'étant pas disponible, le rapport ne lui attribue pas un libellé reconstruit a posteriori. Le stage s'est déroulé du 3 mars au 7 septembre 2026 ; son planning consolidé figure à la section 5.10.4.

1.2 Étude de l'existant

1.2.1 L'application pilote (ELSON) et son hébergement initial

L'application retenue comme premier cas d'usage du socle est ELSON. C'est une plateforme de crowdsourcing gamifiée. Elle construit des jeux de données parallèles texte et audio pour les langues nationales de Mauritanie, en commençant par l'arabe hassaniya. Les contributeurs traduisent des phrases sources vers le hassaniya, puis enregistrent leur voix. Ils évaluent ensuite les contributions des autres participants. Les données de meilleure qualité alimentent des modèles de reconnaissance vocale, de traduction et de synthèse.

Trois caractéristiques élèvent son niveau d'exigence en sécurité. L'inscription collecte des données d'identité officielle : numéro national d'identité et numéro WhatsApp. Les enregistrements vocaux constituent des données biométriques. Enfin, la compétition est dotée de prix en numéraire, ce qui incite à la fraude et à la prise de contrôle de comptes.

Il ne s'agit pas d'un prototype mais d'une application en exploitation réelle. Le dépôt compte environ 34 600 lignes de code TypeScript et 225 points d'entrée HTTP répartis en 11 routeurs. La base réunit 54 tables PostgreSQL, 17 vues, 15 fonctions et déclencheurs, définies dans 74 fichiers SQL dont 72 migrations. Environ 165 endpoints sont protégés par contrôle administrateur.

Avant le projet, l'application est déployée sur un serveur unique loué chez un hébergeur européen. Les composants sont des conteneurs orchestrés par un seul fichier de composition : frontend Next.js, API Express en cluster, base PostgreSQL 17, pooler PgBouncer, proxy Caddy (TLS), passerelle WhatsApp tierce et sauvegarde locale. Ce modèle, illustré en figure 1, repose sur un pare-feu unique en entrée et une confiance implicite à l'intérieur. Tout composant présent sur le réseau interne y est traité comme légitime. L'audit ci-après donne une illustration concrète de ce défaut structurel.

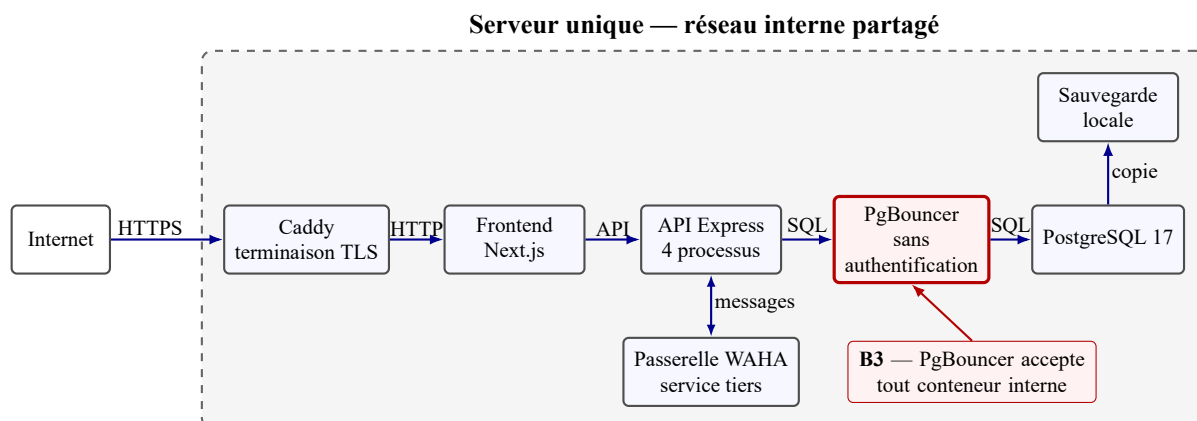


FIG. 1. Modèle de sécurité avant le projet : périmètre unique en entrée, confiance implicite à l'intérieur.

1.2.2 Méthode de l'audit technique

Un audit technique et sécurité a été réalisé le 29 juillet 2026, en amont de toute conception. Il a procédé par analyse statique exhaustive du dépôt : lecture intégrale du code, des configurations, des scripts de déploiement et des 74 fichiers SQL. Aucune exécution ni aucun déploiement n'ont été nécessaires. Cet audit du 29/07/2026 porte sur le dépôt de l'application ; sa grille de 41 critères et ses résultats détaillés sont consignés dans le rapport d'audit correspondant, dont l'annexe A.1 reprend la grille complète.

Deux règles l'ont encadré : la règle de preuve (seul ce qui est réellement présent dans le dépôt est documenté, chemin et ligne cités) et la règle de confidentialité (aucun secret reproduit, valeurs sensibles désignées par leur nom de variable).

Chaque constat a été classé selon une convention de statut à quatre valeurs, reprise dans tout le mémoire. Le statut **Vérifié** désigne un point constaté directement dans un fichier du dépôt, chemin cité. Le statut **À confirmer** désigne un point qui dépend de la configuration d'exécution et n'est pas observable dans le dépôt. Le statut **Absent** signale que rien dans le dépôt ne couvre ce point. Le statut **Recommandé** désigne une proposition d'amélioration, non présente aujourd'hui.

1.2.3 Résultats de l'audit

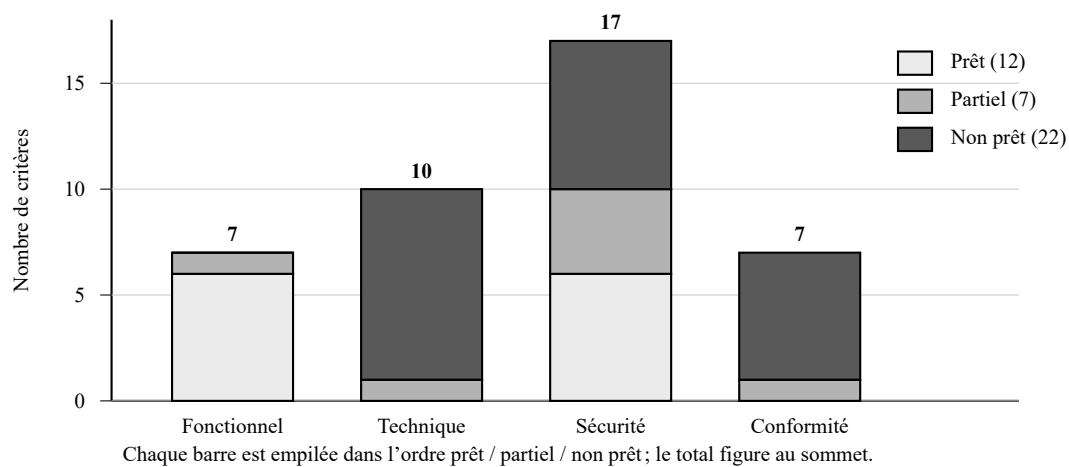
L'audit ne conclut pas à un travail de mauvaise qualité. Plusieurs mécanismes dépassent ce que l'on observe habituellement sur un projet de cette taille. Trois exemples le montrent : absence totale d'injection SQL ou système, sessions avec rotation et détection de réutilisation, intégrité de la compétition assurée par quatorze signaux de fraude. Le code porte la trace de plusieurs cycles de correction antérieurs, et la logique applicative est mûre.

Le problème se situe dans la configuration et l'industrialisation. L'audit identifie six constats bloquants.

- **B1** — compte administrateur par défaut, au mot de passe en clair dans le schéma versionné ;
- **B2** — secret unique partagé par sept mécanismes cryptographiques ;

- **B3** — pooler de base de données accessible sans authentification ;
- **B4** — jeton de téléchargement du corpus non lié à un utilisateur, à une adresse IP ou à un usage unique ;
- **B5** — schéma de base non reconstituable depuis le dépôt, avec trois objets sans définition versionnée ;
- **B6** — état applicatif local au processus, incompatible avec la mise à l'échelle horizontale.

Ces constats se résument dans une grille de 41 critères de préparation au déploiement, détaillée en annexe A.1. Le graphique 1 en donne la répartition par catégorie. Le fonctionnel est prêt à 86 %, tandis que la catégorie technique et la conformité restent à zéro critère prêt. L'application fait ce qu'elle doit faire, mais elle n'est ni reproductible, ni observable, ni conforme, ni déployable de façon maîtrisée.



Graph. 1. Répartition des 41 critères de préparation au déploiement, par catégorie et par statut (audit du 29/07/2026).

1.3 Critique de l'existant

1.3.1 Cinq carences structurantes

En reformulant les constats précédents à un niveau d'abstraction plus élevé, cinq carences structurantes se dégagent. Elles ne sont pas propres à cette application : elles caractérisent un système construit sans socle.

- **C1 — Modèle de confiance périmétrique** : barrière d'entrée unique et confiance implicite à l'intérieur ;
- **C2 — Environnement non reproductible** : infrastructure et schéma de données non décrits en code ;
- **C3 — Chaîne de livraison non contrôlée** : aucun contrôle automatique entre l'écriture du code et sa mise en production ;
- **C4 — Absence d'observabilité et de détection** : événements non centralisés, non corrélés, intrusion non détectée ;

- **C5 — Absence de cadre de conformité** : données d'identité et biométriques traitées sans base légale, sans durée de conservation ni droit d'effacement.

1.3.2 Distinction entre l'application et le socle

Une conclusion importante découle de l'audit : corriger l'application ne suffit pas. Les carences C1 à C5 ne sont pas des défauts de code mais des propriétés absentes de l'environnement d'exécution ; un correctif du code applicatif ne créera ni identité par charge de travail, ni journalisation centralisée, ni chaîne de livraison contrôlée, ni reproductibilité.

Cette distinction fonde le périmètre du projet. Le code applicatif reste hors périmètre. Le socle qui héberge, isole, contrôle, journalise et supervise l'application en constitue l'objet. L'entreprise y trouve un avantage direct : un socle conçu indépendamment de l'application peut accueillir d'autres applications clientes (section 1.1.1).

1.3.3 Positionnement par rapport aux modèles existants

Pour situer la solution visée, trois modèles sont comparés : le modèle A, l'architecture périmétrique de l'existant (section 1.2.1) ; le modèle B, un hébergement cloud managé sans démarche de sécurité explicite ; le modèle C, le socle Zero Trust visé. Les critères comparés proviennent, pour la majorité, des principes de l'architecture Zero Trust [28], et pour les autres, de contraintes d'ingénierie réelles.

La comparaison complète porte sur quinze critères et figure au tableau 26, en annexe A.1. Elle associe à chaque critère et à chaque modèle un niveau de couverture.

Le modèle C domine sur la sécurité et la reproductibilité. Il perd cependant sur trois critères. La simplicité initiale d'abord : un serveur unique se met en service en quelques heures, quand le socle visé demande des semaines de conception. La mise à l'échelle horizontale ensuite, qui reste hors objectif (section 1.5.1). La maturité opérationnelle enfin : une supervision construite sur mesure ne bénéficie d'aucun support éditeur. Ces trois limites, reprises au chapitre 6, sont ce qui rend crédible le reste de la comparaison.

1.4 Problématique et objectifs

1.4.1 Problématique et questions dérivées

Les constats précédents permettent de formuler la question centrale du mémoire.

Comment concevoir, déployer et surtout *prouver* un socle d'hébergement cloud aligné sur les principes Zero Trust et sur une chaîne de livraison DevSecOps ? La question se pose dans les conditions réelles d'une entreprise émergente : une seule personne pour l'exploitation, un budget de quelques dizaines d'euros par mois, aucune solution de supervision commerciale. Et quel prix faut-il payer, en faux positifs, en latence de détection et en complexité, pour atteindre ce résultat ?

Le verbe *prouver* est central : chaque contrôle doit être associé à un test qui démontre son efficacité, plutôt qu'à une simple déclaration de conformité. La question comporte aussi

explicitement un coût : une architecture qui ne mesure pas ce qu'elle coûte n'est pas une architecture d'ingénieur mais un positionnement sans preuve.

Cette question se décompose en six questions dérivées. Chacune est associée à un objectif et à un chapitre de traitement. **Q1** ($\rightarrow$ O2, chap. 5-6) un environnement complet peut-il être détruit puis reconstruit à l'identique depuis le seul dépôt, en combien de temps? **Q2** ($\rightarrow$ O1, chap. 4-6) que reste-t-il atteignable depuis Internet quand le point d'entrée unique est contourné? **Q3** ($\rightarrow$ O1, chap. 4-6) que peut faire un compte ou un service compromis, jusqu'où peut-il aller? **Q4** ($\rightarrow$ O4, chap. 5-6) quelles attaques sont détectées, lesquelles ne le sont pas, en combien de temps? **Q5** ($\rightarrow$ O3, chap. 5-6) qu'est-ce qui empêche une régression de sécurité d'atteindre la production, à quel coût en blocages injustifiés? **Q6** ($\rightarrow$ O5, chap. 5-6) les vulnérabilités livrées peuvent-elles être priorisées selon les menaces réellement observées?

Ces questions portent sur des capacités et non sur des produits : Q2 appelle une réponse en résultat mesuré plutôt qu'un nom de service. Q6 est l'axe original du travail : elle relie sécurité de la chaîne de développement et détection d'incidents, ce que les deux autres modèles (section 1.3.3) ne couvrent pas.

1.4.2 Objectifs et critères de succès

Un objectif qui ne peut pas être mesuré ne peut pas être défendu. Chaque objectif est donc associé à un indicateur, une cible et un moyen de vérification (tableau 1). Ce tableau sert de contrat d'évaluation pour tout le mémoire, et le chapitre 6 y répond point par point.

TAB. 1. Objectifs et critères de succès du projet.

#	Objectif	Indicateur	Cible	Vérification
O1	Supprimer la confiance implicite du réseau	Nombre de tentatives de contournement bloquées lors de la campagne de tests adverses	100 % des scénarios définis	Campagne de tests adverses, chapitre 6
O2	Rendre l'infrastructure reproductible	Part du socle décrite en code d'infrastructure; durée de reconstruction complète d'un environnement	100 % du socle; durée mesurée et documentée	Destruction puis reconstruction chronométrée
O3	Contrôler la chaîne de livraison	Nombre de portes bloquantes; nombre de clés de compte de service exportées	3 portes (secrets, analyse statique, vulnérabilités); 0 clé	Journaux d'exécution de la chaîne d'intégration
O4	Détecter les événements de sécurité	Nombre de règles de détection; couverture des tactiques de la matrice de référence; taux de fausses alertes sur 7 jours	Couverture mesurée et publiée, y compris ses lacunes	Requêtes de détection et mesures, chapitre 6

#	Objectif	Indicateur	Cible	Vérification
O5	Enrichir les alertes de façon déterministe	Précision de l'association alerte → technique d'attaque, comparée à une méthode de référence simple	Gain mesuré, positif ou négatif, sur un jeu annoté	Évaluation comparative, chapitre 6
O6	Rester exploitable et économiquement soutenable	Coût mensuel réel ; disponibilité et latence observées ; existence de procédures d'incident exécutées au moins une fois	Coût de l'ordre de quelques dizaines d'euros par mois ; objectifs de service instrumentés	Facturation, supervision, exécution réelle des procédures

Deux précisions méritent d'être apportées. L'objectif O4 demande de publier ce que le système **ne détecte pas**. L'objectif O5 admet par avance un résultat négatif, condition d'une évaluation rigoureuse.

1.5 Périmètre, contraintes et démarche

1.5.1 Périmètre et hypothèses assumées

Sont dans le périmètre : le socle d'hébergement cloud (filtrage en entrée, identité, exécution des charges, réseau, données, enrichissement, observabilité) et la chaîne de livraison DevSecOps de bout en bout. S'y ajoutent la supervision de sécurité sur un entrepôt de données, l'enrichissement sémantique des alertes, l'interface destinée à l'analyste et des recommandations de conformité.

Restent hors périmètre : le code interne de l'application hébergée et la correction de ses anomalies fonctionnelles. En sont exclus le déploiement multi-région et la reprise d'activité inter-région, ainsi que la mise à l'échelle massive (cache distribué, orchestrateur de conteneurs, maillage de services). Il en va de même de la mise en conformité juridique complète des données d'identité et biométriques au titre du règlement général sur la protection des données (RGPD), qui relève du responsable de traitement.

Le socle prend néanmoins en charge trois obligations techniques attachées à ces données : l'hébergement dans une région unique et documentée, le chiffrement par clés gérées des secrets et de l'espace média, et la journalisation centralisée des accès d'administration. La détermination de la base légale au sens du RGPD, de la durée de conservation et des modalités du droit d'effacement relève du responsable de traitement et reste hors du périmètre : c'est la carence C5, formulée ici et non refermée par ce projet.

Trois hypothèses sont assumées. La première porte sur les environnements : les deux environnements réels (dev/recette) et la production cible sont des projets cloud distincts d'une même région, bâtis sur les mêmes modules d'infrastructure. Seules les variables de dimensionnement changent, la sécurité n'étant jamais un paramètre d'environnement. La deuxième écarte la mise à l'échelle des objectifs du projet : ses limites sont mesurées et

documentées, non contournées. La troisième érige la simplicité en critère d'architecture : tout composant doit justifier son existence, et tout retrait est documenté au même titre qu'un ajout.

1.5.2 Contraintes du projet

Six contraintes structurent la conception du socle.

- **Contrainte humaine** : une seule personne conçoit, réalise et exploite le socle, ce qui écarte les composants à exploitation permanente et impose des procédures écrites ;
- **Contrainte économique** : un budget de quelques dizaines d'euros par mois, qui écarte les solutions de supervision commerciales et impose un filtrage des journaux à la source ;
- **Contrainte technique, exécution** : l'application hébergée écrit sur le disque local et conserve son état en mémoire, ce qui conditionne le mode d'exécution retenu ;
- **Contrainte technique, données** : le schéma de base n'est pas reconstituable depuis le dépôt, ce qui rend sa consolidation préalable à toute migration ;
- **Contrainte réglementaire** : des données d'identité officielle et biométriques, collectées en Mauritanie et dans la diaspora, imposent une région d'hébergement documentée et un chiffrement par clés gérées ;
- **Contrainte temporelle** : la durée du projet de fin d'études, qui impose le phasage avec critères de sortie présenté en section 1.5.3.

1.5.3 Démarche méthodologique

La démarche suit une règle simple : rien n'existe dans l'infrastructure qui n'existe d'abord sous forme de code versionné. Les commandes interactives sont réservées aux opérations ponctuelles, comme la rotation d'un secret ou la réponse à un incident ; elles ne servent jamais au provisionnement. Cette règle répond directement à la carence C2 : reproductibilité complète, contrôle de la sécurité avant création, détection de toute dérive entre l'état décrit et l'état réel.

Le vocabulaire technique employé dans tout le mémoire est défini à sa première occurrence, et repris dans le glossaire de l'annexe G.

Le projet est organisé en cinq phases, chacune fermée par un critère de sortie vérifiable.

- **P0 — Audit et cadrage** : analyse statique de l'existant et objectifs mesurables, clôturée par le rapport d'audit et les constats bloquants identifiés ;
- **P1 — Conception** : architecture en couches, flux nommés, registre des décisions, modèle de menaces, clôturée par une conception validée et justifiée par écrit ;
- **P2 — Socle et infrastructure** : infrastructure en code, réseau, identités, données, clôturée par une infrastructure entièrement décrite en code et une planification sans différence ; la reconstruction complète chronométrée reste à exécuter (chapitre 6) ;
- **P3 — Livraison et détection** : portes de contrôle, identité fédérée, collecte des journaux, règles de détection, enrichissement, clôturée par une chaîne de bout en bout fonctionnelle et des alertes visibles ;

- **P4 — Validation et mesure** : tests adverses, mesures de détection, de performance, de résilience et de coût, clôturée par la confrontation de chaque objectif O1 à O6 à une mesure.

Deux registres accompagnent le projet : celui des décisions d'architecture (option retenue, options écartées, justification) et celui des écarts entre conception cible et implémentation réelle. Ces deux registres sont tenus à jour tout au long du projet. Le chapitre 4 leur consacre une section ; le chapitre 6 rend compte des mesures qui ont contredit certaines hypothèses initiales.

Conclusion du chapitre

Ce chapitre a établi le point de départ du projet sur des faits vérifiés plutôt que sur des intentions. L'entreprise d'accueil cherche à constituer une capacité durable en cloud sécurisé. L'application retenue comme premier cas d'usage est mature sur le plan fonctionnel : 6 critères fonctionnels sur 7 sont satisfaits. Mais l'audit du 29 juillet 2026 montre que 22 des 41 critères de préparation au déploiement ne sont pas remplis, dont six points bloquants.

Ces constats se ramènent à cinq carences structurantes : confiance implicite du réseau, environnement non reproductible, chaîne de livraison non contrôlée, absence d'observabilité et de détection, absence de cadre de conformité. Aucune ne relève du code applicatif ; toutes relèvent de l'environnement d'exécution. L'objet du mémoire n'est donc pas de corriger une application, mais de construire le socle qui la contraint, la surveille et la rend reproductible. Le chapitre suivant examine l'état de l'art des approches disponibles pour répondre à ces carences, et justifie par comparaison argumentée les choix technologiques retenus.

Chapitre 2 État de l’art et choix technologiques

Zero Trust, DevSecOps, ingénierie de la détection et enrichissement sémantique

Le chapitre précédent a mis en évidence des carences et des questions ouvertes sur l’existant, auxquelles des réponses existent déjà : normes, outils, travaux de recherche. Ce chapitre les expose, justifie par comparaison les choix retenus pour ce projet, et identifie ce que l’état de l’art **ne résout pas** : c’est là que se situe la contribution du mémoire. Il suit les quatre domaines mobilisés (Zero Trust, DevSecOps, détection, enrichissement sémantique), une section sur les méthodes d’analyse de risque qui structureront le chapitre 3, puis une synthèse qui positionne la contribution.

2.1 L’architecture Zero Trust

2.1.1 Du modèle périmétrique au Zero Trust

Le modèle de sécurité traditionnel repose sur une frontière : intérieur réputé sûr, extérieur hostile, filtrage entre les deux. Il s’est dégradé pour trois raisons structurelles : ressources dispersées, utilisateurs connectés depuis n’importe où, attaques les plus coûteuses issues d’un accès légitime détourné plutôt que d’une intrusion frontale. La question n’est plus « comment empêcher d’entrer ? » mais « que peut faire un intrus une fois entré ? »

Le terme *Zero Trust* est popularisé par Forrester Research dès 2010 [20], mis en œuvre à grande échelle par Google sous le nom *BeyondCorp* à partir de 2014 [34], puis formalisé en 2020 par le NIST (**SP 800-207** [28]). Cette publication est la référence normative aujourd’hui : la confiance n’est jamais accordée implicitement, elle est évaluée à chaque accès selon l’identité du demandeur, l’état de son équipement et le contexte.

2.1.2 Les sept principes directeurs

La publication [28] énonce sept principes directeurs. Les trois premiers portent sur les ressources et les échanges. Toute ressource de données ou de calcul est une ressource à protéger (P1). Toute communication est sécurisée quelle que soit sa position réseau (P2). L’accès est accordé par session et jamais définitivement (P3). Les deux suivants portent sur la décision d’accès : celle-ci est déterminée par une politique dynamique tenant compte de l’identité et du contexte (P4), et l’organisation mesure et surveille en continu ses ressources (P5). Les deux derniers portent sur la vérification et l’observation : authentification et autorisation sont appliquées avant chaque accès (P6), et l’organisation collecte le plus d’informations possible sur l’état du système (P7).

La traduction de chacun de ces principes pour le projet figure en annexe A.2. Ces sept principes fournissent la grille d’exigences utilisée pour évaluer la conformité du projet au chapitre 6.

2.1.3 Limites reconnues du modèle

Trois limites doivent être mentionnées. La première est le **coût de mise en œuvre** : composants supplémentaires, latence, complexité et points de défaillance additionnels. La deuxième est le **déplacement du risque vers le fournisseur d'identité**, dont la compromission devient l'unique point de défaillance majeur. La troisième est l'**écart entre discours commercial et contenu technique** : un produit portant le nom « Zero Trust » ne rend pas un système Zero Trust.

Une déclinaison pratique publiée en 2025 [7] confirme qu'aucune mise en œuvre n'est valable pour tous les contextes et place la surveillance continue au centre du dispositif. Le projet retient cette approche progressive, et la limite du point de défaillance unique en particulier : le chapitre 6 comporte un test de compromission d'une identité de service.

2.2 L'approche DevSecOps

2.2.1 Principe et portes de contrôle automatisées

Le DevOps a réduit le délai entre écriture du code et mise en production, au prix d'un goulot d'étranglement : la sécurité, vérifiée jusque-là par audit. Le DevSecOps déplace les contrôles vers l'amont (*shift-left* [32]) et les automatise. Le point souvent négligé est le caractère **bloquant** du contrôle : un avertissement qui n'empêche pas le déploiement ne change rien au comportement des équipes [25].

Quatre familles de contrôles sont couramment intégrées : la **détection de secrets** versionnés [12], l'**analyse statique** du code (SAST), l'analyse de **composition logicielle** (SCA) étendue aux images, et l'analyse de l'**infrastructure en code**. La question posée par chaque famille et les outils libres correspondants figurent en annexe A.2.

La quatrième famille n'est possible que si l'infrastructure est décrite en code [22], ce qui la rend analysable avant existence ; argument repris au chapitre 5.

2.2.2 Provenance, intégrité et référentiels

La **provenance** des artefacts est une préoccupation plus récente : prouver qu'un artefact déployé provient du code et de la chaîne attendus. Des compromissions documentées ont rendu cette exigence concrète [9]. Trois réponses coexistent : le **SBOM** (SPDX/CycloneDX), la **signature d'artefacts** (Sigstore) et le cadre **SLSA**, qui définit des niveaux progressifs d'exigence [23]. Aucune n'est mise en œuvre ici : choix assumé au chapitre 4, sans réponse à une carence du chapitre 1 ; ces réponses figurent en perspectives.

Pour les risques applicatifs, la référence est le classement de l'OWASP [26]. Sa dernière édition place le contrôle d'accès défaillant en tête et la mauvaise configuration en deuxième position, contre la cinquième en 2021, ce qui valide le constat du chapitre 1. Elle ajoute une catégorie pour la chaîne d'approvisionnement logicielle, faisant des contrôles de la § 2.2.1 une exigence de référentiel.

Pour la plateforme, la référence est le **CIS GCP Foundation Benchmark** [8, 13] : plus de cent contrôles répartis en sept domaines. La version employée n'est pas consignée dans les

sources disponibles ; aucun taux de conformité n'est donc publié. Ce référentiel permet aussi d'exprimer des **écarts assumés** : documenté et justifié, un écart est une décision d'ingénierie ; non documenté, une négligence. Détail en annexe A.2.

2.3 Supervision et ingénierie de la détection

2.3.1 Système de supervision acheté ou construit

Un SIEM remplit historiquement quatre fonctions : collecter des journaux hétérogènes, les normaliser, y appliquer des règles, présenter les alertes. Son modèle économique facture le volume ingéré, ce qui **incite à collecter moins**. Cette incitation contredit le septième principe du Zero Trust (§ 2.1.2), et le coût reste inaccessible pour un budget contraint.

Une évolution s'est dessinée : dissocier **stockage et interrogation** (entrepôt de données généraliste) de la **logique de détection** (code versionné), soit le *SIEM sur entrepôt de données*. Avantages : coût aligné au volume, langage standard, rétention longue, aucune dépendance à un éditeur. Inconvénients : ni règle, ni interface, ni corrélation, ni support fournis. Un compromis, non une supériorité.

2.3.2 La détection comme code

Le format **Sigma** [31] est à la détection ce que SQL est aux bases de données : une manière neutre d'exprimer une règle, indépendante du moteur, en YAML lisible (source, condition, faux positifs, criticité, techniques associées).

Sigma permet de traiter les règles comme du code source ; mais aucun moteur pris en charge ne cible l'entrepôt de données retenu ici. La traduction est donc manuelle, ce qui plafonne le volume de règles maintenable et la couverture de détection. Ce plafond est mesuré au chapitre 6.

2.3.3 La matrice des techniques d'attaque

La matrice **MITRE ATT&CK** [21, 33] recense les comportements d'attaquants en tactiques (l'objectif) et techniques (le moyen) : vocabulaire commun conception/détection, grille de couverture, référentiel cible pour l'enrichissement (§ 2.4).

Précaution méthodologique : la version 19 (28 avril 2026) a scindé la tactique d'évasion des défenses en deux, portant la matrice Entreprise à quinze tactiques, 222 techniques et 475 sous-techniques. **Toute mesure de couverture sans version indiquée n'est donc pas comparable.** La version employée dans ce mémoire est indiquée en annexe ; en revanche, le rapport ne publie aucun taux de couverture, faute d'inventaire versionné des techniques applicables au périmètre.

2.3.4 Étude comparative et solution retenue

Cinq options ont été comparées sur neuf critères (produit SIEM commercial, service SIEM cloud, pile de recherche libre auto-hébergée, solution libre intégrée, entrepôt de données couplé à une détection en code ; détail en annexe A.2). La contrainte budgétaire du chapitre 1 élimine les deux premières. Le **critère décisif** entre les trois restantes est la capacité à appliquer un

apprentissage automatique aux alertes stockées sans les exporter : seule la dernière option le permet. Prix de ce choix : absence de règles, d'interface d'analyste et de support, soit trois chantiers (chapitre 5) et trois risques (chapitre 6).

Le mode d'exécution des charges a fait l'objet d'une comparaison similaire (annexe A.2); décision et conséquences relèvent du chapitre 4.

2.4 Enrichissement sémantique des alertes

Une règle de détection produit une alerte : horodatage, adresse, ressource, message. L'analyste doit répondre à trois questions qu'elle ne contient pas : *quel comportement d'attaquant? est-ce grave? que faire?* Ces questions forment le premier poste de charge à disparaître quand l'équipe se réduit à une personne. L'automatiser revient à associer chaque alerte à une technique ATT&CK et à afficher la conduite à tenir.

2.4.1 Approches disponibles

Quatre familles permettent cette association (tableau 2).

TAB. 2. Approches d'association alerte → technique ATT&CK

Approche	Principe	Limite décisive
Mots-clés / regex	Table écrite à la main	Ignore les reformulations ; maintenance manuelle
Similarité vectorielle (TF-IDF)	Statistique du texte	Ignore le sens ; formulations équivalentes éloignées
Modèles de langue spécialisés	Proximité vectorielle = proximité de sens	Déterministe, exécution locale ; pas d'explication en langue naturelle
Modèles génératifs	Le modèle rédige l'interprétation	Non déterministe, coût par appel, injection d'instructions

La troisième est retenue. Le dernier point de la quatrième ligne est un argument de **sécurité**, non de performance : les journaux contiennent par construction du texte de tiers non fiables. Le soumettre à un modèle génératif transmet une entrée contrôlée par l'attaquant à un composant qui suit des instructions ; un modèle produisant un simple vecteur numérique n'exécute aucune instruction.

2.4.2 Modèles de langue spécialisés

Les modèles généralistes fondés sur l'architecture Transformer [11] traitent mal le vocabulaire de la cybersécurité, d'où des modèles spécialisés comme **SecureBERT** [5]. Rapprocher deux descriptions d'attaque nécessite une représentation par **phrase** : l'architecture Sentence-BERT [27].

ATT&CK-BERT combine les deux [1, 2] : un modèle de phrases entraîné pour que deux descriptions d'une même action soient proches dans l'espace vectoriel. Il s'exécute localement, sans appel externe, point essentiel vu le coût et la nature des données traitées.

2.4.3 Travail le plus proche et différences

Le travail le plus proche est **SMET** (*Semantic Mapping of CVE to ATT&CK*), IFIP DBSec 2023, étendu en 2024 [3] : il associe une vulnérabilité publiée à des techniques d'attaque via ATT&CK-BERT et une régression logistique, avec des résultats supérieurs aux approches fondées sur des jeux de données annotés. Cette proximité doit être énoncée clairement : l'idée n'est pas nouvelle.

Trois différences précises séparent SMET de ce projet. L'**entrée** d'abord : SMET traite une description de vulnérabilité rédigée et structurée, ce projet une alerte de détection courte et bruitée. Le **régime** ensuite : SMET opère hors ligne sur un corpus constitué, ce projet vise un traitement périodique en recette, sous contrainte de latence et de coût. La **finalité** enfin : SMET enrichit la connaissance d'une vulnérabilité, ce projet **prototype le réordonnement des vulnérabilités détectées à la livraison selon les menaces observées**.

Cette dernière différence constitue l'hypothèse d'apport du mémoire : **réintroduire l'observation d'exploitation dans la décision de développement**, objet de la question Q6 du chapitre 1.

2.5 Choix de la plateforme d'hébergement

Les sections précédentes ont comparé des méthodes et des familles d'outils. Il reste à justifier la plateforme qui les héberge. L'application pilote tournait avant le projet sur un serveur unique loué chez un hébergeur européen. La migration vers un fournisseur de cloud est une décision, non un préalable : elle est argumentée ici et enregistrée au chapitre 4 sous la référence D00.

2.5.1 Critères d'évaluation et options écartées

Six options ont été examinées sur dix critères : trois grands fournisseurs de cloud, un fournisseur européen généraliste, un hébergeur européen à forfait comparable à l'existant, et un hébergeur mauritanien. Le détail figure en annexe A.3.

La contrainte humaine du chapitre 1 écarte les deux dernières options. Une personne seule ne peut pas exploiter en même temps un filtrage applicatif, un gestionnaire de clés, un annuaire d'identités par charge de travail et un entrepôt de journaux, ni les maintenir à jour. Ces briques ne sont pas des préférences : elles conditionnent la faisabilité des vingt exigences du chapitre 3. Cet arbitrage a un coût, énoncé plus bas.

La contrainte économique écarte ensuite les modèles facturés au forfait. Le socle doit pouvoir ne rien coûter lorsqu'il ne sert pas, ce que seule une facturation à l'usage permet.

2.5.2 Critère décisif et prix du choix

Entre les trois fournisseurs restants, le critère décisif découle de la décision prise plus haut (§ 2.3.4) : le système de supervision est bâti sur un entrepôt de données généraliste, et la recherche de similarité doit s'exécuter dans cet entrepôt plutôt que dans une base spécialisée. Un seul des trois fournisseurs réunit, dans un même service, le stockage, le langage de détection, la recherche vectorielle et un palier gratuit couvrant le volume du projet. Les deux autres

imposeraient un composant supplémentaire, ce que le principe P1 du chapitre 4 interdit. Google Cloud est retenu sur ce critère.

Trois critères sont perdus, et ils doivent être lus avec la même attention. Le **coût direct** d'abord : un serveur à forfait chez un hébergeur européen reste moins cher que le socle retenu, à périmètre de calcul comparable. La **réversibilité** ensuite : l'architecture d'origine, faite de conteneurs et d'un fichier de composition, était portable d'un hébergeur à l'autre ; le socle retenu ne l'est plus, et sa reconstruction chez un autre fournisseur demanderait de remplacer le filtrage applicatif, l'entrepôt, la gestion des clés et la fédération d'identité. La **proximité géographique** enfin : aucun des fournisseurs examinés n'exploite de région en Afrique de l'Ouest, et le socle est hébergé dans une région européenne unique. Un hébergeur mauritanien serait le seul à satisfaire ce critère, et le seul à ne satisfaire aucun des six autres.

Le prix du choix se résume en une phrase : le projet échange de la réversibilité et du coût direct contre des briques de sécurité qu'une personne seule n'aurait pas pu exploiter. Le chapitre 6 mesure la part de ce coût qui est vérifiable, et signale celle qui ne l'est pas.

2.6 Méthodes d'analyse de risque

La conception d'une architecture de sécurité suppose d'avoir déterminé contre quoi l'on se protège. Trois méthodes ont été comparées. **STRIDE** [30] (Microsoft) applique six catégories de menaces à chaque flux et à chaque composant : l'analyse technique est fine, mais elle ne traite ni les enjeux métier ni les sources de risque. **EBIOS Risk Manager** [4] (ANSSI) déroule cinq ateliers, des valeurs métier au traitement du risque, en passant par les sources de risque et les scénarios stratégiques et opérationnels : elle relie le risque technique à l'enjeu métier, mais reste plus lourde à mettre en œuvre. **ISO/IEC 27005 :2022** [19] fournit un cadre général de gestion du risque, sans méthode opératoire directement applicable.

Choix retenu : une combinaison des deux premières. EBIOS structure l'analyse de haut niveau : valeurs métier, sources de risque, scénarios stratégiques. STRIDE dérive les scénarios opérationnels flux par flux, les valeurs à protéger étant déjà identifiées (données, identités, compétition dotée de prix) et l'architecture décrite par des flux nommés. Le chapitre 3 en tire la matrice *menace* → *exigence* → *contrôle* → *test*, élément central du mémoire.

2.7 Synthèse : verrous identifiés et positionnement

2.7.1 Verrous identifiés

L'examen de l'état de l'art fait apparaître quatre verrous, c'est-à-dire quatre points où les réponses disponibles ne s'appliquent pas directement au projet.

- **V1** (origine § 2.1.3 ; traité aux chapitres 4 et 5). Les architectures Zero Trust de référence supposent une équipe de sécurité ; aucune n'est dimensionnée pour une exploitation par une seule personne.
- **V2** (origine § 2.3.2 ; traité aux chapitres 5 et 6). La détection comme code ne dispose pas de moteur de conversion vers l'entrepôt de données retenu : la traduction est manuelle et la couverture plafonnée.

- **V3** (origine § 2.4.3 ; traité au chapitre 6). Les modèles de rapprochement sémantique sont évalués sur des textes bien formés, non sur des alertes courtes et bruitées issues d'un système en exploitation.
- **V4** (origine § 2.4.3 ; traité aux chapitres 5 et 6). Aucun travail examiné ne traite directement la boucle entre vulnérabilités détectées à la livraison et menaces observées en exploitation.

2.7.2 Positionnement de la contribution

Le mémoire ne revendique aucune contribution théorique nouvelle. Sa contribution est d'ingénierie et se formule en quatre points.

1. **Une architecture Zero Trust dimensionnée pour la contrainte réelle** d'une entreprise émergente, avec arbitrages explicités et composants écartés justifiés (verrou V1).
2. **Une chaîne de détection versionnée** sur un entrepôt de données généraliste, avec traduction manuelle des règles et limites de couverture publiées (verrou V2).
3. **Un protocole d'évaluation** d'un modèle de rapprochement sémantique spécialisé face à deux références simples, protocole non exécuté dans la campagne (verrou V3).
4. **Un prototype de boucle** entre chaîne de livraison et chaîne de détection, dont l'effet sur le classement n'est pas mesuré (verrou V4).

Le quatrième point constitue l'hypothèse d'apport principale, encore à valider. Les trois premiers relèvent de la transposition d'un état de l'art à un contexte contraint, avec arbitrages explicités et résultats mesurés.

Conclusion du chapitre

Ce chapitre a montré que les réponses aux carences du chapitre 1 existent, mais qu'aucune ne s'applique telle quelle. Le référentiel Zero Trust fournit sept principes et une méthode progressive, mais suppose des moyens que le projet n'a pas. Le DevSecOps fournit des familles de contrôles éprouvées, adossées à un référentiel applicatif qui fait de la chaîne d'approvisionnement logicielle une catégorie de risque à part entière. La détection comme code fournit un format neutre, mais pas de moteur de conversion vers l'entrepôt de données retenu. Les modèles de rapprochement sémantique existent, mais n'ont pas été évalués sur ce type de texte.

Quatre verrous ont été formulés, et la contribution positionnée par rapport à eux. Le chapitre suivant applique la méthode d'analyse de risque retenue : il détermine les valeurs à protéger, les sources de risque et les scénarios d'attaque, puis construit la matrice qui reliera chaque menace à un contrôle et au test qui en démontrera l'efficacité.

Chapitre 3 Analyse des besoins et modélisation des menaces

De la valeur métier à l'exigence de sécurité vérifiable

Une architecture de sécurité ne se conçoit pas à partir d'une liste de bonnes pratiques, mais à partir d'une réponse à trois questions : qu'est-ce qui a de la valeur, qui voudrait s'y attaquer, et par quel chemin ? Ce chapitre répond à ces trois questions, puis en dérive les exigences de sécurité. Il applique la méthode retenue au chapitre 2 : EBIOS Risk Manager pour l'analyse de haut niveau, STRIDE pour l'analyse opérationnelle des sept flux. Il aborde successivement les acteurs et cas d'utilisation, la spécification des besoins, l'analyse de risque, les exigences de sécurité et leur matrice de traçabilité, puis leur rattachement aux référentiels du chapitre 2. Cette matrice relie le risque analysé ici, l'architecture du chapitre 4, la réalisation du chapitre 5 et les mesures du chapitre 6.

3.1 Acteurs et cas d'utilisation

3.1.1 Acteurs légitimes et acteurs hostiles

L'analyse distingue les acteurs **légitimes**, dont les besoins définissent les fonctionnalités, des acteurs **hostiles**, dont les objectifs définissent les menaces. Cette distinction n'est pas étanche : un compte légitime détourné devient un acteur hostile disposant de droits légitimes, scénario que le modèle Zero Trust cherche à contenir. Le tableau 3 recense les six acteurs légitimes A1 à A6 et les cinq acteurs hostiles H1 à H5, avec leur rôle et leurs moyens d'interaction.

TAB. 3. Acteurs légitimes et hostiles du modèle

Acteur	Rôle ou motivation	Interaction ou moyens
A1 — Utilisateur	Contribue à l'application hébergée	Point d'entrée public (F1)
A2 — Analyste	Consulte, qualifie et documente les incidents	Tableau de bord, lecture et verdict
A3 — Administrateur	Administre la plateforme	Consoles d'administration et dépôts
A4 — Développeur	Modifie le code ou l'infrastructure	Chaînes F3 et F7
A5 — CI	Identité automatisée à privilèges	Fédération sans secret permanent, F3 et F7
A6 — Tâches internes	Détectent et enrichissent	Requêtes et tâches planifiées, F5
H1 — Opportuniste	Gain rapide, cible non choisie	Outils automatisés, vulnérabilités connues
H2 — Intéressé par les données	Valeur du corpus linguistique constitué	Ciblage délibéré, patience
H3 — Participant fraudeur	Gain financier lié aux prix de la compétition	Comptes multiples, manipulation applicative

TAB. 3. Acteurs légitimes et hostiles du modèle (suite)

Acteur	Rôle ou motivation	Interaction ou moyens
H4 — Chaîne d'approvisionnement	Exécution de code chez la victime	Dépendance ou image de base compromise
H5 — Interne ou prestataire	Négligence, curiosité ou malveillance	Accès légitime initial, connaissance du système

Les acteurs A5 et H3 appellent une vigilance particulière. La chaîne CI possède des droits de modification et doit être traitée comme une identité à privilèges. Le participant fraudeur dispose, lui, d'un accès légitime et d'une incitation financière.

3.1.2 Cas d'utilisation du socle

Huit cas d'utilisation structurent le socle, formulés du point de vue de l'acteur et non du composant technique (figure 2). Chacun est rattaché à un flux de l'architecture. UC1, UC2 et UC3 empruntent le point d'entrée public F1; UC4 la chaîne de livraison F3; UC5 la chaîne de provisionnement F7. UC6 s'appuie sur la collecte et la détection F4 et F5, UC7 sur l'enrichissement F5, UC8 sur la boucle de priorisation F6. Les besoins couverts sont l'exposition contrôlée et filtrée, la supervision exploitable et la traçabilité de la décision humaine. Viennent ensuite la livraison contrôlée, le provisionnement reproductible et revu, la détection sans surveillance permanente, la réduction de la charge d'interprétation et la boucle livraison ↔ détection.

UC3 impose que le verdict de l'analyste soit enregistré sans pouvoir altérer les preuves sur lesquelles il porte. D'où, au chapitre 4, la séparation entre tables de preuve en écriture interdite et table de verdict humain. UC8, qui correspond à la question Q6 et au verrou V4, constitue l'apport propre du mémoire.

3.2 Spécification des besoins

3.2.1 Besoins fonctionnels

Les besoins fonctionnels traduisent les carences C1 à C4 identifiées par l'audit du chapitre 1 (tableau 4).

TAB. 4. Besoins fonctionnels

#	Besoin	Segment	Origine
BF1	Exposer les applications derrière un point d'entrée unique, filtré et journalisé	Sécurité	C1
BF2	Attribuer une identité distincte à chaque charge de travail, droits minimaux	Sécurité	C1
BF3	Rendre les données inaccessibles depuis Internet, accès privé uniquement	Sécurité	C1
BF4	Décrire l'intégralité du socle sous forme de code versionné	Ops	C2
BF5	Contrôler automatiquement chaque livraison avant mise en production	Dev	C3

TAB. 4. Besoins fonctionnels (suite)

#	Besoin	Segment	Origine
BF6	Authentifier la chaîne d'intégration sans secret permanent	Dev	C3
BF7	Centraliser les journaux de toutes les couches dans un entrepôt unique	Détection	C4
BF8	Exécuter des règles de détection versionnées sur ces journaux	Détection	C4
BF9	Garantir qu'aucun composant d'analyse ne modifie les preuves qu'il analyse	Sécurité	(propre)
BF10	Associer automatiquement chaque alerte à une technique d'attaque connue	Données	V3
BF11	Présenter à l'analyste incidents, contexte et conduite à tenir	Métier	C4
BF12	Réordonner les vulnérabilités détectées à la livraison selon les menaces observées	Données	V4
BF13	Permettre l'accueil d'une nouvelle application sans reconception du socle	Métier	(entreprise)

BF9 est volontairement absolu : *un moteur de détection ne doit jamais modifier les preuves qu'il analyse*. **BF13** traduit l'objectif d'entreprise du chapitre 1 : aucun composant du socle ne doit contenir de logique spécifique à une application.

3.2.2 Besoins non fonctionnels

Le tableau 5 recense les sept besoins non fonctionnels BNF1 à BNF7, avec pour chacun la cible visée et le moyen de vérification retenu.

TAB. 5. Besoins non fonctionnels

#	Besoin	Cible	Vérification
BNF1	Disponibilité	Objectif de niveau de service instrumenté, mesuré en continu	Supervision, ch.6
BNF2	Latence	Objectif défini et mesuré ; tout dépassement documenté	Supervision, ch.6
BNF3	Coût mensuel	Quelques dizaines d'euros ; poste dominant identifié	Facturation, ch.6
BNF4	Exploitabilité par une seule personne	Procédures écrites et exécutées au moins une fois	Exécution réelle, ch.6
BNF5	Reproductibilité	Reconstruction complète d'un environnement, chronométrée	Reconstruction complète
BNF6	Auditabilité	Chaque décision automatisée journalisée, entrées et version	Inspection des journaux
BNF7	Scalabilité	Volontairement limitée ; limites mesurées et documentées	Déclaration explicite, ch.6

BNF3 : le poste de coût dominant d'une supervision de sécurité n'est pas le calcul mais l'**ingestion des journaux**, d'où le choix de filtrer à la source (chapitre 4). **BNF7** est une limite assumée : le chapitre 6 doit en produire la mesure, faute de quoi l'affirmation reste invérifiable.

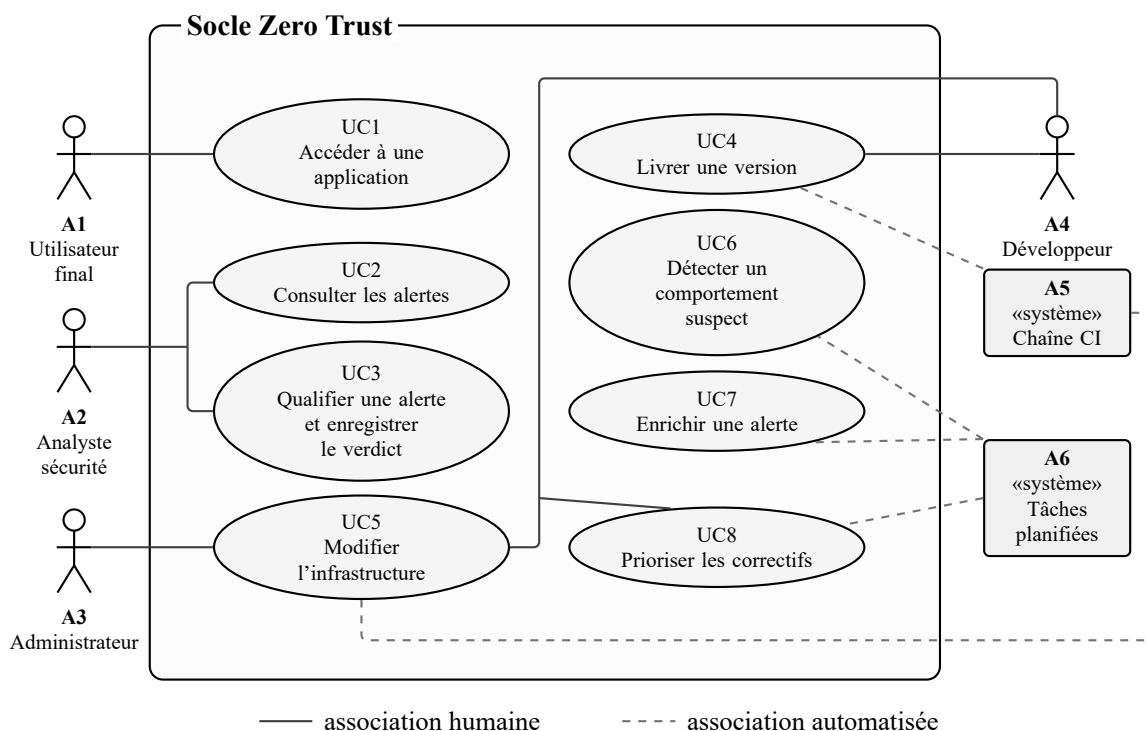


FIG. 2. Diagramme de cas d'utilisation du socle

3.3 Analyse de risque

3.3.1 Valeurs métier, biens supports et sources de risque

Une **valeur métier** est ce dont la perte, l'altération ou la divulgation nuit à l'organisation ; un **bien support** est un élément technique dont dépend une valeur métier. Le tableau 6 croise les six valeurs métier VM1 à VM6, leurs biens supports et les sources de risque associées.

TAB. 6. Synthèse valeur métier, biens supports et sources de risque

#	Valeur métier	Biens supports principaux	Sources / scénarios
VM1	Corpus linguistique	Base, charges, CI, secrets, identités, dépôt	SR2/SR4/SR5 ; SS1, SS2, SS3, SS7
VM2	Identités et voix des contributeurs	Base, secrets, identités, dépôt	SR2/SR5 ; SS1, SS7
VM3	Intégrité de la compétition	Base, identités	SR3 ; SS5
VM4	Disponibilité du service	Base, charges, CI, identités, entrée	SR1/SR4/SR5 ; SS3, SS6
VM5	Intégrité des preuves de supervision	Entrepôt, CI, identités, dépôt, enrichissement	SR2/SR4/SR5 ; SS3, SS4
VM6	Crédibilité technique de MENAL	Ensemble du socle	Conséquence transverse des scénarios

Les biens supports BS1 à BS9 couvrent la base, l'entrepôt, les charges, la CI, les secrets, les identités, le dépôt et l'état, l'enrichissement et le point d'entrée. Les sources SR1 à SR5 sont l'opportuniste, l'acteur cherchant le corpus, le fraudeur, la chaîne d'approvisionnement

et l'interne/prestataire. SR6, acteur étatique organisé, est écarté pour maintenir un périmètre cohérent avec les moyens du projet. VM5 rappelle que protéger les données sans protéger les traces de l'attaque rend la supervision contestable.

3.3.2 Scénarios stratégiques

Sept scénarios stratégiques relient chacun une source de risque à une valeur métier atteinte, par un chemin de haut niveau sans détail technique :

- **SS1** — accès direct à la base de données, copie du corpus et des identités (SR2 → VM1, VM2), gravité critique ;
- **SS2** — obtention et téléchargement de l'URL ou du jeton d'export du corpus (SR2 → VM1), gravité critique ;
- **SS3** — détournement de l'identité de la chaîne d'intégration, déploiement non revu (SR4, SR5 → VM1, VM4, VM5), gravité critique ;
- **SS4** — altération ou effacement des journaux et détections (SR2, SR5 → VM5), gravité grave ;
- **SS5** — contournement des contrôles applicatifs, classement faussé (SR3 → VM3), gravité grave ;
- **SS6** — saturation ou détournement d'un service exposé (SR1 → VM4), gravité significative ;
- **SS7** — divulgation d'un secret permettant de reconstituer des accès légitimes (SR1, SR5 → VM1, VM2), gravité critique.

Trois scénarios sur sept (SS1, SS2 et SS7) correspondent directement à des points bloquants de l'audit du chapitre 1 : l'audit a fourni la matière factuelle de cette analyse.

3.3.3 Scénarios opérationnels

Les scénarios stratégiques sont traduits en chemins techniques par application systématique de STRIDE (usurpation, altération, répudiation, divulgation, déni de service, élévation de privilège) aux sept flux F1 à F7 de l'architecture, définis au chapitre 4. L'application systématique de la méthode aux sept flux produit vingt-quatre scénarios opérationnels, dont huit atteignent le niveau de risque le plus élevé. Ces huit scénarios concernent principalement les chemins de livraison, de provisionnement et d'accès aux données. Le détail figure en annexe C.

3.3.4 Appréciation et traitement du risque

Le croisement gravité × vraisemblance, détaillé en annexe C, place la zone de risque la plus élevée sur la chaîne de livraison et le provisionnement de l'infrastructure (F3, F7), ainsi que l'accès direct aux données (F2). C'est le principal enseignement de l'analyse : le risque dominant ne provient pas de l'application exposée sur Internet, le seul point sur lequel le modèle périmétrique concentrait ses contrôles. Il provient des **chemins d'administration et de livraison**, qui disposent par nature de droits élevés et qui, dans l'existant du chapitre 1, n'étaient soumis à aucun contrôle. Le scénario le plus critique de vraisemblance forte correspond exactement au point bloquant B2 de l'audit.

Les décisions de traitement sont, pour l'essentiel, la **réduction** par des contrôles d'architecture (section 3.4), complétée par deux **acceptations explicites**, datées et révisables ; aucun transfert n'est appliqué, faute d'assurance ou de sous-traitance de sécurité dans le périmètre. Le détail figure en annexe C.

3.4 Exigences de sécurité et traçabilité

3.4.1 Les vingt exigences de sécurité

L'analyse de risque est traduite en vingt exigences de sécurité EX1 à EX20, chacune formulée comme une propriété vérifiable du système plutôt que comme une intention. Chaque exigence découle d'un ou plusieurs scénarios opérationnels et se lit dans la matrice de traçabilité unique du chapitre (tableau 7), qui en donne le libellé court, le contrôle associé et le test correspondant.

3.4.2 Matrice menace → exigence → contrôle → test

Cette matrice (tableau 7) relie formellement les quatre niveaux d'analyse : pour chaque scénario opérationnel, elle établit la chaîne complète du risque analysé jusqu'à sa démonstration. Chaque ligne se lit ainsi : *ce scénario impose cette exigence, réalisée par ce contrôle, dont l'efficacité est démontrée par ce test.*

TAB. 7. Matrice de traçabilité menace → exigence → contrôle → test

Menace	Exigence (libellé court)	Contrôle (couche)	Test de validation
SO1	EX1 — Filtrage avant toute charge de travail	Filtrage applicatif au point d'entrée unique (L1)	T1 — Charges d'attaque connues ; vérification du blocage
SO2, SO3	EX2 — Authentification anormale limitée et détectée	Limitation de débit (L1) ; règle de détection sur échecs répétés (L5)	T2 — Échecs répétés ; blocage et alerte
SO4, SO5	EX3 — Disponibilité sous charge et balayage tracé	Limitation de débit, restriction géographique (L1) ; journalisation (L7)	T3 — Test de charge ; limitation et trace
SO6	EX4 — Données non joignables depuis Internet	Base sans adresse publique, accès privé uniquement (L4, L5)	T4 — Connexion directe externe ; échec attendu
SO7	EX5 — Identité applicative limitée à son périmètre	Une identité de service par charge de travail (L2)	T5 — Lecture de l'entrepôt de supervision ; refus attendu
SO8	EX6 — Accès lié à une identité, sans jeton transmissible	Authentification requise entre services (L2, L3)	T6 — Appel sans jeton ; refus attendu
SO9	EX7 — Aucune clé de longue durée	Identité fédérée, jetons courts, création de clés interdite (L2)	T7 — Inventaire des clés ; tentative de création ; refus attendu

Menace	Exigence (libellé court)	Contrôle (couche)	Test de validation
SO10	EX8 — Aucun artefact vulnérable en production	Contrôle de vulnérabilité bloquant (F3)	T8 — Artefact vulnérable ; blocage attendu
SO11	EX9 — Registre de confiance unique	Registre unique autorisé, droits limités (L2, F3)	T9 — Déploiement depuis source externe ; refus attendu
SO12	EX10 — Aucun secret versionné	Détection de secrets bloquante (F3) ; gestionnaire dédié (L2)	T10 — Secret factice ; blocage attendu
SO13, SO16	EX11 — Preuves non modifiables par l'analyse	Droits d'écriture réservés à la collecte (L2, L5)	T11 — Écriture avec l'identité d'enrichissement ; refus attendu
SO14	EX12 — Interruption de collecte détectable	Supervision de la continuité du flux (L7)	T12 — Interruption volontaire ; alerte attendue
SO15	EX13 — Action privilégiée attribuable	Journaux d'audit du fournisseur activés (L7)	T13 — Action privilégiée ; attribution vérifiée
SO17	EX14 — Inférence à entrée interne	Entrée interne seule ; sortie ni restreinte ni vérifiée (L4, L6)	T14 — Appel sortant ; non exécuté
SO18	EX15 — Charge d'alertes sans compromission	Traitement par lots à cadence fixe (L6)	T15 — Volume anormal ; comportement et coût observés
SO20	EX16 — Aucune ressource hors code versionné	Infrastructure en code exclusive, détection de dérive (F7)	T16 — Ressource manuelle ; détection comme dérive
SO21	EX17 — État privé, versionné, chiffré	Stockage d'état distant, accès restreint (F7)	T17 — Accès non autorisé ; refus attendu
SO22	EX18 — Modification de droits revue	Approbation manuelle obligatoire (F7)	T18 — Changement élargissant des droits ; blocage en attente
SO23	EX19 — Consommation anormale détectée	Supervision de consommation, alerte de budget (L7)	T19 — Consommation simulée ; alerte attendue
SO24	EX20 — Sorties réseau maîtrisées	Aucune règle de sortie : autorisation implicite du fournisseur (L4)	T20 — Destination non autorisée ; non exécuté

Vingt exigences, vingt tests. Ces tests constituent le programme de validation du chapitre 6 ; aucun n'est optionnel, une exigence dont le test n'est pas exécuté reste une déclaration. La matrice se lit dans les deux sens : de gauche à droite elle justifie chaque contrôle par une menace, ce qui empêche d'ajouter un composant parce qu'il est à la mode ; de droite à gauche elle vérifie qu'aucune menace identifiée n'est restée sans réponse. Elle fixe surtout le contenu du chapitre 6 *avant* que celui-ci ne soit écrit : le programme de test est dérivé de l'analyse de risque, non choisi après coup parmi les tests qui réussissent.

3.5 Rattachement aux référentiels

Les vingt exigences sont rattachées aux référentiels du chapitre 2 (tableau 8), pour exprimer la conformité en termes reconnus et identifier les écarts assumés.

TAB. 8. Rattachement des exigences aux référentiels

Référentiel	Exigences concernées	Écarts assumés
Zero Trust ([28])	EX4-EX7, EX11, EX13, EX14, EX20	Aucun principe non traité ; degré mesuré au ch.6
Applicatif ([24])	EX1, EX8-EX10	Code hébergé hors périmètre
Infrastructure (CIS)	EX4, EX5, EX7, EX13, EX16, EX17, EX20	Journalisation des flux et segmentation d'un sous-réseau inutilisé, justifiées par le coût
Techniques d'attaque ([21])	Couverture des scénarios opérationnels	Partielle par construction ; plafond et lacunes publiés au ch.6

La couverture obtenue est publiée avec ses lacunes ; le chapitre 6 en donne le détail.

Conclusion du chapitre

Ce chapitre a transformé les carences du chapitre 1 et l'état de l'art du chapitre 2 en un ensemble d'exigences vérifiables. L'analyse a identifié six valeurs métier, dont l'intégrité de la chaîne de preuve, propre au socle. Elle a retenu cinq sources de risque en écartant explicitement la sixième, puis produit sept scénarios stratégiques et vingt-quatre scénarios opérationnels par application systématique de STRIDE aux sept flux. Le principal enseignement est que les scénarios les plus graves ne concernent pas l'application exposée sur Internet, mais les chemins d'administration, de livraison et d'accès aux données, précisément ceux que le modèle périmétrique de l'existant laissait sans contrôle. Vingt exigences en ont été dérivées, chacune associée à un contrôle et à un test, formant le programme de validation du chapitre 6. Le chapitre suivant présente l'architecture qui réalise ces vingt contrôles : son modèle en couches, ses flux, le registre des décisions qui la justifie et les composants évalués puis écartés.

Chapitre 4 Conception de l'architecture

Modèle en couches, plans transversaux et registre des décisions

Le chapitre 3 a produit vingt exigences de sécurité, chacune dérivée d'un scénario de menace analysé. Ce chapitre présente l'architecture qui les réalise : non un catalogue de composants, mais un système jugé sur la cohérence de son modèle, la justification de ses choix et la rigueur avec laquelle il expose ses écarts. Il se termine sur le registre des décisions, refus compris, et sur les écarts constatés : une architecture qui ne documente que ce qu'elle contient laisse penser que tout ce qui n'y figure pas a été oublié.

4.1 Principes directeurs de conception

Quatre principes ont guidé l'ensemble des décisions ; ils rendent chaque choix contestable, ce qui est une qualité recherchée plutôt qu'une faiblesse.

P1 — Tout composant doit justifier son existence. Un composant ajouté est à configurer, mettre à jour, surveiller et payer. Quand une seule personne exploite le système, il dégrade la sécurité réelle même s'il améliore la sécurité théorique. Règle appliquée : **un composant n'est retenu que s'il couvre une menace du chapitre 3 qu'aucun composant existant ne couvre déjà**. Sept composants ont été écartés à ce titre (section 4.8.2).

P2 — L'identité est le plan de contrôle, pas une couche. Le modèle périmétrique segmente par le réseau. Le modèle retenu segmente par l'identité : chaque charge de travail a la sienne, et ses droits définissent ce qu'elle peut atteindre. Conséquence structurante, développée en 4.2.2 : représenter l'identité comme une couche latérale reviendrait à admettre des chemins où elle n'est pas consultée, soit la définition même de la confiance implicite.

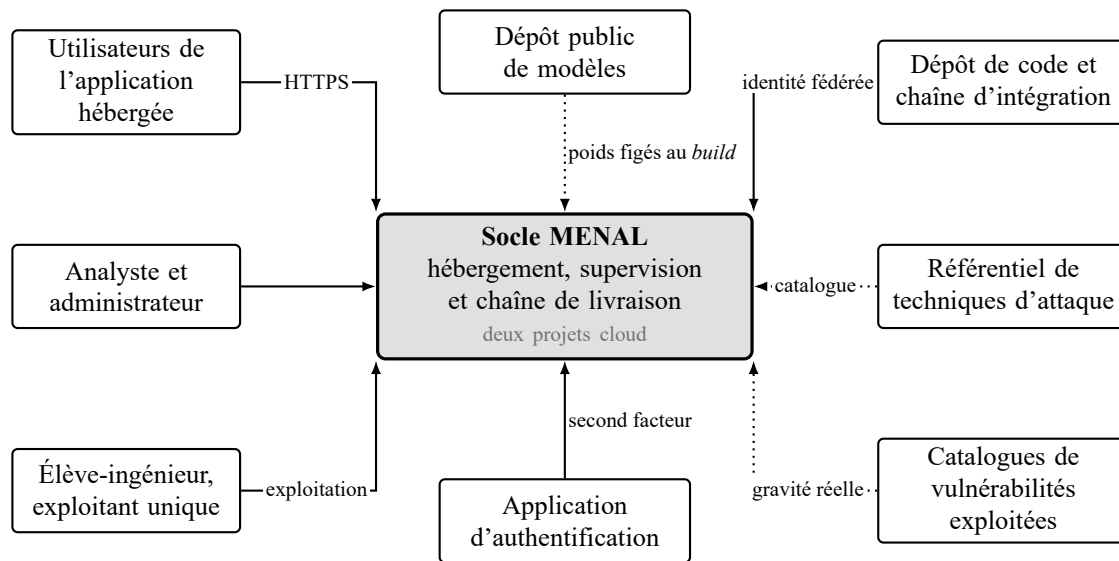
P3 — Un moteur de détection ne modifie jamais les preuves qu'il analyse. Traduction directe de la valeur métier VM5 et de l'exigence EX11. Le principe s'étend au tableau de bord de l'analyste, qui consulte les preuves sans les modifier. Seule exception, explicite : l'enregistrement du verdict humain, une donnée nouvelle et non une modification.

P4 — Rien n'existe dans l'infrastructure qui n'existe d'abord dans le code. Réponse directe à la carence C2 et au point bloquant B5 de l'audit du chapitre 1. Trois effets : reproductibilité, contrôle avant existence (analyse statique avant création de la ressource) et détection de dérive. Les commandes interactives restent réservées aux opérations ponctuelles d'exploitation, jamais au provisionnement.

4.2 Architecture générale

Avant tout détail interne, la figure 3 fixe la frontière du système : ce qui est conçu, exploité et défendu ici, et ce qui lui reste extérieur. Elle nomme aussi ce dont le socle dépend sans le maîtriser — cinq systèmes tiers, dont trois imports de données qui portent le risque de chaîne

d’approvisionnement identifié au chapitre 3 — car une frontière ne se décrit pas seulement par ce qu’elle contient.



Trois catégories d’acteurs et cinq systèmes extérieurs. Trait plein : échange synchrone pendant l’exploitation. Pointillés : import différé, hors du chemin de la requête — une indisponibilité y dégrade l’enrichissement ou la priorisation, jamais le service rendu. Ces trois imports sont les seules entrées de données que le socle ne maîtrise pas : ils portent le risque de chaîne d’approvisionnement H4 du chapitre 3.

FIG. 3. Vue de contexte : le socle, ses acteurs et les systèmes extérieurs dont il dépend

4.2.1 Modèle en couches

L’architecture s’organise en sept niveaux numérotés (figure 4), dont deux plans transversaux plutôt que des couches ordinaires, suivant l’approche recommandée pour les architectures cloud sécurisées [14]. La numérotation résulte d’une révision de la conception initiale, qui comportait deux couches de même numéro et omettait l’enrichissement (L6). Un modèle en couches n’a de valeur que si sa numérotation est unique et ordonnée, condition pour que documentation, code et tests désignent la même chose.

4.2.2 Justification des deux plans transversaux

L2 est un plan parce que l’identité est vérifiée à *chaque* saut — du périmètre aux charges de travail, des charges de travail aux données, de la chaîne d’intégration au registre [28] — portée dont un bloc latéral pointant vers les seules charges de travail ne rendrait pas compte. **L7 en est un** parce que la collecte part de *toutes* les couches pour alimenter l’entrepôt de supervision (L5), qui serait sinon un composant sans aucune source de données.

4.2.3 Vue de déploiement

La vue en couches est logique. La vue de déploiement situe les mêmes éléments comme composants réels reliés par des liens réseau (figure 5). Deux précisions ne s’y lisent pas. Les services applicatifs, qui ne reçoivent de trafic que du périmètre, unique point d’entrée public, sont exposés sur deux domaines distincts. Le service d’encodage, lui, n’a pas de chemin public dans la configuration ; son absence effective de sortie reste à vérifier par T14.

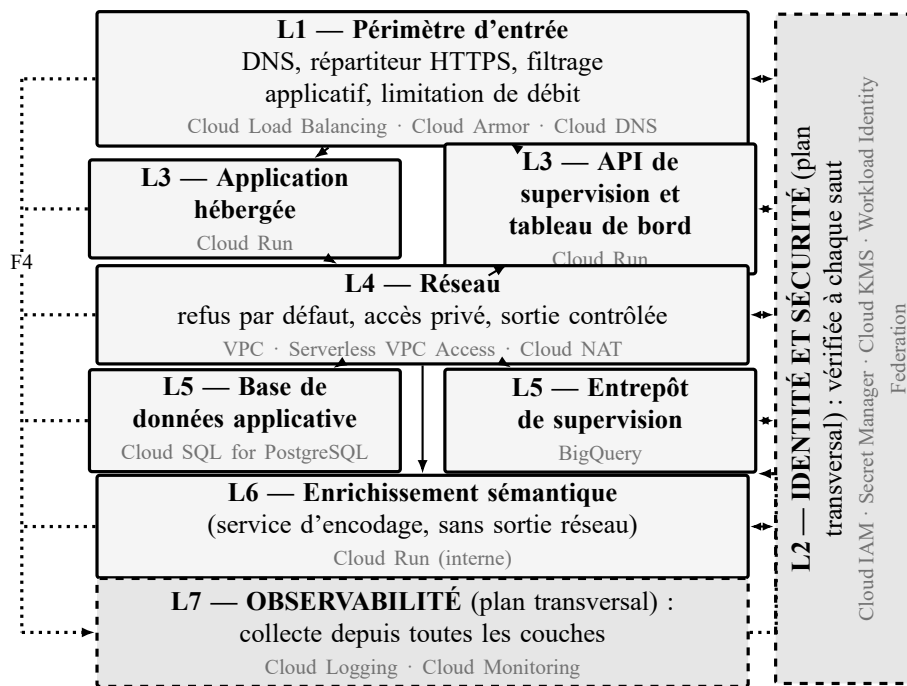


FIG. 4. Modèle en couches : cinq couches empilées (L1, L3, L4, L5, L6) et deux plans transversaux (L2, L7). Pointillés : collecte F4 ; tirets : vérification d’identité à chaque saut.

Chaque capacité est réalisée par un service managé du fournisseur, indiqué en gris sous le libellé de la capacité. La correspondance complète, avec la référence de la ressource déclarée dans le code d’infrastructure, figure en annexe D.

Le plan réseau ne porte pas tous les flux. Le tableau 9 distingue ceux qui traversent effectivement le réseau privé de ceux qui empruntent le chemin managé du fournisseur, autorisés par la seule identité — distinction que la vue de déploiement ne rend pas et que l’écart É11 relève.

TAB. 9. Chemin réseau effectif des flux, reconstitué depuis le code d’infrastructure.

Flux	Chemin réel	Réseau	Contrôle effectif
F1	Internet → répartiteur → service	Managé	Filtrage applicatif, entrée restreinte au répartiteur, TLS 1.2 minimum
F2	API → connecteur → accès privé → base	Privé	Adresse privée exclusive, chiffrement obligatoire, rôle client de base
F2b	API → entrepôt de supervision	Managé	Identité seule : la sortie ne route que les plages privées (É11)
F4	Collecte → entrepôt de supervision	Managé	Identité d’export dédiée, écriture sur un seul jeu de données
F5a	Tâche d’enrichissement → service d’encodage	Privé	Sortie intégrale par le connecteur, jeton d’identité, entrée interne
F5b	Tâche d’enrichissement → entrepôt	Privé	Connecteur, puis accès privé aux interfaces du fournisseur
—	Tableau de bord → API	Public	Ressort par le répartiteur : deuxième passage du filtrage applicatif

4.3 Vue dynamique : les sept flux

La vue en couches décrit ce qui existe ; la vue en flux décrit ce qui se passe. Les sept flux F1 à F7 forment le vocabulaire commun du projet : employés pour l’analyse de menace du chapitre 3,

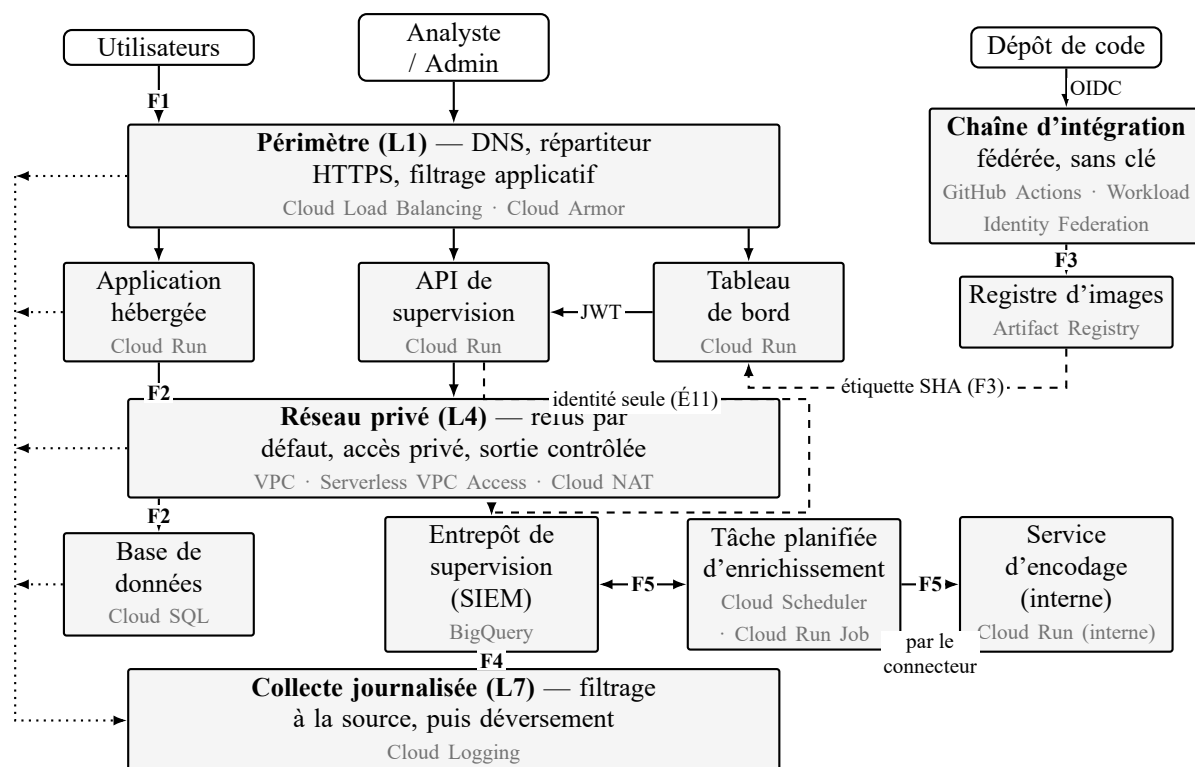


FIG. 5. Vue de déploiement : composants, liens réseau et flux F1 à F5. Le tableau de bord n'atteint les données que par l'API, avec autorisation par rôles (JWT). Le trait tireté vers l'entrepôt ne traverse pas le réseau privé : il est autorisé par l'identité seule (écart É11). Le provisionnement de l'infrastructure (F7) et la boucle de priorisation (F6) sont traités au chapitre 5.

ils le seront pour la réalisation et pour les tests (tableau 10 ; figure 6 pour la séquence du flux nominal F1–F2).

TAB. 10. Les sept flux de l'architecture.

Flux	Chemin	Exigences
F1	Utilisateur → périmètre → filtrage → charge de travail	EX1–EX3
F2	Charge de travail → réseau privé → base de données	EX4–EX6
F3	Dépôt → chaîne d'intégration → registre → déploiement	EX7–EX10
F4	Toutes les couches → collecte → entrepôt de supervision	EX11–EX13
F5	Planificateur → enrichissement → modèle → recherche vectorielle	EX11, EX14, EX15
F6	Vulnérabilités de livraison → encodage → rapprochement → priorisation	apport, aucune exigence
F7	Dépôt → plan → contrôle → approbation → application	EX16–EX18

Le flux F6 est l'hypothèse d'apport de l'architecture. Il relie deux ensembles habituellement disjoints : la chaîne de livraison, qui classe les vulnérabilités par gravité théorique, et la chaîne de détection, qui observe les techniques réellement dirigées contre le système. Le rapprochement réordonne les correctifs : une vulnérabilité moyenne liée à une technique observée cette semaine passe devant une vulnérabilité élevée sans rapport avec l'activité constatée. F6 ne couvre aucune exigence et ne réduit aucun risque par lui-même. Son utilité reste à établir par la comparaison prévue au chapitre 6, non exécutée à ce jour.

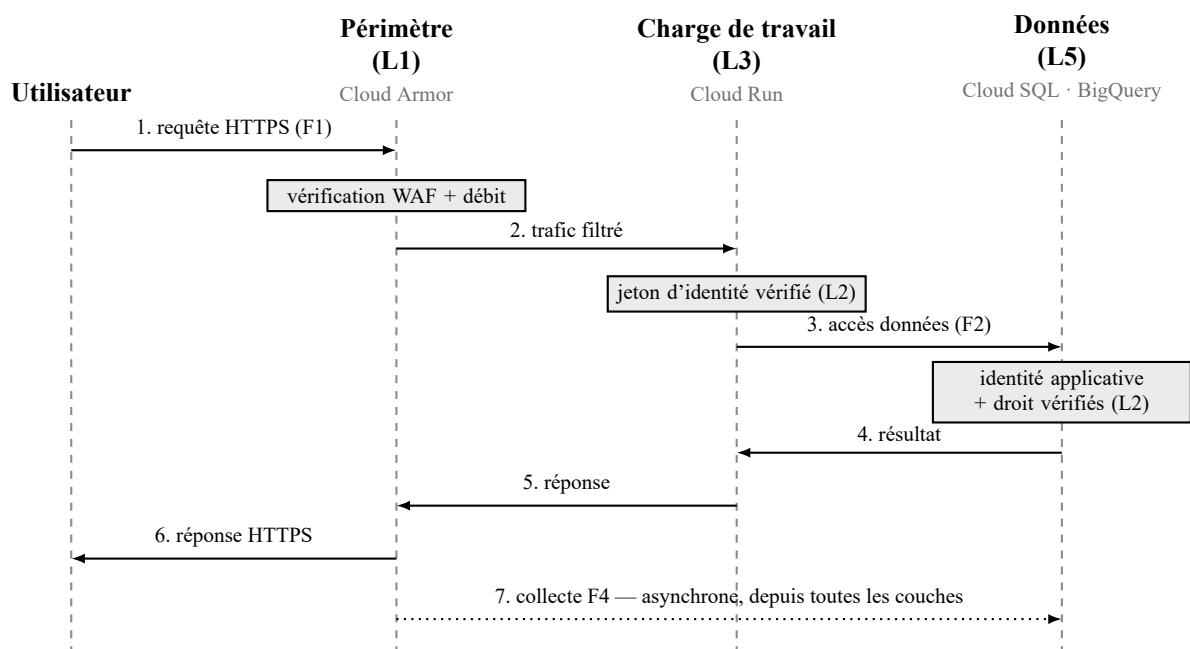
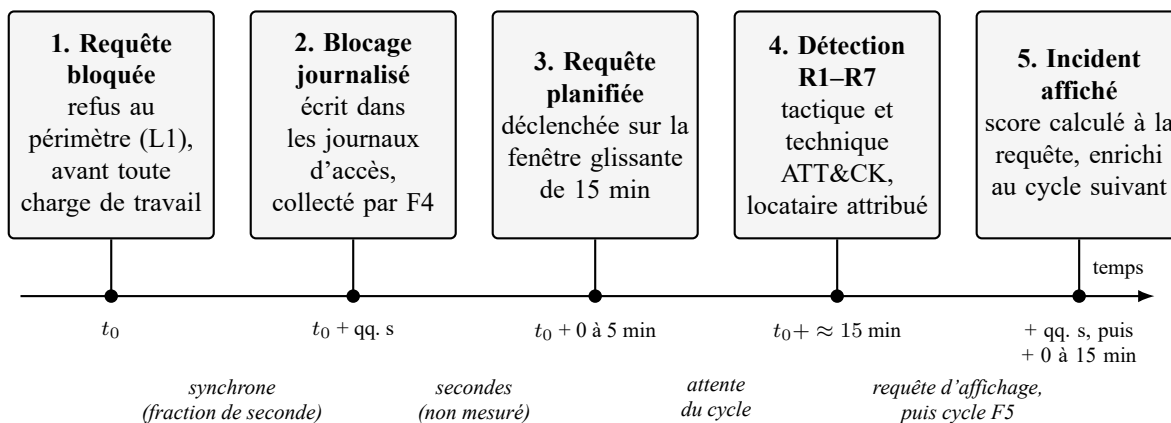


FIG. 6. Séquence du flux nominal F1–F2 et points de vérification d'identité (L2).

4.4 De l'attaque à l'incident : fonctionnement de bout en bout

Entre le moment où une requête malveillante atteint le périmètre et celui où l'analyste voit l'incident qualifié dans son tableau de bord, cinq repères se succèdent, chacun avec son délai (figure 7).



Échelle : repères équi-distants, *échelle non linéaire* — le délai réel est porté par les étiquettes, non par la distance. Repères 3 et 4 mesurés à 6 min 15 s le 10/08/2026 sur un scénario de force brute, et observés à $\approx 15 \text{ min}$ le 19/08/2026 ; repères 2 et 5 décrivent la configuration, pas une latence mesurée.

FIG. 7. De l'attaque à l'incident : cinq repères et budget de latence par segment

Étapes 1 et 2 — Blocage puis visibilité. Le refus au périmètre est synchrone. Aller et retour compris, la requête se compte en fractions de seconde. Aucune ressource applicative n'est sollicitée. Le blocage est ensuite rendu disponible pour la collecte (F4) en quelques secondes attendues. Aucun couple d'horodatages n'est archivé : cette valeur décrit la configuration, pas une latence mesurée.

Étapes 3 et 4 — Qualification (cadence 5 min, fenêtre glissante 15 min). Une **requête planifiée** est une requête enregistrée dans l'entrepôt de données et exécutée automatiquement

à intervalle fixe, sans intervention humaine. Les sept qui portent les règles de détection sont réévaluées toutes les cinq minutes. La **fenêtre glissante** est l'intervalle immédiatement passé sur lequel porte chaque exécution. Elle avance à chaque déclenchement et couvre les quinze dernières minutes. Chaque exécution applique les règles R1 à R7, identifie la tactique et la technique ATT&CK configurées dans la règle, puis associe l'alerte au locataire concerné. Un **locataire** est une application cliente hébergée par le socle, dotée de sa propre identité de service, de ses propres secrets et de sa propre base de données. Deux mesures encadrent ce délai, et aucune n'est un maximum garanti. La première est de 6 min 15 s le 10/08/2026, sur un scénario de force brute qualifié par la règle R1. La seconde est d'environ quinze minutes le 19/08/2026 : ce délai correspond à la fenêtre d'analyse, non à la cadence de réévaluation.

Étape 5 — Incident et enrichissement (secondes, puis 0 à 15 min). L'API de supervision regroupe les alertes par entité et calcule un score à la requête. L'enrichissement sémantique (F5) est ajouté au cycle suivant. La tâche planifiée s'exécute toutes les quinze minutes, calcule le rattachement à une technique d'attaque via le modèle de représentation, puis le stocke. Le délai dépend donc de cette cadence et du démarrage à froid. Le **démarrage à froid** est le délai nécessaire à un service réduit à zéro instance pour démarrer et charger son modèle lorsqu'une requête arrive après une période d'inactivité. Il a été mesuré à 27 s en moyenne et 94 s au pic pour le service d'encodage, et à environ 10,5 s le 07/08/2026 pour le tableau de bord.

4.5 Conception par couche

Chaque couche suit un même gabarit — composants, contrôles apportés, exigences couvertes et point de vigilance — dont le détail intégral, couche par couche, figure en annexe D, section D.1. Deux constats s'en dégagent : le nombre d'exigences ne mesure pas la criticité d'une couche, puisque L5, la moins chargée, porte à elle seule toute la chaîne de preuve, des journaux au score ; et quatre couches sur six — L1, L3, L4 et L6 — désignent une confiance résiduelle qu'un contrôle voisin doit reprendre.

4.6 Le plan d'identité : la segmentation réelle

Cette section traduit le principe P2 : ce qui, dans cette architecture, remplace les pare-feux internes.

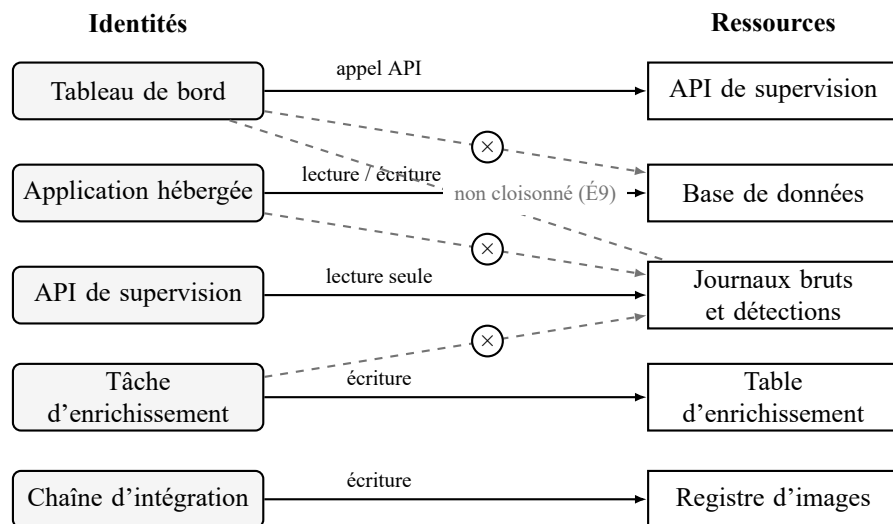
4.6.1 Matrice des identités et des droits

Le tableau 11 recense les identités du socle et leurs droits ; la figure 8 en projette les cinq identités porteuses d'un droit direct sur une ressource, avec leurs interdictions structurantes.

Mise sous forme de graphe, la matrice rend visible ce qu'un tableau montre mal : les interdictions. Elle ne décrit pas des règles réseau, elle décrit qui peut atteindre quoi. Sa ligne la plus significative est celle de la tâche d'enrichissement, dont l'interdiction d'écriture sur les détections empêche un attaquant qui l'aurait compromise d'effacer la trace de son passage (scénario SO16, test T11 du chapitre 6).

TAB. 11. Matrice des identités et des droits.

Identité	Droits accordés	Interdiction structurante
Identité applicative (une par application)	Accès à la base de données ; accès aux secrets de cette application uniquement	Aucun accès à l'entrepôt de supervision
Identité de l'API de supervision	Lecture seule sur l'entrepôt ; accès à la base ; secrets de la plateforme	Aucune écriture sur les preuves — exception unique : la table des verdicts d'analyste
Identité du tableau de bord	Appel de l'API de supervision ; lecture du jeu de données de supervision	Aucun accès à la base de données applicative ; séparation vis-à-vis de l'entrepôt appliquée par le code et non par les autorisations (écart É9)
Identité de la tâche d'enrichissement	Lecture des détections ; écriture uniquement sur la table d'enrichissement ; appel du service d'encodage	Écriture interdite sur les journaux bruts et les détections
Identité de la chaîne d'intégration	Écriture dans le registre ; déploiement ; usurpation contrôlée des identités d'exécution	Aucune clé exportée ; portée limitée au projet de son environnement



Trait plein : droit accordé. Trait tireté barré : **interdiction structurante** — ni l'application hébergée ni la tâche d'enrichissement ne peuvent écrire sur les preuves (scénario SO16, test T11). Trait tireté simple : séparation appliquée par le code applicatif et non par les autorisations. Le tableau de bord passe par l'API de supervision, mais son identité conserve un droit de lecture sur l'entrepôt : c'est l'écart É9.

FIG. 8. Plan d'identité : droits accordés et interdictions structurantes (cinq identités)

4.6.2 Fédération de la chaîne d'intégration

Le point bloquant B2 de l'audit concernait un secret unique gouvernant sept mécanismes ; le scénario SO9 concerne une clé d'identité de longue durée détenue par la chaîne d'intégration. La réponse aux deux est de même nature : **supprimer la classe de risque plutôt que la gérer**. La chaîne d'intégration s'authentifie par fédération d'identité : elle présente une assertion signée par la forge logicielle, vérifiée par le fournisseur cloud, et obtient un jeton de courte durée. Une condition d'attribut restreint cette fédération à un dépôt et une branche précis. Aucune clé de longue durée n'a été trouvée à l'inventaire du 19/08/2026, et aucune n'est déclarée dans le code d'infrastructure. Ce contrôle repose toutefois sur la configuration des modules et sur la revue du plan, non sur une interdiction imposée au niveau de l'organisation. La politique du fournisseur qui interdirait la création de clés de compte de service est inapplicable ici, faute d'organisation cloud sur laquelle l'appliquer (écart É7). L'absence de clé est donc vérifiée par inventaire, pas garantie par une contrainte structurelle.

4.6.3 Secrets et chiffrement

Une leçon de l'audit du chapitre 1 est appliquée sans exception : **un secret par usage, jamais de secret dérivé d'un autre**. Le point bloquant B2 en démontrait le coût, la fuite d'une valeur unique compromettant l'authentification, l'anonymat et l'actif principal. Seconde règle : **l'infrastructure en code crée les conteneurs de secrets, jamais leurs valeurs**, injectées hors du code, pour que le fichier d'état ne devienne jamais un coffre.

4.7 Couverture des exigences de sécurité

Les vingt exigences du chapitre 3 sont toutes prises en charge par au moins une couche ou un flux ; le détail, couche et test associés, figure en annexe D. Cette prise en charge n'est pas une preuve de conformité : l'implémentation et le niveau de test sont évalués séparément au chapitre 6. Trois réserves, portant sur quatre exigences, sont nommées explicitement :

- **EX7** : politique d'organisation inapplicable faute d'organisation cloud (écart É7, section 4.6.2), compensée par les autorisations et l'infrastructure en code.
- **EX9** : le déploiement référence une étiquette égale au SHA du commit, et non une empreinte d'image stricte (écart É8).
- **EX16 et EX18** : la portée est limitée, la couverture étant bornée aux ressources déjà décrites en code et la revue d'approbation restant manuelle.

La correspondance avec les sept principes Zero Trust du chapitre 2 a aussi été vérifiée point par point : l'identité comme plan de contrôle et la mesure continue de l'état y sont les mieux représentés.

4.8 Décisions d'architecture

4.8.1 Registre des décisions

Le registre prouve qu'une architecture est délibérée : chaque décision y figure avec son statut (tableau 12), sa justification complète étant reportée en annexe D. Il en compte quinze, de D00

à D14, la première — le choix d’un fournisseur unique — conditionnant toutes les suivantes, la dernière étant la seule qui porte sur le logiciel écrit plutôt que sur la plateforme.

TAB. 12. Registre synthétique des décisions d’architecture (justification complète en annexe D).

#	Décision	Statut
D00	Google Cloud comme fournisseur unique du socle	Validée
D01	Exécution de conteneurs sans serveur comme unique plateforme	Validée
D02	Point d’entrée unique avec filtrage applicatif	Validée
D03	Base de données managée, adresse privée, restauration à un instant donné	Validée
D04	Entrepôt de données généraliste comme système de supervision	Validée
D05	Modèle de représentation non génératif pour l’enrichissement	Validée
D06	Recherche vectorielle déportée dans l’entrepôt	Validée
D07	Registre d’images unique, retrait du second registre	Retouchée
D08	Fédération d’identité pour la chaîne d’intégration	Ajoutée
D09	Détection de secrets en tête de chaîne	Ajoutée
D10	Autorisation applicative par rôles conservée	Validée
D11	Sortie réseau : route par défaut, aucune règle de sortie déclarée	Réserve
D12	Infrastructure en code comme standard unique de provisionnement	Validée, renforcée
D13	Passage de la base de données en haute disponibilité régionale	Révision de D03 (08/08/2026)
D14	Réécriture du tableau de bord sur cadre à rendu serveur avec passerelle applicative	Validée

La décision D13 illustre la fonction du registre : elle contredit D03, contradiction enregistrée telle quelle plutôt que masquée par une réécriture rétroactive. Un second registre, tenu au fil de la réalisation, compte quinze entrées à la date de référence, de la plus ancienne du 30/07/2026 à la plus récente du 19/08/2026. Les deux registres sont complémentaires (détail en annexe D).

4.8.2 Composants évalués puis écartés

Sept éléments ont été évalués puis écartés en application du principe P1. Un seul l’a été pour un motif de sécurité : le **modèle de langue génératif**, dont la sortie non déterministe et la surface d’injection sont rédhibitoires pour une chaîne de preuve — **ce refus ne sera pas révisé si le contexte change**, contrairement aux six autres. Les six autres — périmètre anti-exfiltration, orchestrateur et maillage de services, cache distribué, déploiement multi-région, signature des images au déploiement, passerelle d’authentification — relèvent d’un arbitrage de coût ou d’une redondance avec un contrôle déjà présent ; leur motif de rejet et leurs conditions de réévaluation figurent en annexe D, section D.3.

4.9 Écarts entre la conception et l’implémentation

Tout projet d’infrastructure produit des écarts entre l’architecture décrite et le système réellement déployé. La question n’est pas de savoir s’il y en a, mais s’ils sont connus, justifiés, datés lorsqu’ils sont clos et mesurés dans leurs conséquences ; les écarts encore ouverts portent, à la place d’une date, leur état d’avancement. Ils figurent donc ici, dans le chapitre de conception, plutôt qu’en annexe (tableau 13).

TAB. 13. Écarts entre conception et implémentation.

#	Écart et cause	Date ou état	Exigence	Statut
É1	Journalisation des refus du pare-feu et de la passerelle de sortie initialement absente	19/08/2026	EX20	Corrigé, déployé et vérifié
É2	Les deux sous-réseaux prévus, public <i>et</i> privé, sont inutilisés : aucune ressource ne les occupe, aucune machine virtuelle n'existe dans le dépôt et les sorties du module réseau ne sont consommées par aucun autre module ; seul le connecteur, doté de sa propre plage, occupe le réseau privé	25/08/2026	—	Retrait décidé, non appliqué
É3	Service d'encodage partage l'identité de la tâche de détection planifiée, faute d'identité dédiée	19/08/2026	EX5, EX14	Corrigé le 19/08/2026, vérifié
É4	Mécanisme de connexion au réseau privé différent de celui prévu (confort d'un composant managé)	en cours	—	Assumé
É5	Cadence de la tâche d'enrichissement plus lente que prévu (arbitrage coût/latence)	mise en œuvre	—	Assumé
É6	Cache d'encodage instrumenté mais non utilisé (non terminé)	mise en œuvre	—	À terminer
É7	Politiques d'organisation décrites en code mais inapplicables sans organisation GCP	19/08/2026	EX7	Ouvert, contrôle compensatoire par IAM et IaC
É8	Déploiement applicatif référencé par une étiquette égale au SHA du commit, et non par une empreinte d'image stricte	19/08/2026	EX9	Assumé, provenance à renforcer
É9	Cloisonnement du tableau de bord non appliqué par les autorisations : l'interface passe par l'API de supervision dans son code, mais son identité de service conserve un droit de lecture sur le jeu de données de supervision et le droit d'exécuter des requêtes ; la séparation est applicative et non structurelle	27/08/2026	EX5	Ouvert
É10	Zone DNS hors du périmètre décrit en code : le schéma du périmètre fait figurer le service de noms, mais aucune ressource correspondante n'est déclarée dans le code d'infrastructure — l'enregistrement est créé à la main, par exception au principe P4	27/08/2026	—	Ouvert
É11	L'accès à l'entrepôt de supervision ne traverse pas le réseau privé : les services d'exécution ne routent que les plages privées par le connecteur, et les appels à l'entrepôt empruntent le chemin managé du fournisseur, autorisés par l'identité seule ; la vue de déploiement laisse croire l'inverse	27/08/2026	EX5	Assumé, documenté

L'écart É3 a été le plus significatif, car il constituait une entorse au principe P2 dans la couche même qui l'illustre. L'identité dédiée a été déployée et vérifiée le 19/08/2026, mais les tests formels de sortie réseau et d'usurpation restent à exécuter. Un incident survenu lors de l'activation du chiffrement par clés gérées a par ailleurs montré qu'un échec partiel peut laisser l'état local différent de l'état réel. Il est relaté en section 5.10.2 du chapitre 5. Les trois derniers écarts, relevés le 27/08/2026, laissent É9 et É10 ouverts et É11 assumé.

Conclusion du chapitre

Ce chapitre a présenté l'architecture conçue pour prendre en charge les vingt exigences du chapitre 3. Quatre principes l'ont guidée : la justification obligatoire de chaque composant, l'identité comme plan de contrôle plutôt que comme couche, l'intégrité de la chaîne de preuve, et la description exclusive de l'infrastructure sous forme de code. Le modèle retenu comporte sept niveaux L1–L7, soit cinq couches et deux plans transversaux. Sept flux nommés structurent la vue dynamique. Le sixième relie les vulnérabilités détectées à la livraison aux techniques d'attaque observées en recette, et son utilité reste à mesurer.

Quinze décisions structurantes ont été enregistrées, de D00 à D14, dont une révision explicite d'une décision antérieure, et sept composants ont été évalués puis écartés. Les onze écarts recensés sont datés lorsqu'ils sont clos, et rattachés aux exigences qu'ils affectent lorsqu'une exigence est en jeu ; deux ont été corrigés et vérifiés le 19/08/2026. Le chapitre 5 décrit la réalisation.

Chapitre 5 Réalisation et industrialisation

Infrastructure as code, chaînes de livraison et chaîne de détection

Le chapitre précédent décrivait une architecture cible ; celui-ci rend compte de ce qui a été effectivement construit. Le texte suit l'ordre de construction et distingue partout trois statuts : **réalisé et vérifié**, **réalisé partiellement** et **prévu mais non réalisé**.

5.1 Environnement de travail

5.1.1 Environnements et organisation du dépôt

Deux environnements réels correspondent à deux projets cloud distincts : le développement, dimensionné au minimum, sert à l'itération rapide et à l'expérimentation. La recette est l'environnement de référence, réduit lui aussi mais de topologie identique à la cible. La production est une cible documentée, non provisionnée, dont le répertoire de configuration ne contient qu'un fichier d'amorçage. Séparer par projet plutôt que par étiquette dans un projet unique rend l'isolation **structurelle** : les ressources d'un environnement ne sont pas adressables depuis l'autre. Cette isolation dépend néanmoins des liaisons d'autorisation accordées à l'identité de déploiement, et n'a pas été éprouvée par un test dédié. Le développement n'est pas non plus un miroir fidèle de la recette. La configuration du second locataire et huit variables liées à l'accueil de plusieurs applications n'existent qu'en recette. La chaîne de promotion développement vers recette puis production n'a donc jamais été déroulée de bout en bout.

Une règle a été appliquée sans exception : les mêmes modules servent partout, seules les variables de dimensionnement changent. La sécurité n'est jamais un paramètre d'environnement, et aucune configuration « sans authentification en développement » ne risque d'être promue par inadvertance. Un quatrième projet, destiné à porter des éléments d'amorçage partagés et prévu par la conception initiale, n'a pas été créé. Ces éléments ont été replacés dans chaque projet d'environnement. Cette simplification est jugée cohérente avec le principe P1 du chapitre 4, et enregistrée comme écart.

Le dépôt d'infrastructure reproduit le modèle en couches du chapitre 4 : un module par couche (fondations, périmètre, identité, charges de travail, réseau, données, apprentissage automatique, observabilité), organisé autour d'un état distant et de fichiers de variables par environnement. L'arborescence complète figure en annexe B. Trois politiques d'organisation avaient été prévues pour interdire l'adresse publique d'une base de données, la création de clés d'identité de service et l'exposition publique d'un espace de stockage. Elles se sont révélées inapplicables dans le périmètre administratif disponible. Ces interdictions sont donc recherchées par la configuration des modules, les contrôles de la chaîne d'infrastructure et la revue du *plan* (différence calculée et relue avant toute modification). Elles ne sont pas des garanties imposées au niveau de l'organisation.

5.1.2 Frontière entre le code et l'exploitation

La règle du principe P4 (chapitre 4) a été appliquée littéralement. Aucune ressource durable créée hors du code n'a été constatée, sous les réserves de portée exposées en section 5.2.2. Restent hors du code, par construction : les valeurs des secrets (le code crée les conteneurs, jamais les valeurs), les données applicatives, les actions de réponse à incident, et le déploiement des images applicatives.

Ce dernier point est la couture la plus délicate entre les deux chaînes, commune à toute équipe combinant infrastructure en code [22] et livraison continue. La chaîne d'infrastructure (F7) crée le service d'exécution et en possède la définition ; la chaîne applicative (F3) met à jour l'image à chaque livraison. Si les deux prétendent posséder le champ « image », chaque exécution de l'une annule le travail de l'autre.

Résolution retenue. La chaîne d'infrastructure possède le service, la chaîne applicative possède l'image. Le code d'infrastructure ignore explicitement les modifications du champ image. La frontière est déclarée une fois, dans le code, plutôt que découverte à chaque conflit.

5.2 Infrastructure as code

5.2.1 Mise en œuvre et sécurité de l'état

Le fichier d'état décrit la topologie complète du système : c'est une donnée sensible, traitée comme telle. Il est conservé dans un espace de stockage dédié, versionné, non exposé publiquement, avec un préfixe distinct par environnement et un verrouillage natif pendant chaque opération. L'accès est limité à l'identité de la chaîne d'infrastructure et à l'administrateur (détail en annexe B).

Décrire les secrets directement en code d'infrastructure, comme le font beaucoup de projets comparables, les fait mécaniquement apparaître en clair dans l'état. Ici, **le code crée les conteneurs de secrets et jamais leurs valeurs**, injectées par un chemin distinct. Aucune valeur sensible n'a été relevée dans l'état lors des revues du 19/08/2026. Son inspection exhaustive sous une identité non autorisée reste l'objet du test T17, non exécuté.

5.2.2 Détection de dérive et limites constatées

La détection de dérive [17], troisième bénéfice attendu du principe P4, repose sur une planification régulière : pour une *ressource déjà gérée dans l'état*, une différence entre la configuration déclarée et la valeur observée produit un plan non vide. Le protocole T16 modifie hors code un attribut réversible d'une ressource gérée, planifie avec rafraîchissement, puis rapproche le résultat des journaux d'audit. Une ressource nouvelle, absente de l'état, échappe à ce mécanisme et exige un contrôle d'inventaire complémentaire. T16 n'a pas été rejoué depuis la correction du protocole ; il reste partiellement conforme au chapitre 6.

Point de vigilance

Deux limites de cette approche ont été rencontrées, et sont rapportées bien que défavorables.
Le verrouillage des versions a dû être corrigé : le fichier de verrouillage et l'initialisation

complète de la validation ont été ajoutés le 19/08/2026 après constat d'un défaut de reproductibilité. Cette correction doit encore être rejouée dans le protocole T16. **Le plan ne prédit pas toujours l'effet réel de l'application** : la planification ne capture pas certaines validations effectuées par le fournisseur au moment de l'application, comme le démontre l'incident détaillé en §5.10.2. La procédure a été amendée en conséquence.

Une fois les correctifs appliqués, la planification du 19/08/2026 ne renvoie aucune différence : l'infrastructure décrite dans le dépôt correspond à l'état provisionné (figure 9).

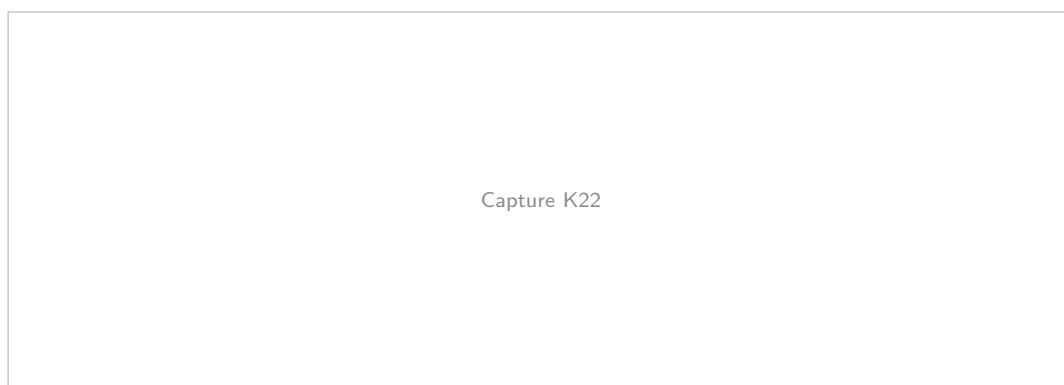
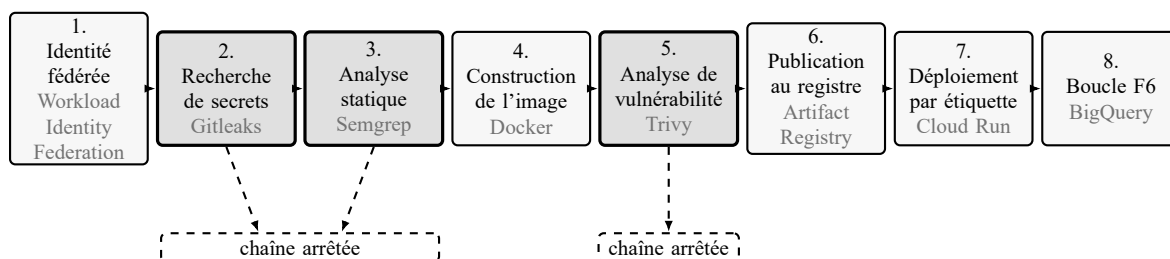


FIG. 9. Planification de l'infrastructure sans différence détectée sur l'environnement de recette, le 19/08/2026 : la configuration déclarée correspond à l'état réellement provisionné.

5.3 Chaîne de livraison applicative

5.3.1 Étapes et portes bloquantes

La chaîne applicative comporte huit étapes, dont trois **portes bloquantes** [25] (figure 10).



*Cadre épais et fond grisé : **porte bloquante** — si le contrôle échoue, la livraison s'arrête (étapes 2, 3 et 5). Les cas de refus correspondants sont décrits au §5.3.3 ; les deux qui disposent d'un protocole numéroté restent à rejouer.*

FIG. 10. Chaîne de livraison applicative : huit étapes et trois portes bloquantes

L'ordre des portes n'est pas arbitraire. La recherche de secrets [12] précède l'analyse statique pour une raison économique : un secret est compromis dès sa publication. Le détecter à la première étape déclenche immédiatement la rotation ; le détecter plus tard ne changerait rien à l'exposition et retarderait la réaction. Le déploiement à l'étape 7 s'effectue **par étiquette SHA** plutôt que par tag mutable, dans l'esprit des cadres de provenance [23], et l'étape 5 s'appuie sur

une analyse de vulnérabilité d'image alignée sur les pratiques recommandées pour les conteneurs [13].

5.3.2 Authentification sans secret permanent

L'étape 1 réalise l'exigence EX7 : la chaîne d'intégration ne détient aucune clé, elle présente une assertion signée par la forge logicielle, vérifiée par le fournisseur cloud, et reçoit un jeton valable dix minutes. Une condition d'attribut restreint cette fédération à un dépôt et une branche précis. Elle a été resserrée en cours de projet, la version initiale acceptant un ensemble plus large de références.

Le mécanisme prévu à l'origine, trois paliers d'identité avec promotion progressive entre environnements, n'a pas été mis en œuvre. Lui ont été préférées une fédération et une identité de déploiement uniques par projet d'environnement, la séparation étant portée par les projets et leurs rôles. Cette réduction du périmètre rend le chemin d'autorisation plus lisible, sans prouver l'impossibilité d'un accès croisé, qui dépend aussi des liaisons IAM effectivement accordées.

5.3.3 Refus vérifiables

Une chaîne de livraison doit être éprouvée par des cas de refus : détection d'un secret factice (T10), détection d'un défaut par analyse statique et détection d'une vulnérabilité critique (T8). Le refus par analyse statique n'a pas de protocole numéroté dans la campagne. Il est documenté par l'incident de porte d'analyse statique rapporté en §5.10.2. Les deux scénarios numérotés ne sont pas comptabilisés comme exécutés tant que leur trace horodatée et leur code de retour non nul ne sont pas archivés.

Un refus supplémentaire, non planifié celui-là, a porté sur le logiciel écrit pour ce projet : la porte d'analyse de vulnérabilité a bloqué une livraison sur une faille critique d'une bibliothèque d'archivage, embarquée par le gestionnaire de paquets de l'image de base. La correction a consisté à retirer ce gestionnaire de l'image finale plutôt qu'à ignorer la vulnérabilité ; c'est un refus réellement survenu, sur le code de l'auteur, et non un scénario rejoué.

5.4 Chaîne de provisionnement de l'infrastructure

La seconde chaîne est automatisée jusqu'au contrôle et manuelle au-delà. Trois étapes s'exécutent dans la chaîne d'intégration : vérification du format, validation syntaxique sur les deux environnements et analyse de sécurité de la configuration en porte bloquante. Celle-ci refuse un espace de stockage public, une base de données dotée d'une adresse publique ou une identité sur-privilegiée. Les deux suivantes, production puis application du plan de modification, restent un geste manuel de l'administrateur, exécuté hors de la chaîne avec ses propres identifiants. La revue du plan a donc lieu, mais sans porte d'approbation automatisée : c'est la réserve qui rend le test T18 partiellement conforme, et non conforme.

Deux principes gouvernent l'ensemble. **Le plan est revu comme du code** : l'infrastructure ne change jamais sans une différence lisible et relue. **L'application est la seule voie d'écriture** : toute modification par un autre chemin devient une dérive, détectée à la planification suivante (section 5.2.2). L'analyse de sécurité de la configuration réutilise l'outil déjà employé pour les images : aucun outil n'a été ajouté, ce qui illustre le principe P1.

Le quatrième scénario de refus porte sur une ressource volontairement mal configurée, dont le blocage doit être constaté avant toute création plutôt que lors d'un audit a posteriori. Il est défini, mais sa trace n'est pas disponible dans la campagne : il reste non exécuté.

5.5 Chaîne de détection

5.5.1 Collecte filtrée et modèle de données

La collecte (flux F4) rassemble vers l'entrepôt de supervision les journaux d'audit du fournisseur, ceux des services d'exécution et les verdicts du filtrage applicatif. Le filtrage est appliqué **à la source**, au moment de la collecte et non après stockage, pour répondre au besoin BNF3. Les contrôles de disponibilité et les réponses statiques réussies, volumineux pour une valeur de détection nulle, sont exclus d'emblée.

L'entrepôt compte dix tables (tableau 14). Six des dix identités d'écriture sont restreintes à une table unique par une liaison de droits, et le score d'incident n'est stocké nulle part. Il est recalculé à chaque requête. Cette séparation vise l'exigence EX11 en réduisant le périmètre d'écriture de la tâche d'enrichissement. Elle ne rend pas les preuves immuables : une identité d'administration ou une liaison IAM excessive pourrait encore les modifier, ce qui doit être contrôlé séparément.

Une réserve porte sur les journaux d'audit du fournisseur. Ceux d'activité d'administration sont collectés et conservés avec les autres sources. Ceux d'accès aux données — entrepôt de supervision, service de secrets, service de clés, base applicative — sont produits sans collecte dédiée. Ils restent dans l'espace par défaut du fournisseur, avec une conservation de trente jours, modifiable. L'attribution d'une action privilégiée visée par l'exigence EX13 n'est donc établie que pour le plan d'administration, ce qui impose d'exécuter le protocole T13 sur les deux plans.

Trois colonnes portent des données à caractère personnel : l'adresse source et l'identifiant d'utilisateur des journaux d'accès, et l'entité des détections, qui est le plus souvent une adresse. Les journaux expirent à quatre-vingt-dix jours ; les détections, qui portent la même adresse, n'expirent pas — écart assumé au titre de la valeur probante, et à trancher par le responsable de traitement.

Les 872 vecteurs de référence couvrent 697 techniques et sous-techniques du référentiel ATT&CK Entreprise [21], sous forme de couples technique × tactique indexés et en lecture seule.

Chaque locataire dispose en outre d'un espace de stockage objet dédié à son média, chiffré par clé gérée, protégé contre tout accès public et administrable en écriture par la seule identité de l'application concernée. Il porte les **enregistrements vocaux** de l'application pilote, données biométriques qui fondent la contrainte réglementaire énoncée au chapitre 1, et suit la règle des secrets. Le code crée le conteneur et les droits, jamais le contenu.

Point de vigilance

La journalisation des refus du pare-feu a été activée et vérifiée le 19/08/2026, ce qui clôt l'écart É1 et rend la source de signal disponible. Elle ne valide pas encore la chaîne complète de

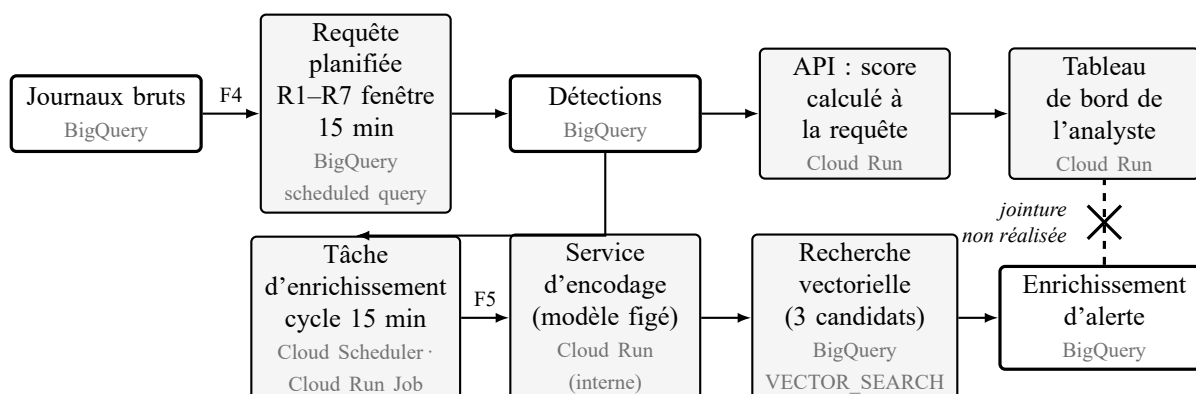
TAB. 14. Modèle de données de l'entrepôt de supervision : dix tables, un écrivain chacune

Table	Contenu	Partition et rétention	Écrivain autorisé	Clé d'application
Journaux d'accès access_logs	Une ligne par requête HTTP applicative	Jour · 90 jours	Normalisation F4 (identité du pipeline)	service
Journaux bruts raw_logs	Charge JSON des quatre sources collectées	Jour · 90 jours	Normalisation F4	resource_name
Détections detections	Alertes R1–R7, tactique et technique ATT&CK	Jour · sans expiration	Requêtes planifiées R1–R7	service
Événements de sécurité security_events	Blocages du filtrage applicatif, déjà mitigés	Jour · sans expiration	Normalisation F4	absente
Enrichissement alert_enrichment	Technique rattachée, similarité, candidats de rang 2–3	Jour · sans expiration	Tâche F5 — droit limité à cette seule table	absente
Métriques api_metrics	Agrégat horaire : volume, erreurs, latence, blocages	Jour · sans expiration	Normalisation F4	absente
Verdicts analyst_verdicts	Jugement humain, ajout seul, jamais de mise à jour	Jour · sans expiration	API de supervision — cette seule table, rôle administrateur	absente
Vulnérabilités cve_findings	CVE du dernier scan, catalogue d'exploitation, score EPSS	Jour · sans expiration	Chaîne d'intégration — cette seule table, réécriture totale	sans objet
Vecteurs de référence attack_embeddings	872 vecteurs de 768 dimensions, catalogue ATT&CK	Aucune	Chargement hors ligne, identité d'opérateur	sans objet
File d'attente ML pending_embeddings	Déclarée, jamais écrite ni lue : vestige du pipeline F5	Aucune	Aucun	sans objet

détection des sorties interdites, le test T20 n'ayant pas été exécuté dans la campagne présentée au chapitre 6.

5.5.2 Traduction des règles de détection

Il n'existe pas de convertisseur automatique depuis le format neutre de règles de détection vers le dialecte de l'entrepôt retenu (chapitre 2). La traduction a donc été réalisée manuellement, selon un gabarit systématique (source, condition de sélection, fenêtre temporelle, agrégation, identifiants, faux positifs connus) détaillé en annexe B. La figure 11 résume la chaîne complète, de la collecte à l'affichage.



Cadre épais : table de l'entrepôt de supervision. Les deux cycles sont indépendants : une détection est affichée dès qu'elle est écrite, son enrichissement arrive au cycle suivant. Le score d'incident est calculé à partir des seules détections — limite énoncée au §5.6.2 et mesurée au §6.4.

FIG. 11. Chaîne de détection et d'enrichissement : deux cycles indépendants

Cette traduction manuelle demande, pour chaque règle, une écriture, une vérification sur données réelles et une maintenance à toute évolution du schéma de journaux. Le volume de règles maintenable par une personne est donc limité, et ce plafond détermine mécaniquement la couverture de détection atteignable : conséquence directe du choix d'architecture D04, anticipée au chapitre 2 (verrou V2) et mesurée au chapitre 6. En contrepartie, les règles sont du code, versionnées, revues et déployées par la chaîne d'infrastructure, et non une configuration saisie dans une interface.

5.6 Couche d'enrichissement sémantique

5.6.1 Préparation et exécution du modèle

Le modèle retenu, identifié au chapitre 2, est un modèle de représentation de phrases spécialisé en cybersécurité, fondé sur les travaux SecureBERT et SMET [5, 2]. Son déploiement en recette a suivi quatre étapes : figement de la version par identifiant de validation, format des poids refusant l'exécution de code à la lecture, vérification d'intégrité par étiquettes cryptographiques et optimisation par export quantifié rejeté.

La fidélité est vérifiée, pas supposée : une validation compare la similarité des deux formats sur un échantillon, et le format d'origine est conservé si l'écart dépasse le seuil. La quantification en entiers, testée puis rejetée, dégradait les représentations au point de ne produire aucune correspondance correcte de premier rang sur cinq cas. Le modèle livré est donc en précision flottante simple. **Les poids sont embarqués dans l'image**, jamais téléchargés à l'exécution, pour ne pas introduire de dépendance externe dans le chemin critique ni de point d'injection dans la chaîne d'approvisionnement.

La configuration du service d'encodage route le trafic par le connecteur prévu et ne lui attribue pas de chemin public direct (exigence EX14, scénario SO17). Le service n'est joignable qu'en interne, avec appel authentifié obligatoire, et se réduit à zéro instance hors traitement, dont l'effet est rapporté en section 5.10.2. Le test dynamique T14 d'absence de sortie n'ayant pas été exécuté, le rapport distingue cette configuration de sa validation. La tâche d'enrichissement retient enfin trois candidats plutôt qu'un, afin que l'analyste compare des alternatives au lieu de recevoir une affirmation unique.

5.6.2 État d'avancement réel de la couche

L'écart entre conception et réalisation est ici le plus important (tableau 15).

Point de vigilance

À ce jour, la couche d'enrichissement produit ses résultats, mais ceux-ci n'alimentent pas le score d'incident présenté à l'analyste. L'enrichissement est calculé, stocké et consultable, jamais intégré au calcul de priorité. Cet écart ne remet pas en cause la démonstration technique : la chaîne complète fonctionne et le chapitre 6 la mesure. Il limite en revanche la portée de l'affirmation possible. Le rattachement automatique produit des candidats consultables sans preuve suffisante de précision, de coût stabilisé ni d'amélioration de la priorisation.

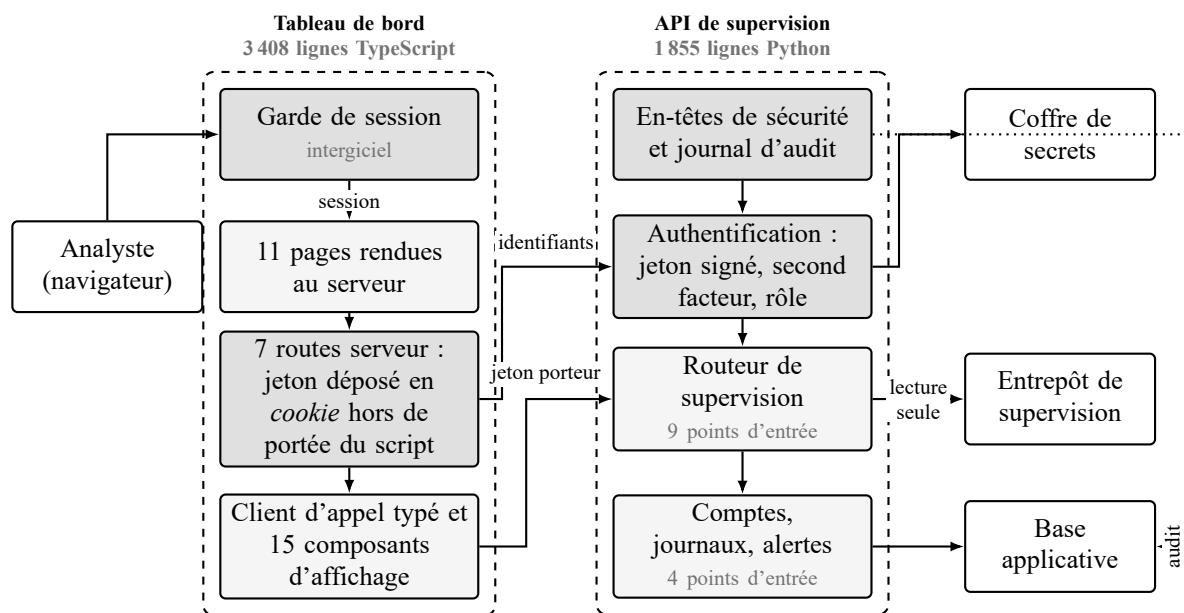
TAB. 15. État d'avancement de la couche d'enrichissement sémantique

Composant	Réalisé	Statut
Préparation et figement du modèle	Oui	Vérifié
Chemin public direct absent dans la configuration	Oui	Réalisé; T14 non exécuté
Table de vecteurs de référence et index	Oui	Vérifié
Tâche d'enrichissement, recherche vectorielle	Oui	Réalisé
Cadence prévue (5 min)	Non — 15 min	Écart assumé (coût)
Cache par étiquette SHA d'entrée	Calculé, jamais exploité	Non réalisé
Vue de corrélation entre alertes	Non	Non réalisé
Enrichissement dans le score d'incident	Non	Écart majeur

Décision du 25/08/2026 : le positionnement informationnel est assumé comme état livré, et la jointure au score d'incident est reportée en perspective. Elle ne se réduit pas à une jointure technique. Elle suppose une jointure contrôlée, une règle de décision évaluée et surtout l'ajout d'une clé d'entité à la table d'enrichissement, aujourd'hui absente de son schéma, ce qui interdit la corrélation par entité sans changement de modèle de données.

5.7 Interface de supervision

L'interface de supervision repose sur une interface web et une API qui l'alimente (figure 12). Tout passe par l'API, qui applique le contrôle d'autorisation. Cette séparation réalise les exigences EX5 et EX6 et évite l'erreur fréquente donnant à une interface web les droits de lecture d'un entrepôt de données.



Trait plein : appel synchrone. Pointillés : écriture au mieux, hors chemin de réponse — son échec est absorbé et ne fait jamais échouer la requête de l'analyste. Tirets : frontière de déploiement, un conteneur par cadre. Fond grisé : composant portant un contrôle de sécurité; le rôle est vérifié sur les treize points d'entrée de données de l'API, jamais dans le tableau de bord, qui ne détient aucune autorisation propre.

FIG. 12. Architecture interne des deux logiciels écrits : composants, frontières de déploiement et points d'application du contrôle d'accès

5.7.1 Rôles, flux et second facteur

Trois rôles sont définis dans le jeton émis par l'API : administrateur (gestion de la plateforme et des comptes), analyste (lecture des incidents, de la matrice de couverture et des vulnérabilités prioritaires, enregistrement d'un verdict) et service (identité non humaine, réservée aux appels automatisés entre composants). Aucun rôle n'est prévu pour les utilisateurs de l'application hébergée : ceux-ci n'accèdent jamais à l'interface de supervision.

Le rôle d'analyste illustre l'exception prévue au principe P3 : il peut écrire un verdict, mais uniquement dans une table qui lui est propre (tableau 14), jamais dans les tables de preuve. Chaque famille de technique d'attaque est associée à une procédure d'incident accessible depuis l'alerte. Les indicateurs affichés incluent délibérément le taux d'alertes non rattachées : afficher ce que le système ne sait pas interpréter est une décision de conception assumée. La figure 13 montre l'interface servie à un compte analyste, sur des détections réelles de la recette.

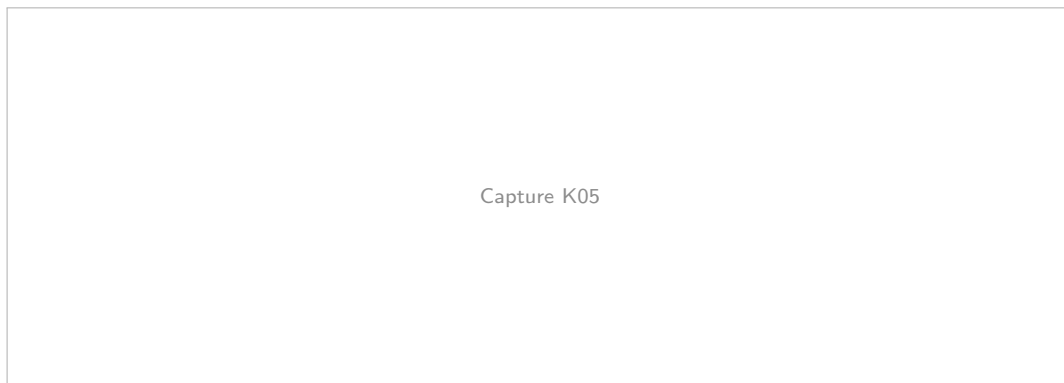


FIG. 13. Vue des incidents de l'interface de supervision, sous un compte analyste, le 23/08/2026 : alerte de la règle R2 rattachée à la technique T1498 et attribuée au locataire concerné.

L'accès au tableau de bord ajoute au mot de passe une vérification par code à usage unique fondé sur le temps. Le point d'entrée qui reçoit ce code n'était couvert que par un limiteur applicatif, non par la limitation de débit du périmètre. Il a été ajouté aux chemins d'authentification protégés le 19/08/2026 et vérifié en conditions réelles le jour même. Onze requêtes successives ont produit dix refus de validation, puis un refus pour dépassement de seuil. C'est cette trace qui étaye le test T2.

Le secret partagé du second facteur était auparavant stocké en clair : une fuite de la base aurait exposé directement tous les secrets. Un chiffrement symétrique applicatif a été mis en place le 19/08/2026, avec élargissement de la colonne et migration non destructive tolérant les valeurs antérieures non chiffrées. La clé est gérée par le service de secrets et injectée à l'exécution. La migration des valeurs déjà en base n'est pas documentée comme exécutée : l'écart n'est pas clos.

5.7.2 Le logiciel écrit : structure, tests et dette assumée

Les deux composants de cette interface sont les seuls éléments du socle écrits ligne à ligne plutôt que déclarés : ils méritent donc d'être caractérisés comme tels (figure 12, tableau 16). L'API applique une séparation en quatre couches — entrée, authentification, accès aux données,

schémas de validation — et le tableau de bord ne fait aucun appel direct à un service de données : il n'existe aucun chemin de code qui contourne le contrôle de rôle.

TAB. 16. Caractérisation quantifiée des deux logiciels écrits, dépôt vérifié le 25/08/2026.

	API de supervision	Tableau de bord
Langage et cadre	Python 3.12, cadre applicatif asynchrone à validation typée	TypeScript, cadre à rendu serveur
Volume écrit	1 855 lignes, 20 modules	3 408 lignes, 40 fichiers
Points d'entrée	21, dont 9 pour la supervision	11 pages et 7 routes serveur
Modèle de données	4 tables, 3 migrations, 22 schémas de validation	16 types partagés avec l'API
Tests automatisés	31 tests, exécutés à chaque livraison	22 tests unitaires exécutés ; 22 tests de parcours écrits mais jamais exécutés par la chaîne
Couverture mesurée	jamais mesurée : l'outil est installé, l'option ne l'est pas	2,99 % des lignes le 08/08/2026, pour un seuil de 70 % déclaré et non appliqué
Dette assumée	aucune version portée par les points d'entrée : un client ne peut pas se lier à un contrat stable	375 lignes d'une interface antérieure, non déployée, conservées au dépôt

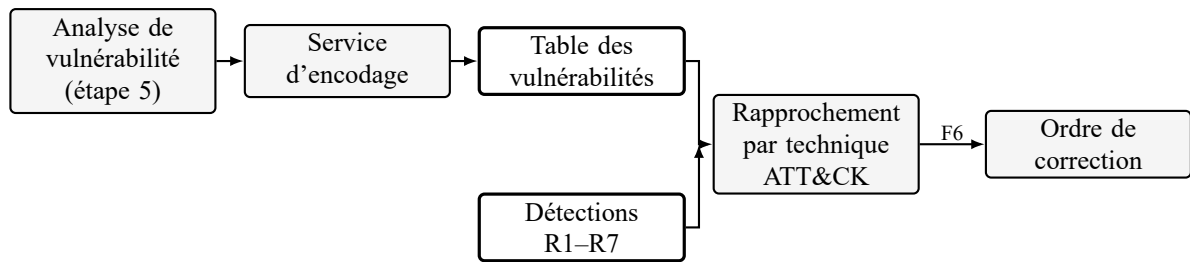
Deux de ces lignes sont défavorables et rapportées comme telles. La couverture du tableau de bord, 2,99 % des lignes, tient à ce que les pages ne sont pas testées : seules les fonctions pures le sont. Le seuil de 70 % est déclaré dans la configuration mais volontairement non imposé à la chaîne, une activation immédiate bloquant toute livraison pour une dette antérieure plutôt que pour une régression. L'absence de version sur les points d'entrée de l'API est sans conséquence tant que le tableau de bord en est le seul client, et deviendrait bloquante à l'ouverture à un client tiers : c'est la condition de réévaluation de cet écart.

Deux comportements de repli doivent enfin être nommés, car ils sont visibles à l'exécution. L'intergiciel qui écrit le journal d'audit absorbe toute exception : une panne d'écriture du journal est donc silencieuse et ne fait jamais échouer la requête de l'analyste. L'arbitrage privilégie la disponibilité de l'interface, mais il est en tension avec l'intégrité de la chaîne de preuve et devra être compensé par une alerte sur l'absence d'écriture. Symétriquement, le tableau de bord bascule sur un jeu de données de démonstration lorsque l'API est injoignable : ce repli est signalé par un bandeau visible et volontairement désactivé sur le flux d'authentification, de sorte qu'aucune session ne peut être ouverte sans l'API.

5.8 Boucle entre livraison et détection

C'est le prototype proposé par le projet, correspondant au flux F6, à la question Q6 du chapitre 1 et au verrou V4 du chapitre 2. Une chaîne de livraison produit des vulnérabilités classées par gravité théorique, indépendante du contexte ; une chaîne de détection produit des techniques d'attaque observées. F6 rapproche ces deux informations, qui coexistent dans le même entrepôt sans se parler. L'étape 8 de la chaîne applicative exporte le résultat de l'analyse de vulnérabilité vers une table dédiée, avec un droit d'écriture limité à cette seule table.

La chaîne de données nécessaire au rapprochement est présente, mais son utilité ne se déduit pas de son fonctionnement technique (figure 14). C'est l'objet d'une mesure du chapitre 6, qui peut conclure à l'absence de différence.



F6 ne couvre aucune exigence de sécurité : il produit un ordre de traitement, pas une réduction de risque. Sa chaîne de données existe ; son utilité reste non validée (§6.4.2) tant que l'ordre produit n'est pas comparé à l'ordre par gravité seule.

FIG. 14. Boucle F6 : rapprochement des vulnérabilités livrées et des techniques observées

5.9 Accueil d'un second locataire : preuve vivante et limites

Le besoin BF13 exigeait que le socle puisse accueillir une nouvelle application sans reconception. Le module d'exécution des services applicatifs, écrit pour l'application pilote, a donc été rendu paramétrique en cours de projet. Le nom de l'application est une variable, et chaque application reçoit sa propre identité, ses propres secrets et son propre service. Une procédure d'accueil a été rédigée. Le socle héberge la plateforme MENAL elle-même, API et tableau de bord, et à côté d'elle l'application pilote ELSON du chapitre 1 : c'est cette seconde instance, désignée plus bas par « le second locataire », qui sert de preuve d'accueil.

5.9.1 Mise en œuvre concrète

Le second locataire a été accueilli en recette le 07/08/2026 par instanciation du module d'exécution paramétrique. Ont été provisionnés : compte de service dédié à deux rôles (client base de données, écriture de journaux), base de données et utilisateur séparés, DNS et certificat gérés, six alertes et une sonde de disponibilité. Depuis le 08/08/2026, les secrets et l'espace média sont chiffrés par clé gérée dédiée.

Un contrôle quotidien d'isolation SQL est exécuté par un job planifié, avec une alerte dédiée ; son exécution du 19/08/2026, reproduite en figure 15, établit que l'identité, les secrets et la base sont effectivement séparés.

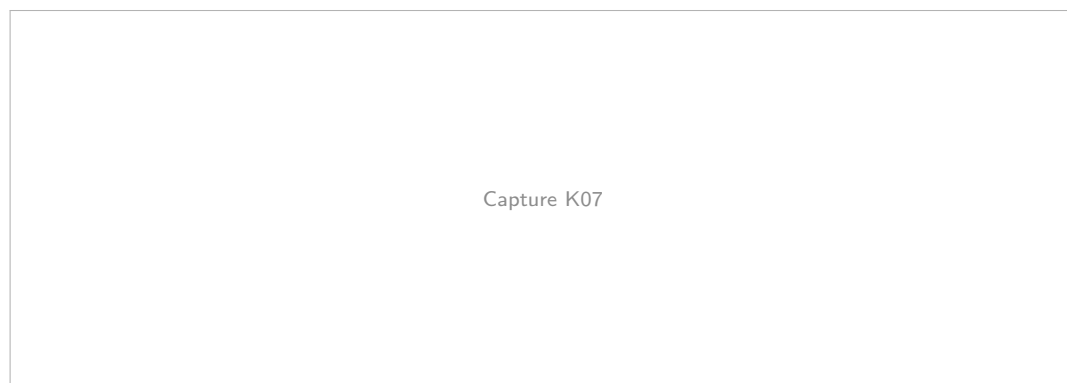


FIG. 15. Contrôle d'isolation entre locataires exécuté en recette le 19/08/2026 : six vérifications sur six réussies et connexion croisée entre bases effectivement refusée.

5.9.2 Limites à signaler

L'isolation est réalisée par l'identité (comptes séparés), les secrets (clés distinctes) et la base de données (base et utilisateur dédiés sur une instance partagée), mais **pas par le réseau**. Le VPC, le connecteur et l'instance SQL sont partagés, et la règle interne est large. Une clé de locataire est partielle dans certaines tables du SIEM, et le module base de données n'est pas réinstanciable. Ces limites définissent un seuil à franchir avant d'accueillir un troisième locataire : l'isolation réseau par VPC distinct ou par règles de pare-feu internes dédiées.

L'expérimentation montre la réutilisabilité partielle du module d'exécution, sans suffire à qualifier le socle de produit multi-locataire abouti. Son coût de sécurité doit être signalé symétriquement : le périmètre d'usurpation d'identité accordé à la chaîne d'intégration croît avec chaque application accueillie. Il reste borné et explicite, mais c'est une propriété à surveiller.

5.10 Conduite du projet

5.10.1 Déroulement et tâches quotidiennes

J'ai conduit seul l'ensemble des étapes du projet : audit du dépôt existant, rédaction des exigences, conception de l'architecture, écriture des modules d'infrastructure, construction des deux chaînes de livraison, traduction des règles de détection, mise en place de la couche d'enrichissement et de l'interface de supervision, puis exploitation quotidienne du socle en recette. Cette exploitation a produit les quatre incidents rapportés ci-dessous : je les ai diagnostiqués, corrigés et documentés au moment où ils sont survenus. Le rythme précis des échanges d'encadrement n'est pas retracé dans les pièces techniques consultées ; il relève du suivi de stage. Le code d'infrastructure, les règles de détection et les deux logiciels applicatifs ont été écrits par moi ; un assistant de programmation a servi à produire des squelettes répétitifs, des tests et des relectures, jamais à décider d'une option d'architecture ou de sécurité. Aucune production assistée n'a été retenue sans exécution : elle est passée par les portes de la chaîne d'intégration puis par une vérification en conditions réelles, dont les traces sont celles rapportées dans ce chapitre et au chapitre 6.

5.10.2 Difficultés rencontrées

Chacun des quatre incidents ci-dessous a produit une correction et une leçon transférable.

Indisponibilité liée au démarrage à froid. Le service d'encodage, réduit à zéro instance hors traitement, doit démarrer et charger le modèle lorsqu'une requête arrive après une période d'inactivité. Les mesures rapportées début août ont établi une durée moyenne d'environ vingt-sept secondes, avec un pic à quatre-vingt-quatorze secondes (graphique 2 du chapitre 6). Elles sont d'un tout autre ordre de grandeur que l'estimation initiale, qui n'a pas été corrigée discrètement mais conservée avec la mesure qui la contredit. Le budget de la sonde de disponibilité a été porté au-dessus du pic observé. Maintenir une instance active en permanence aurait supprimé le problème, pour un coût jugé disproportionné au regard d'un traitement par lots à intervalle fixe : cet arbitrage est assumé.

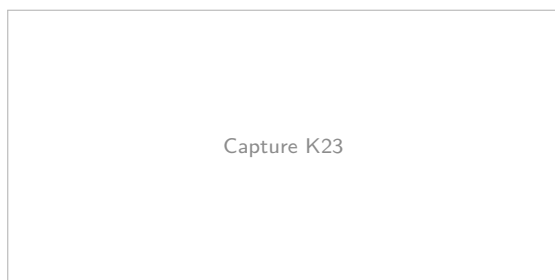
Blocage collectif par la limitation de débit. Le mécanisme initial, un seuil unique par adresse IP, bloquait des utilisateurs légitimes : le tableau de bord et l'API partagent une adresse

de sortie commune, si bien que l'activité normale de quelques analystes suffisait à franchir le seuil. La correction a introduit une limitation à deux niveaux : seuil strict sur les chemins d'authentification avec bannissement temporaire, seuil global élevé contre la saturation. La leçon dépasse ce cas : un contrôle supposant qu'une adresse IP correspond à un utilisateur produit des blocages collectifs dès qu'une agrégation existe.

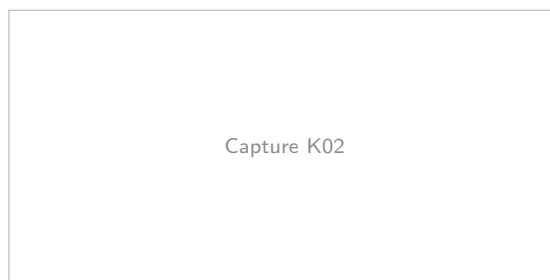
État divergent après une application partiellement échouée. Le 08/08/2026, une modification d'infrastructure a été planifiée puis appliquée sur l'environnement de recette. Une contrainte du fournisseur, non évaluée à la planification, a refusé une partie des changements. L'application s'est terminée en échec partiel, une partie des ressources modifiée et l'autre non. L'état local a néanmoins enregistré une configuration jamais appliquée, si bien que la planification suivante ne signalait plus aucune différence alors que l'infrastructure réelle en présentait une. L'écart a été détecté par comparaison explicite entre l'état enregistré et les valeurs lues chez le fournisseur, puis corrigé par resynchronisation de l'état sur la réalité observée avant toute nouvelle planification. Le constat à retenir est factuel : un échec partiel peut laisser l'état local différent de l'état réel, et la planification suivante hérite de cette erreur.

Porte SAST en faux vert. L'action Semgrep utilisée par la chaîne échouait en interne sur une incompatibilité de sévérité, tandis que l'étape apparaissait verte. Elle n'avait donc évalué aucune règle malgré la porte annoncée. Le 19/08/2026, l'action a été remplacée par un appel direct au CLI avec propagation du code de sortie. Le premier run réel, exécution numéro 32264602112 de la chaîne d'intégration, a analysé 438 fichiers avec 612 règles, produit 74 constats et terminé avec le code 1. La CI rouge prouve ici le rétablissement du contrôle ; elle ne prouve pas la remédiation des 74 constats, dont le triage reste nécessaire.

La figure 16 rapproche les deux états de la chaîne.



(a) Exécution du 16/08/2026, toutes les tâches en succès



(b) Exécution du 19/08/2026 : 612 règles sur 438 fichiers, 74 constats, code de sortie 1

FIG. 16. Chaîne d'intégration avant et après correction de la porte d'analyse statique, environnement de recette

5.10.3 Changements apportés aux objectifs initiaux

Aucun changement de mission n'est documenté dans les sources disponibles, ni donc revendiqué ici. Les deux changements de périmètre significatifs — abandon du quatrième projet cloud d'amorçage (section 5.1.1) et fédération d'identité simplifiée (section 5.3.2) — sont d'ordre technique et documentés au moment de leur décision.

5.10.4 Planning de travail

La période de stage confirmée par l’auteur s’étend du 3 mars au 7 septembre 2026, et la figure 17 la couvre intégralement. Faute de journal quotidien avant le 29 juillet, ses barres n’affichent pas une fausse précision au jour près. Les losanges M1 à M7 renvoient en revanche à des jalons datés par une trace technique.

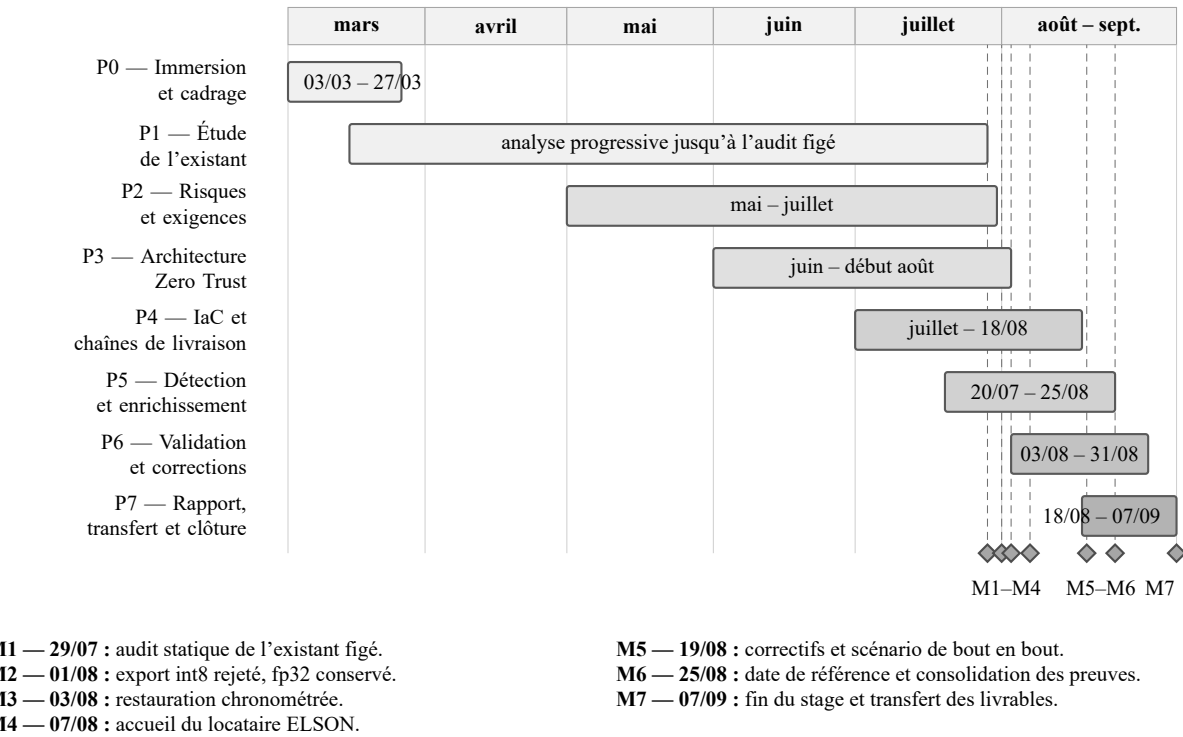


FIG. 17. Planning consolidé du stage, du 03/03/2026 au 07/09/2026. Les barres sont une reconstruction macroscopique ; les losanges signalent les jalons exactement datés.

Conclusion du chapitre

L’infrastructure est décrite en code, en modules qui reproduisent le modèle en couches du chapitre 4. Trois politiques d’organisation prévues s’étant révélées inapplicables, les contrôles correspondants reposent sur les modules, l’analyse automatisée et la revue. Les deux chaînes de livraison définissent des portes bloquantes dont les cas de refus restent à rejouer, et la chaîne de détection s’appuie sur un entrepôt généraliste et des règles traduites manuellement. Trois limites sont assumées : le test dynamique des sorties réseau n’a pas été exécuté, le cache d’encodage est instrumenté mais inexploité, et **l’enrichissement sémantique n’alimente pas le score d’incident**. Le chapitre suivant confronte l’ensemble à la mesure.

Chapitre 6 Validation, résultats et démonstration

Campagne de tests adverses, évaluation de la détection et mesures

Les chapitres précédents ont analysé, conçu et construit. Celui-ci mesure : une architecture Zero Trust ne se déclare pas, elle se démontre [28]. Contrainte posée au chapitre 3 et tenue ici : les vingt tests de la section 6.2 sont exactement ceux dérivés de l'analyse de risque, choisis *avant* la conception de l'architecture. Il devient donc impossible de sélectionner *a posteriori* les tests qui réussissent. Le chapitre suit quatre axes : sécurité, détection, performance et résilience.

Principe directeur du chapitre

Chaque mesure est soit une valeur réellement relevée et datée, soit une case explicitement ouverte, jamais une estimation présentée comme mesurée.

6.1 Stratégie de validation

Chaque test produit l'un de quatre résultats, appliqués sans exception, y compris défavorables : **Conforme**, **Partiellement conforme** (réserve documentée), **Non conforme** (l'exigence redevient ouverte) ou **Non exécuté** (raison indiquée). Un résultat non conforme n'est jamais caché : la matrice de traçabilité du chapitre 3 identifie aussitôt l'exigence non satisfaite et le scénario de menace rouvert.

Les mesures sont réalisées sur l'environnement de recette, représentatif de la cible décrite mais sans trafic d'utilisateurs réels, conséquences traitées en section 6.8. Les preuves exploitées sont datées jusqu'au 23/08/2026 ; les sources ne définissent pas une fenêtre d'observation unique et continue. Les protocoles et réserves sont consignés en annexe E.

6.2 Résultats de la campagne de tests

6.2.1 Synthèse des vingt tests

Les vingt tests dérivés du chapitre 3 (exigences EX1 à EX20) couvrent ces quatre axes ; seule leur synthèse figure ici (tableau 17).

Campagne partiellement exécutée

Une observation opérationnelle ne remplace un protocole que si elle couvre son critère d'acceptation ; sinon, elle est citée comme simple corroboration.

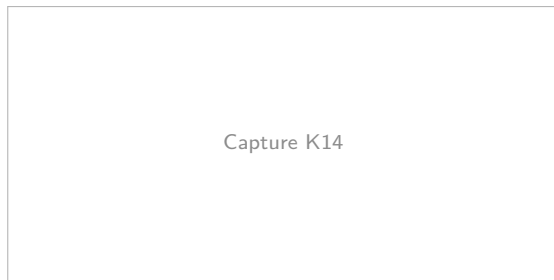
TAB. 17. Synthèse de la campagne de vingt tests

Test	Exig.	Résultat	Commentaire
T1	EX1	Partiellement conforme	SQLi/XSS/LFI bloqués le 23/08 (relevé de validation en direct); un motif brut a reçu 302
T2	EX2	Conforme	11 POST : 10 réponses 422 puis 429, le 19/08
T3	EX3	Partiellement conforme	Balayage contrôlé observé; essai de charge complet absent
T4	EX4	Non exécuté	Inaccessibilité directe des données non rejouée
T5	EX5	Conforme	Deux rôles exacts et usurpation refusée le 23/08 (relevé de validation en direct); ML sans rôle BigQuery le 19/08
T6	EX6	Non exécuté	Auth. inter-services
T7	EX7	Partiellement conforme	Fédération sans clé utilisée; interdiction organisationnelle inapplicable
T8	EX8	Non exécuté	Artefact vulnérable bloqué
T9	EX9	Non exécuté	Critère révisé : étiquette SHA distincte d'un digest immuable
T10	EX10	Non exécuté	Secret versionné bloqué
T11	EX11	Conforme	Identité d'enrichissement séparée, écriture limitée à sa table de résultat
T12	EX12	Non exécuté	Interruption de collecte
T13	EX13	Non exécuté	Attribution des actions
T14	EX14	Non exécuté	Sortie du composant d'inférence ni restreinte ni testée; l'entrée interne seule est en place
T15	EX15	Non exécuté	Charge sur l'enrichissement
T16	EX16	Partiellement conforme	Incident CMEK du 08/08 et plan vide du 19/08; protocole corrigé non rejoué
T17	EX17	Non exécuté	État de l'infrastructure protégé
T18	EX18	Partiellement conforme	Revue de PR et application manuelle; approbation non outillée
T19	EX19	Non exécuté	Consommation anormale
T20	EX20	Non exécuté	Journalisation É1 corrigée; scénario de sortie bloquée non rejoué

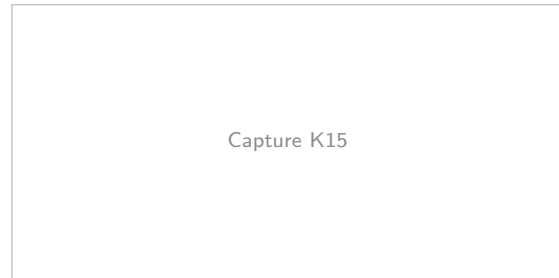
Bilan : 3 conformes, 5 partiellement conformes, 0 non conforme et 12 non exécutés. Les résultats partiels ne valent pas conformité complète; les douze exigences associées à un test non exécuté restent ouvertes jusqu'au rejeu de leur protocole. Parmi les résultats partiels, les exigences EX5, EX6 et EX14 disposent d'une validation infrastructure (droits IAM vérifiés et configuration de sortie confirmée), mais leur validation dynamique complète reste à produire.

Ces douze tests n'ont pas été exécutés faute de temps de campagne en fin de projet, non faute de dispositif : leur protocole est écrit et publié en annexe, et chacun se ramène à une commande ou à un commit. La priorité a été donnée aux corrections d'infrastructure du 19/08/2026, qui conditionnaient la validité des tests eux-mêmes.

Deux des trois tests conformes disposent d'une trace exploitable, ainsi que le résultat partiel de T1 (figure 18 et figure 19). Le test T11, troisième conforme, a été vérifié dans l'état des droits sans capture archivée.



(a) T1, le 23/08/2026 : trois charges d'attaque refusées en 403 et requête de contrôle légitime en 200



(b) T2, le 19/08/2026 : dix réponses 422 puis une réponse 429 à la onzième tentative

FIG. 18. Refus obtenus au périmètre de l'environnement de recette, tests T1 et T2

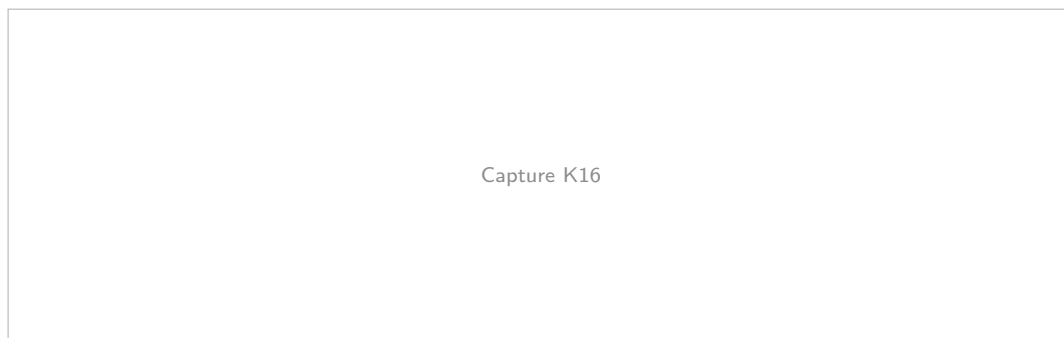


FIG. 19. Cloisonnement de l'identité du second locataire, vérifié en direct le 23/08/2026 : deux rôles exactement attribués, et refus de l'usurpation d'identité depuis un compte d'administration.

Quatre tests, jugés les plus démonstratifs, appellent une capture dédiée une fois exécutés ; leurs emplacements seront posés au rejeu des protocoles.

6.2.2 Analyse des non-conformités

Deux réserves étaient connues à la conception de la campagne (chapitre 4) : les corrections d'infrastructure sont appliquées, les tests dynamiques correspondants restent à rejouer.

Réserve sur T5/T11/T14, corrigée côté infrastructure. La tâche d'enrichissement partageait son identité de service avec les requêtes planifiées de détection, d'où un droit d'écriture non prévu sur les tables de preuves. Elle dispose désormais d'une identité dédiée, limitée en lecture au jeu de données de supervision et en écriture à sa seule table de résultat, vérifiée après application et datée. Les contrôles d'IAM étayent T5 et T11 ; T14 reste non exécuté, faute de test dynamique de l'absence de sortie.

Réserve sur T20, instrumentation corrigée et test ouvert. La journalisation des refus du pare-feu a été activée et vérifiée le 19/08/2026. Cette activation clôt É1 sans démontrer le scénario T20 : il faut encore provoquer une sortie interdite, rapprocher le refus du journal attendu et archiver l'horodatage.

6.3 Évaluation de la détection

6.3.1 Couverture obtenue

La mesure de couverture prête aux erreurs d'interprétation [21], d'où deux précautions. Le **dénominateur** d'abord : la matrice couvre des systèmes d'exploitation, des environnements industriels et des terminaux mobiles absents d'ici. Il est donc restreint aux techniques dont les plateformes déclarées incluent les conteneurs managés, l'infrastructure en tant que service et les identités cloud [33]. La **version** ensuite : une évolution majeure survenue pendant le projet a redistribué une tactique entière, rendant un taux non daté incomparable.

Sept règles de détection sont actives (R1 à R7, chacune adossée à une requête planifiée), plus cinq requêtes de normalisation. Faute d'inventaire versionné des techniques applicables, ni taux ni graphique de couverture ne sont publiés : le nombre de règles actives n'est pas assimilé à un taux de couverture ATT&CK.

6.3.2 Ce que le système ne détecte pas

TAB. 18. Causes connues de non-couverture

Cause	Origine	Conséquence
Scénarios réseau non rejoués	Journalisation des refus activée, mais T20 non exécuté	Couverture des mouvements latéraux et sorties bloquées non établie
Plafond de traduction manuelle	Une seule personne traduit les règles publiques	Couverture bornée par le volume maintenable ; exhaustivité non revendiquée
Absence de trafic réel	Environnement de recette sans usage réel	Seuils comportementaux non calibrables
Exfiltration	Aucune règle dédiée au canal sortant	Transferts sortants non qualifiés comme incidents
Abus IAM / plan de contrôle	Règles concentrées sur les événements HTTP/WAF	Élévations et usages anormaux de rôles peu couverts
Seuils codés en dur	Paramètres intégrés aux requêtes	Adaptation au volume réel lente et peu traçable
Absence de test unitaire par règle	Validation surtout par scénarios de bout en bout	Régression d'une règle difficile à isoler

6.3.3 Qualité et délai de détection

Le volume d'alertes, le taux de faux positifs et les délais médian et maximal ne sont pas établis par une campagne suffisamment large ; le scénario du 19/08 fournit une observation ponctuelle. La règle R2, exécutée toutes les cinq minutes sur une fenêtre de quinze minutes, a produit une alerte environ quinze minutes après les requêtes, et la tâche d'enrichissement s'exécute toutes les quinze minutes. Ces cadences sont des paramètres de planification, pas des bornes garanties du délai de bout en bout, que la charge, la file d'attente et le démarrage à froid peuvent allonger. Le délai observé tient surtout à la nature de la règle : R2 agrège avant de décider, exigeant plus de dix blocages comptés sur sa fenêtre glissante, et ne se déclenche donc jamais à la première requête. Cette fenêtre absorbe en outre la latence d'ingestion des journaux, si bien que le délai attendu est voisin de la fenêtre et non de la cadence de réévaluation.

Note sur l'enrichissement et le score. La chaîne d'enrichissement (F5) produit ses résultats, mais ceux-ci n'alimentent pas encore le score d'incident présenté à l'analyste : écart architectural documenté en section 6.4 et en annexe F.

6.4 Évaluation de l'enrichissement sémantique

6.4.1 Comparaison aux méthodes de référence

Cette évaluation répond au verrou V3 du chapitre 2 : les modèles de rapprochement sémantique sont habituellement évalués sur des textes bien formés, non sur des alertes courtes et bruitées. Une limite doit être rappelée avant toute mesure. L'enrichissement n'alimente aujourd'hui pas le score d'incident, calculé entièrement à partir des règles de détection. Son effet sur la priorisation n'est donc pas évaluable. Ce qui est mesurable, rigoureusement, est la qualité du rattachement d'une alerte à une technique. Elle se compare à deux méthodes de référence plus simples, la correspondance par mots-clés (M0) et la similarité par pondération de termes sans apprentissage de domaine (M1), face à la méthode retenue (M2). Le protocole complet et le constat de non-mesure figurent en annexe F ; le graphique comparatif reste sans objet tant que les valeurs manquent.

L'enrichissement reste utile même sans jointure au score : il fournit à l'analyste, depuis chaque alerte, une technique candidate et la procédure d'incident associée, ce qui raccourcit la qualification manuelle. Faute de mesure, le rapport ne peut affirmer ce rattachement assez précis pour être automatisé dans le calcul de priorité.

Une validation distincte, déjà exécutée, mérite d'être signalée sans s'y substituer. Un export quantifié a été rejeté après un contrôle d'accord de classement : 0 correspondance de premier rang sur 5 requêtes face au modèle de référence. Le format fp32 a donc été conservé en recette. Ce petit échantillon invalide cet export quantifié précis ; il ne démontre ni la qualité générale du modèle fp32 ni sa supériorité sur M0/M1/M2.

6.4.2 Boucle entre livraison et détection

La boucle reliant les vulnérabilités livrées aux techniques observées se mesure par une question unique : l'ordre de priorité qu'elle produit diffère-t-il de l'ordre par gravité théorique seule ? Aucun jeu de résultats ne permet encore de répondre : nombre de vulnérabilités rattachées, changements de rang et amplitude maximale n'ont pas été mesurés. F6 reste donc un prototype architectural non validé comme mécanisme de priorisation.

6.5 Performance, résilience et coût

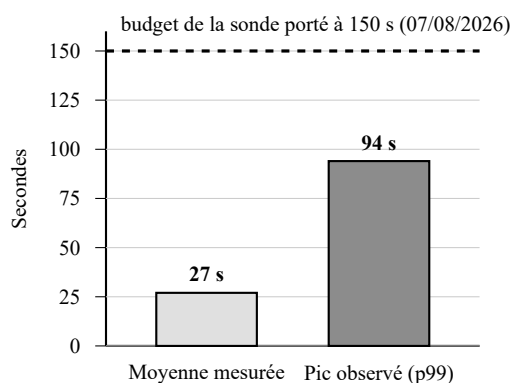
6.5.1 Objectifs de service

Deux objectifs sont configurés sur trente jours glissants : disponibilité API à 99 % (budget d'erreur de 7 h 12 sur 30 jours) et latence au 95^e centile sous 1 s [14]. Cette cible de latence a été relâchée depuis 800 ms, en conséquence directe du choix de réduire à zéro le nombre d'instances actives hors trafic, un arbitrage coût contre latence déclaré comme tel. La valeur

atteinte sur trente jours ne peut pas être rapportée en l'absence de trafic réel (section 6.8) : ce sont des objectifs configurés, non des SLO atteints.

Une observation partielle existe néanmoins. Sur 48 heures d'exploitation, relevées le 07/08/2026, la latence au 95^e centile de l'API est restée comprise entre 9,5 ms et 1004 ms, avec un seul point au-dessus de 800 ms. Cette fenêtre est trop courte, et le trafic trop artificiel, pour valider l'objectif sur trente jours ; elle indique seulement que le service se tient dans l'ordre de grandeur visé en régime de recette.

Une mesure réelle existe pour le démarrage à froid du composant d'encodage sémantique au début d'août 2026 (graphique 2) : moyenne ≈ 27 s, pic ≈ 94 s, très au-dessus de l'estimation retenue en conception, de l'ordre de deux à quatre secondes. L'écart a provoqué des erreurs de service, corrigées dans les jours suivants (§5.10.2). **Règle valable pour tout le chapitre : la mesure fait foi**, y compris quand elle contredit l'estimation initiale, conservée dans la documentation plutôt que corrigée en silence. Le tableau de bord présente un profil plus favorable, avec environ 10,5 s de démarrage à froid mesurés le 07/08/2026, dominés par l'initialisation de la plateforme d'exécution et non par le code.



Graph. 2. Démarrage à froid du service d'encodage : moyenne et pic mesurés début août 2026, comparés au budget de la sonde de disponibilité.

6.5.2 Reproductibilité et résilience

La reconstruction complète d'un environnement depuis le seul dépôt répond au constat de départ d'infrastructure non reproductible (chapitre 1). Elle n'a pas été chronométrée dans son ensemble et n'est donc pas comptabilisée comme résultat de la campagne : elle constitue la démonstration recommandée pour la soutenance, filmée ou exécutée en direct.

La restauration de la base de données, elle, a été exécutée et chronométrée (tableau 19).

Le RTO déclaré ne couvre que le clonage technique : détection, décision et bascule applicative, non chronométrées séparément, portent l'estimation de bout en bout entre 45 minutes et 1 heure. Le retour arrière applicatif par révision, à l'inverse, est mesuré : la bascule du trafic vers la révision précédente a pris 11,6 s, et le retour vers la dernière révision 16,5 s. L'écart s'explique par un démarrage à froid observé au retour, cohérent avec une configuration sans instance active permanente. Cette mesure du 07/08/2026, sur le service d'API en recette, n'a pas été répétée : le protocole complet, le nombre de séries et le délai de validation humaine ne sont pas documentés. La capture est reportée en annexe H (figure 23).

TAB. 19. Restauration de la base de données — test réel exécuté le 3 août 2026

Grandeur	Valeur mesurée
RTO (durée de l'opération de restauration)	32 min 45 s (opération de clonage, de 11:16:40 à 11:49:26 UTC, instance d'entrée de gamme, 10 Go)
RPO (perte de données au point demandé)	0
Résultat au point demandé	314 lignes attendues, 314 restaurées, aucune manquante, aucune en trop ; les trois écritures postérieures au point de restauration correctement absentes
Fenêtre de restauration disponible	7 jours de journaux de transactions conservés en continu
Sauvegardes complètes conservées	7, quotidiennes à 02:00 UTC
Portée de la mesure	Configuration zonale, antérieure au passage en haute disponibilité régionale du 08/08/2026 ; mesure à revalider sur la configuration actuelle

Le mécanisme de détection de dérive [17] a été sollicité en conditions réelles début août 2026, lors de l'incident de chiffrement géré par le client rapporté en §5.10.2. L'écart entre l'état local et la plateforme a été détecté par comparaison explicite, puis corrigé par resynchronisation. Cet épisode ne constitue pas le protocole T16 corrigé : une ressource créée hors état échapperait à la seule planification.

6.5.3 Coût réel

Aucune ventilation mensuelle vérifiable par poste (ingestion, base de données, exécution, connecteur, périmètre, requêtes) n'existe dans les sources : aucun relevé de facturation ventilé n'est donc publié, et il reste à produire. Un fait reste toutefois sourcé. Le document d'architecture du projet, dans son tableau des chiffres mesurés (§5.8, ligne « Coût financier »), situe le coût au niveau des paliers gratuits, avec quelques dizaines d'euros par mois, et désigne l'ingestion de journaux comme poste dominant. Sa colonne de mesure réelle confirme l'absence de processeur graphique et de base vectorielle facturée séparément. C'est un constat interne daté, non un relevé de facturation. Trois constats datés le complètent (tableau 20).

TAB. 20. Constats de coût datés, statut à la date de la dernière mesure

Poste	Constat	Statut
Services d'exécution (facturation à l'instance)	Instance maintenue active en permanence, donc coût continu sans contrepartie en recette ; réglage hérité jamais déclaré	Corrigé
Requêtes planifiées de l'entrepôt	≈ 78 Go/j facturés pour 24 Mo de données : minimum forfaitaire × exécutions quotidiennes	Ouvert
Haute disponibilité base de données	Bascule régionale appliquée et confirmée en direct le 08/08/2026 ; basculement de zone jamais provoqué	Appliqué

L'application de la haute disponibilité régionale a réussi en 11 min 2 s et fermé le point de défaillance zonal ; la preuve dynamique manque, le basculement n'ayant été ni provoqué ni

chronométré. Faute de volume représentatif et de grille tarifaire datée, le rapport ne chiffre pas non plus l’alternative commerciale étudiée au chapitre 2.

6.5.4 Ordre de grandeur des postes de coût

Le tableau 21 est une reconstitution, non un relevé de facturation, établie à partir du dimensionnement déclaré dans le code d’infrastructure et des paliers publics du fournisseur, à la date de 25/08/2026.

TAB. 21. Postes de coût et dimensionnement déclaré (reconstitution, non facturation)

Poste	Dimensionnement déclaré	Commentaire
Base de données	Instance d’entrée de gamme, haute disponibilité régionale depuis le 08/08/2026	Le mode régional double le coût de calcul de l’instance ; décision assumée et datée
Connecteur réseau sans serveur	Deux instances minimales en permanence, dix au maximum	Coût plancher permanent, indépendant du trafic
Services d’exécution	Tableau de bord et services du locataire à une instance active ; service d’encodage et API à zéro instance au repos	Explique les démarrages à froid mesurés
Entrepôt de supervision	≈ 78 Go facturés par jour pour un jeu de données réel de 24 Mo	Écart dû au minimum forfaitaire par table multiplié par les exécutions quotidiennes ; la fusion des sept règles ramènerait ce poste sous le palier gratuit
Répartiteur de charge et filtrage applicatif	Répartiteur global permanent	Coût fixe mensuel, indépendant du trafic

6.6 Conformité aux référentiels

Le chapitre 4 positionne la conception par rapport aux principes Zero Trust [10] et à un référentiel de configuration. Il ne s’agit ni d’une certification ni d’un audit exhaustif : aucun taux de conformité n’est calculé sans grille contrôle par contrôle et preuves associées. Trois des onze écarts recensés au chapitre 4 touchent cette campagne (tableau 13, dates et statuts complets). Il s’agit de la journalisation des refus réseau (É1) et de l’identité partagée du composant d’encodage (É3), toutes deux traitées en section 6.2.2. Le troisième est le sous-réseau public inutilisé, dont le retrait est décidé mais non appliqué.

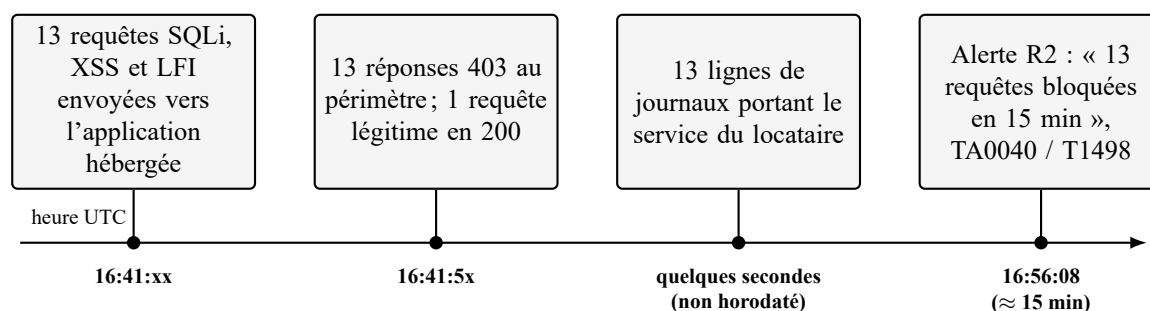
6.7 Démonstration du fonctionnement global

Le 19/08/2026, un scénario d’attaque complet a été exécuté en recette : il combine les preuves de cinq domaines distincts (identité, périmètre, cloisonnement des données, SOC et CI/CD) en une démonstration continue et filée.

6.7.1 Scénario exécuté

La figure 20 déroule la chaîne complète, de l’attaque à l’alerte qualifiée ; les treize requêtes mêlaient injections SQL, cross-site scripting, inclusion de fichier local et accès à des fichiers

sensibles. Cette observation ponctuelle ne mesure pas le taux de faux positifs, qui n'a pas été établi.



Échelle non linéaire. L'étiquetage TA0040 / T1498 est celui produit par la règle; une qualification par T1190 serait plus plausible pour ces charges et doit être revue par l'analyste. L'enrichissement disponible datait de 12:16:15 : il n'enrichit pas cette alerte.

FIG. 20. Scénario de bout en bout du 19/08/2026 : de l'attaque à l'alerte qualifiée

La figure 21 reproduit l'alerte R2 elle-même, dernier maillon de cette chaîne.

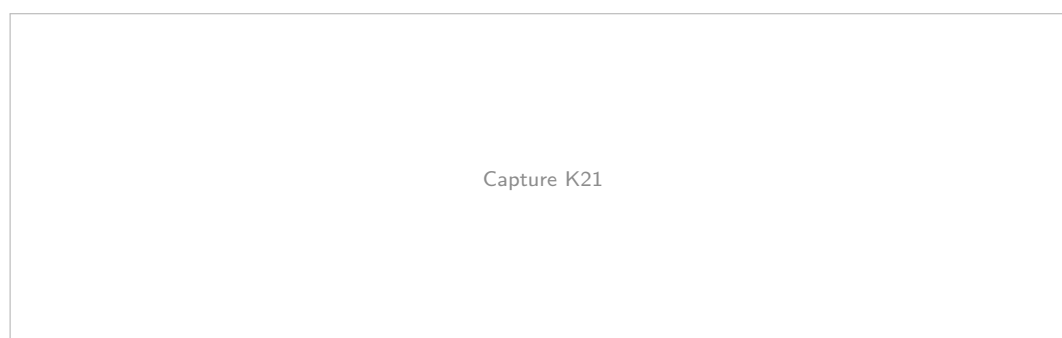


FIG. 21. Alerte de la règle R2 produite le 19/08/2026 à 16:56:08 UTC : treize requêtes bloquées comptées sur la fenêtre de quinze minutes et attribuées au locataire.

6.7.2 Contrôles complémentaires exécutés en direct

Le contrôle d'isolation SQL a été relancé : ses six vérifications ont toutes échoué comme attendu, et le compte de service du second locataire dispose exactement de deux rôles (client base de données, écriture de journaux), sans privilège supplémentaire. Le dernier rattachement sémantique disponible, daté de 12:16:15 UTC, présente une similarité de 0,698 avec T1556.003. Précédant l'attaque de plus de quatre heures, il atteste le fonctionnement antérieur du composant, pas l'enrichissement de l'alerte R2 de 16:56:08.

6.7.3 Correspondance avec les preuves de soutenance

Le scénario ne vaut comme démonstration que s'il se rattache aux résultats du rapport. Le tableau 22 relie chacune des cinq preuves attendues en soutenance à ce que le scénario a produit et à la section ou au test qui la documente.

6.7.4 Ce que le scénario ne couvre pas

Trois points restent hors du périmètre de ce scénario. Il ne couvre ni l'isolation réseau (VPC partagé, écart documenté en section 5.9), ni le motif WAF brut (H13, écart documenté en T1).

TAB. 22. Correspondance entre les preuves du scénario et les sections du rapport

Domaine	Preuve	Section ou test associé
Périmètre	13 requêtes bloquées (403)	§4.4 ; test T1
Identité	2 rôles exacts, usurpation refusée	§4.6 ; test T5
Cloisonnement des données	Isolation SQL 6/6	§5.9 ; test —
SOC	Alerte R2 à 16:56:08 UTC ; qualification à revoir	§5.5, scénario global ; test —
CI/CD	Exécution SAST réelle en échec sur 74 constats	§5.3, incident SAST ; test —

Il ne couvre pas davantage les constats SAST : 74 constats et tâche CI en échec le 19/08, sans remédiation complète démontrée. Tous trois font l’objet de tests spécifiques dans la campagne de la section 6.2.

Le motif de traversée de chemin resté en 302 correspond à une requête que le filtrage applicatif traite par redirection plutôt que par refus, faute de règle de blocage couvrant cette forme brute. Le contrôle attendu par EX1 n’est donc pas complet, et T1 reste partiellement conforme jusqu’à l’ajout de la règle manquante et son rejeu.

6.8 Limites et menaces à la validité

Toute mesure porte les limites de son dispositif. Le tableau 23 recense celles qui affectent l’interprétation des résultats de ce chapitre. La plus lourde de conséquences est l’auto-évaluation, non levable dans le cadre d’un projet mono-porteur. Vient ensuite l’absence de trafic d’utilisateurs réels, qui interdit d’établir un taux de faux positifs et de valider un objectif de disponibilité sur une période représentative.

TAB. 23. Limites du dispositif de mesure et de l’évaluation sémantique

Limite	Conséquence sur l’interprétation
Absence de trafic réel	Faux positifs et seuils comportementaux non représentatifs d’une exploitation réelle
Attaques simulées, non adverses	Les tests valident les scénarios prévus, pas l’espace des scénarios non prévus
Période d’observation courte	Phénomènes lents (dérive, saturation, coût) non observables
Auto-évaluation	Auteur du système et des tests confondus, aucun regard extérieur — limite la plus structurelle, non levable ; atténuée par la publication des protocoles (annexe E) pour reproduction contradictoire
Annotation sémantique par une seule personne, auteur du système	Biais d’annotation ; atténuation et accord inter-annotateurs en annexe F

6.9 Réponse aux objectifs du projet

Les six objectifs mesurables du chapitre 1 sont confrontés aux résultats obtenus (tableau 24), y compris quand la réponse reste partielle.

Tab. 24. Réponse aux six objectifs mesurables du projet

#	Objectif	Résultat à ce stade	Atteint ?
O1	Supprimer la confiance implicite du réseau	Contrôles d'identité et de périmètre observés; isolation réseau multi-locataire incomplète	Partiel
O2	Rendre l'infrastructure reproductible	Socle intégralement en code (ch. 4–5); durée de reconstruction non chronométrée	Partiel
O3	Contrôler la chaîne de livraison	Aucune clé de compte de service exportée par conception; vérification empirique (T7–T10) non exécutée	Partiel
O4	Détecter les événements de sécurité	7 règles actives; couverture, faux positifs et délai non mesurés	Partiel
O5	Enrichir les alertes de façon déterministe	Candidats sémantiques produits; comparaison M0/M1/M2 et effet sur le score non mesurés	Partiel
O6	Rester exploitable et soutenable	Restauration DB exécutée (32 min 45 s, RPO 0, 314/314 lignes au point demandé); haute disponibilité régionale appliquée le 08/08/2026 mais bascule non provoquée; reconstruction complète non exécutée	Partiel

Deux engagements du chapitre 1 restent à tenir : O4 exige de publier ce que le système **ne** détecte pas (tableau 18), et O5 admettait par avance un résultat négatif, à rapporter tel quel s'il se confirme.

Conclusion du chapitre

La campagne établit 3 résultats conformes, 5 partiels et laisse 12 protocoles non exécutés. Le résultat le plus solide est une restauration de base de données mesurée en 32 min 45 s, avec 314 lignes sur 314 au point demandé. S'y ajoutent l'observation d'une divergence entre état et réalité et la correction de l'écart d'identité le plus sensible. Les plus fragiles restent la couverture de détection non calculée, les tests réseau non rejoués et l'absence de validation comparative de l'enrichissement. La question ouverte au chapitre 2 le reste ici : le gain de l'enrichissement sémantique justifiera-t-il son coût ?

Conclusion générale

Récapitulation. Ce mémoire a présenté la conception, la réalisation et la validation d'un socle d'hébergement cloud Zero Trust pour une entreprise émergente. Le point de départ était une application fonctionnelle, mais hébergée sur un serveur unique, avec confiance implicite entre tous ses composants, sans reproductibilité et sans détection de sécurité. Le point d'arrivée est un socle entièrement décrit en code, organisé en sept niveaux L1–L7, soit cinq couches et deux plans transversaux. Il comporte deux chaînes de livraison à portes bloquantes, une chaîne de détection enrichie par un modèle de représentation sémantique, et une interface de supervision destinée à l'analyste.

Résultats chiffrés. Le socle fonctionne avec deux environnements réels, développement et recette ; la production reste une cible non provisionnée. L'infrastructure durable du périmètre est décrite en code, avec ses décisions et ses écarts datés. La restauration de la base de données a été mesurée le 03/08/2026 : 32 min 45 s, avec 314 lignes restaurées sur 314 au point demandé et aucune perte de données. Cette mesure porte sur la configuration zonale, antérieure au passage en haute disponibilité régionale du 08/08/2026. Deux opérations de retour arrière applicatif ont pris 11,6 s et 16,5 s le 07/08/2026, sans répétition du protocole. Le démarrage à froid du service d'encodage est de 27 s en moyenne et de 94 s au pic. Le 19/08/2026, un scénario de bout en bout a produit treize requêtes malveillantes, toutes bloquées, agrégées en une alerte environ quinze minutes plus tard. La campagne compte trois tests conformes, cinq partiellement conformes et douze non exécutés. La chaîne sémantique produit des candidats de rattachement, mais l'évaluation comparative des méthodes et l'effet de la boucle F6 sur l'ordre de priorité ne sont pas mesurés : F6 demeure un prototype. La seconde moitié de la problématique posée en introduction reste donc sans réponse mesurée : le prix payé pour ce résultat, en faux positifs et en latence de détection, n'a pas été établi. Il demande une période d'observation sous trafic réel et constitue la première des perspectives.

Problèmes rencontrés. Quatre incidents d'ingénierie ont été documentés au chapitre 5. Le premier est une indisponibilité liée au démarrage à froid. Le deuxième est un blocage collectif d'utilisateurs légitimes par la limitation de débit. Le troisième est un état local divergent après une application partiellement échouée. Le quatrième est une porte d'analyse statique restée verte sans évaluer aucune règle. Chacun a produit une correction et une leçon transférable. Trois limites subsistent. Le test dynamique des sorties réseau n'a pas été exécuté. Le cache d'encodage est instrumenté et inexploité. Surtout, l'enrichissement sémantique n'alimente pas le score d'incident présenté à l'analyste, et sa précision comparative n'est pas établie.

Apports. Pour l'entreprise, le socle fournit une base interne réutilisable, éprouvée partiellement par l'accueil d'un second locataire le 07/08/2026. L'identité, les secrets et les données sont séparés par locataire ; le réseau privé, le connecteur et l'instance de base de données restent partagés. Pour ma part, ce projet a mobilisé l'ensemble des compétences d'un ingénieur en cybersécurité cloud, sans répartition d'équipe. J'ai réalisé l'audit, dérivé les exigences et conçu l'architecture. J'ai écrit l'infrastructure en code, construit les deux chaînes de livraison et

la chaîne de détection, puis exécuté la campagne de validation. J'ai appris à documenter un écart au moment où il apparaît, plutôt qu'à le refermer discrètement. J'ai appris aussi à préférer une mesure défavorable à une estimation flatteuse. Le démarrage à froid mesuré à 27 s contre une estimation initiale de quelques secondes, et la porte d'analyse statique découverte en faux vert, en sont les deux exemples les plus formateurs. J'ai aussi appris qu'un contrôle correctement conçu peut produire un effet non prévu en exploitation, comme cette limitation de débit qui bloquait des utilisateurs légitimes partageant une même adresse.

Perspectives. Quatre axes d'amélioration sont identifiés. Le premier est la segmentation réseau par locataire, par réseau privé distinct ou par règles de pare-feu internes dédiées. Le deuxième est l'intégration contrôlée de l'enrichissement au score d'incident, avec clé d'entité, règle de décision et mesure comparative. Le troisième est la signature des images par chaîne de provenance. Le quatrième est l'écriture de tests unitaires par règle de détection, vérifiant que chaque règle produit l'alerte attendue sur des données de test. Le gain de l'enrichissement sémantique, une fois mesuré, justifiera-t-il son coût ? C'est la question ouverte du chapitre 2, et elle reste ouverte.

Bibliographie/Netographie

- [1] Basel ABDEEN, Ehab AL-SHAER, Anoop SINGHAL, Latifur KHAN et Kevin W. HAMLEN. *ATT&CK-BERT : modèle de représentation de phrases spécialisé pour la cybersécurité (carte de modèle)*. Hugging Face, dépôt `basel/ATTACK-BERT`. Modèle publié par les auteurs de SMET. 2023. URL : <https://huggingface.co/basel/ATTACK-BERT> (visité le 26 août 2026).
- [2] Basel ABDEEN, Ehab AL-SHAER, Anoop SINGHAL, Latifur KHAN et Kevin W. HAMLEN. « SMET : Semantic Mapping of CVE to ATT&CK and Its Application to Cybersecurity ». In : *Data and Applications Security and Privacy XXXVII*. T. 13942. Lecture Notes in Computer Science. Springer, 2023, p. 243-260. DOI : [10.1007/978-3-031-37586-6_15](https://doi.org/10.1007/978-3-031-37586-6_15).
- [3] Basel ABDEEN, Ehab AL-SHAER, Anoop SINGHAL, Latifur KHAN et Kevin W. HAMLEN. « SMET : Semantic Mapping of CTI Reports and CVE to ATT&CK for Advanced Threat Intelligence ». In : *Journal of Computer Security* (2024). DOI : [10.3233/JCS-230218](https://doi.org/10.3233/JCS-230218).
- [4] AGENCE NATIONALE DE LA SÉCURITÉ DES SYSTÈMES D'INFORMATION (ANSSI). *La méthode EBIOS Risk Manager — Le Guide*. Rapp. tech. ANSSI-PA-048, version 1.1. ANSSI, déc. 2018. URL : <https://www.ssi.gouv.fr/uploads/2018/10/guide-methode-ebios-risk-manager.pdf> (visité le 26 août 2026).
- [5] Ehsan AGHAEI, Xi NIU, Waseem SHADID et Ehab AL-SHAER. *SecureBERT : A Domain-Specific Language Model for Cybersecurity*. 2022. arXiv : [2204.02685](https://arxiv.org/abs/2204.02685). URL : <https://arxiv.org/abs/2204.02685> (visité le 26 août 2026).
- [6] AMAZON WEB SERVICES. *AWS Global Infrastructure : Regions and Availability Zones*. 2026. URL : https://aws.amazon.com/about-aws/global-infrastructure/regions_az/ (visité le 27 août 2026).
- [7] Oliver BORCHERT, Gema HOWELL, Alper KERMAN, Scott ROSE, Murugiah SOUPPAYA et al. *Implementing a Zero Trust Architecture*. NIST Special Publication 1800-35. National Institute of Standards et Technology (NIST), juin 2025. DOI : [10.6028/NIST.SP.1800-35](https://doi.org/10.6028/NIST.SP.1800-35). URL : <https://csrc.nist.gov/pubs/sp/1800/35/final> (visité le 26 août 2026).
- [8] CENTER FOR INTERNET SECURITY. *CIS Google Cloud Computing Platform Benchmark*. 2026. URL : https://www.cisecurity.org/benchmark/google_cloud_computing_platform (visité le 26 août 2026).

- [9] CYBERSECURITY AND INFRASTRUCTURE SECURITY AGENCY (CISA). *Advanced Persistent Threat Compromise of Government Agencies, Critical Infrastructure, and Private Sector Organizations*. Cybersecurity Advisory AA20-352A. Mis à jour en avril 2021. CISA, déc. 2020. URL : <https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-352a> (visité le 26 août 2026).
- [10] CYBERSECURITY AND INFRASTRUCTURE SECURITY AGENCY (CISA). *Zero Trust Maturity Model*. Version 2.0. 2023. URL : <https://www.cisa.gov/zero-trust-maturity-model> (visité le 26 août 2026).
- [11] JACOB DEVLIN, MING-WEI CHANG, KENTON LEE et KRISTINA TOUTANOVA. « BERT : Pre-training of Deep Bidirectional Transformers for Language Understanding ». In : *Proceedings of the 2019 Conference of the North American Chapter of the Association for Computational Linguistics : Human Language Technologies*. Association for Computational Linguistics, 2019, p. 4171-4186.
- [12] GITGUARDIAN. *State of Secrets Sprawl*. 2025. URL : <https://www.gitguardian.com/state-of-secrets-sprawl-report-2025> (visité le 26 août 2026).
- [13] GOOGLE CLOUD. *Best Practices for Building Containers*. 2026. URL : <https://cloud.google.com/architecture/best-practices-for-building-containers> (visité le 26 août 2026).
- [14] GOOGLE CLOUD. *Google Cloud Architecture Framework*. 2026. URL : <https://cloud.google.com/architecture/framework> (visité le 26 août 2026).
- [15] GOOGLE CLOUD. *Google Cloud Free Program : Free Tier Usage Limits*. 2026. URL : <https://cloud.google.com/free/docs/free-cloud-features> (visité le 27 août 2026).
- [16] GOOGLE CLOUD. *Regions and Zones*. 2026. URL : <https://cloud.google.com/compute/docs/regions-zones> (visité le 27 août 2026).
- [17] HASHICORP. *Automatically Detect Resource Drift and Health*. 2025. URL : <https://developer.hashicorp.com/well-architected-framework/optimize-systems/monitor-system-health/detect-configuration-drift> (visité le 26 août 2026).
- [18] HETZNER ONLINE GMBH. *Hetzner Data Center Locations*. 2026. URL : <https://www.hetzner.com/unternehmen/rechenzentrum/> (visité le 27 août 2026).
- [19] INTERNATIONAL ORGANIZATION FOR STANDARDIZATION. *Information Security, Cybersecurity and Privacy Protection — Guidance on Managing Information Security Risks*. Oct. 2022. URL : <https://www.iso.org/standard/80585.html> (visité le 26 août 2026).

- [20] John KINDERVAG. *No More Chewy Centers : Introducing the Zero Trust Model of Information Security*. Rapp. tech. Forrester Research, 2010.
- [21] MITRE CORPORATION. *MITRE ATT&CK*. Version v19. 2026. URL : <https://attack.mitre.org/> (visité le 26 août 2026).
- [22] Kief MORRIS. *Infrastructure as Code : Dynamic Systems for the Cloud Age*. 2^e éd. O'Reilly Media, 2020. ISBN : 978-1-098-11467-1.
- [23] OPEN SOURCE SECURITY FOUNDATION (OPENSSF). *Supply-chain Levels for Software Artifacts (SLSA)*. Version 1.0. 2023. URL : <https://slsa.dev> (visité le 26 août 2026).
- [24] OWASP FOUNDATION. *OWASP Top Ten Web Application Security Risks*. 2021. URL : <https://owasp.org/www-project-top-ten/> (visité le 26 août 2026).
- [25] OWASP FOUNDATION. *OWASP Top 10 CI/CD Security Risks*. 2022. URL : <https://owasp.org/www-project-top-10-ci-cd-security-risks/> (visité le 26 août 2026).
- [26] OWASP FOUNDATION. *OWASP Top 10 :2025*. 2025. URL : <https://owasp.org/Top10/> (visité le 26 août 2026).
- [27] Nils REIMERS et Iryna GUREVYCH. « Sentence-BERT : Sentence Embeddings using Siamese BERT-Networks ». In : *Proceedings of EMNLP-IJCNLP 2019*. Association for Computational Linguistics, 2019, p. 3982-3992. DOI : [10.18653/v1/D19-1410](https://doi.org/10.18653/v1/D19-1410). URL : <https://aclanthology.org/D19-1410/> (visité le 26 août 2026).
- [28] Scott ROSE, Oliver BORCHERT, Stu MITCHELL et Sean CONNELLY. *Zero Trust Architecture*. NIST Special Publication 800-207. National Institute of Standards et Technology (NIST), août 2020. DOI : [10.6028/NIST.SP.800-207](https://doi.org/10.6028/NIST.SP.800-207).
- [29] SCALEWAY. *Understanding Regions and Availability Zones*. 2026. URL : <https://www.scaleway.com/en/docs/console/my-account/reference-content/products-availability/> (visité le 27 août 2026).
- [30] Adam SHOSTACK. *Threat Modeling : Designing for Security*. Wiley, 2014. ISBN : 978-1-118-80999-0.
- [31] SIGMAHQ. *Sigma Specification : Generic Signature Format for SIEM Systems*. 2026. URL : <https://sigmahq.io/sigma-specification/> (visité le 26 août 2026).
- [32] Larry SMITH. « Shift-Left Testing ». In : *Dr. Dobb's Journal* 26.9 (2001), p. 56-62.
- [33] Blake E. STROM, Andy APPLEBAUM, Doug P. MILLER, Kathryn C. NICKELS, Adam G. PENNINGTON et Cody B. THOMAS. *MITRE ATT&CK : Design and Philosophy*. Rapp. tech. MP180360R1. MITRE Corporation, 2018.
- [34] Rory WARD et Betsy BEYER. « BeyondCorp : A New Approach to Enterprise Security ». In : *login* : 39.6 (2014), p. 6-11.

Annexe A Études comparatives détaillées

A.1 Audit de l'existant et positionnement (issus du chapitre 1)

Cette section reprend, dans son détail complet, le contenu condensé au chapitre 1 : la grille des 41 critères de préparation au déploiement issue de l'audit du 29 juillet 2026 (section 1.2.3), et le tableau de positionnement à quinze critères entre les trois modèles d'architecture comparés (section 1.3.3).

A.1.1 Grille complète des 41 critères d'audit

Le tableau 25 détaille, par catégorie, la répartition des 41 critères de préparation au déploiement entre les trois statuts « Prêt », « Partiel » et « Non prêt ». C'est à partir de ces chiffres qu'est construit le graphique 1 du chapitre 1.

TAB. 25. Grille complète des 41 critères de préparation au déploiement, par catégorie.

Catégorie	Critères	Prêt	Partiel	Non prêt
Fonctionnel	7	6	1	0
Technique	10	0	1	9
Sécurité	17	6	4	7
Conformité	7	0	1	6
Total	41	12	7	22

La lecture de cette grille est sans ambiguïté et constitue le point de départ du projet : le fonctionnel est prêt à 86 %, tandis que le technique (0 % prêt sur 10 critères) et la conformité (0 % prêt sur 7 critères) sont proches de zéro. La sécurité, à mi-chemin, porte à la fois les points forts applicatifs et les six constats bloquants présentés au chapitre 1.

A.1.2 Positionnement complet à quinze critères

Le tableau 26 reprend l'intégralité de la comparaison entre les trois modèles introduite au section 1.3.3 : le modèle A (architecture périmétrique de l'existant), le modèle B (hébergement cloud managé sans démarche de sécurité explicite) et le modèle C (socle Zero Trust visé par le projet). Les sept premiers critères proviennent des principes de l'architecture Zero Trust [28] ; les critères 8 à 11 reprennent les carences C2 à C4 et l'apport original du projet ; les critères 12 à 15 traduisent des contraintes d'ingénierie réelles, sur lesquelles le modèle C ne l'emporte pas systématiquement. Légende : ● couvert par conception, ◐ partiellement couvert ou dépendant de la configuration, ○ non couvert.

TAB. 26. Positionnement complet des trois modèles sur quinze critères.

#	Critère	Origine	A	B	C
1	Vérification explicite de l'identité à chaque requête	NIST SP 800-207	○	◐	●

TAB. 26. Positionnement complet des trois modèles sur quinze critères (suite)

#	Critère	Origine	A	B	C
2	Aucune confiance accordée à la position réseau	NIST SP 800-207	○	●	●
3	Moindre privilège, une identité par charge de travail	NIST SP 800-207	○	●	●
4	Micro-segmentation, limitation des mouvements latéraux	NIST SP 800-207	○	●	●
5	Hypothèse de compromission : tout est journalisé	NIST SP 800-207	○	●	●
6	Collecte, corrélation et conservation des événements	NIST SP 800-207	○	●	●
7	Surveillance continue et amélioration	NIST SP 800-207	○	○	●
8	Infrastructure entièrement décrite en code	Carence C2	○	○	●
9	Contrôles de sécurité bloquants dans la livraison	Carence C3	○	●	●
10	Règles de détection écrites, versionnées et mesurées	Carence C4	○	○	●
11	Priorisation des vulnérabilités par la menace observée	Apport du projet	○	○	●
12	Coût mensuel d'exploitation	Contrainte projet	●	●	●
13	Simplicité initiale, délai de mise en service	Contrainte projet	●	●	○
14	Mise à l'échelle horizontale	Contrainte projet	○	●	●
15	Maturité, support éditeur, compétences disponibles	Contrainte projet	●	●	○

Lecture du tableau. Les onze premières lignes montrent l'apport du modèle retenu et justifient le projet. Les quatre dernières montrent ce qu'il coûte et doivent être lues avec la même attention : le modèle C perd sur la simplicité initiale (ligne 13), sur la mise à l'échelle (ligne 14, explicitement hors objectif du projet) et sur la maturité opérationnelle (ligne 15). Le coût mensuel (ligne 12) mérite une nuance : le modèle A est le moins cher en facturation directe, mais ce coût n'intègre ni la sauvegarde externalisée, ni la détection, ni la reprise après incident, qui en sont absentes ; la comparaison ne porte donc pas sur des périmètres équivalents. Une comparaison dont l'auteur sort vainqueur sur tous les critères n'est pas une comparaison équilibrée : les trois critères perdus ci-dessus sont ce qui rend les onze autres crédibles. Ils sont repris tels quels au chapitre 6, section « limites ».

A.2 État de l'art et choix technologiques (issus du chapitre 2)

A.2.1 Les sept principes du NIST SP 800-207

Le tableau 27 reprend, dans son détail complet, les sept principes directeurs condensés au § 2.1.2 du chapitre 2, avec leur traduction pour le projet.

TAB. 27. Les sept principes du NIST SP 800-207 et leur traduction pour le projet

#	Principe (reformulé)	Traduction pour le projet
P1	Toute ressource de données ou de calcul est une ressource à protéger	Base de données, journaux, images et secrets sont des ressources contrôlées
P2	Toute communication est sécurisée, quelle que soit sa position réseau	Le chiffrement en transit ne dépend pas d'être « à l'intérieur »
P3	L'accès est accordé par session, jamais définitivement	Jetons à durée courte, jamais de clé permanente
P4	L'accès est déterminé par une politique dynamique (identité, contexte)	Une identité par charge de travail, droits au cas par cas
P5	L'organisation mesure et surveille en continu ses ressources	Journalisation centralisée, analyse de posture
P6	Authentification et autorisation appliquées avant chaque accès	Vérification à chaque requête, jamais une seule fois à l'entrée
P7	L'organisation collecte le plus d'informations possible	Détection, mesure et amélioration à partir des observations

TAB. 28. Rôle et limite des référentiels retenus

Référentiel	Usage dans le projet	Limite de l'affirmation
NIST SP 800-207 / SP 1800-35	Principes d'architecture et exemples de mise en œuvre Zero Trust	Guides de référence, pas certification du socle
OWASP Top 10 :2025	Priorisation des risques applicatifs et de configuration	Ne remplace pas un audit applicatif complet
CIS GCP Foundation Benchmark	Grille de configuration de la plateforme	Version appliquée non consignée ; aucun taux de conformité publié
SLSA	Provenance et intégrité attendues pour les artefacts	Signature et provenance complètes non mises en œuvre
MITRE ATT&CK v19	Vocabulaire des techniques, cartographie et cible sémantique	Une étiquette de règle doit rester révisable par l'analyste

A.2.2 Référentiels mobilisés

A.2.3 Familles de contrôles automatisés de sécurité

Le tableau 29 détaille les quatre familles de contrôles nommées au § 2.2.1 : la question posée par chacune et les outils libres couramment employés.

TAB. 29. Familles de contrôles automatisés de sécurité

Famille	Question posée	Exemples d'outils libres
Détection de secrets [12]	Un secret a-t-il été versionné ?	Gitleaks, TruffleHog
Analyse statique (SAST)	Le code contient-il une vulnérabilité connue ?	Semgrep, CodeQL, SonarQube
Composition (SCA) et images	Utilisons-nous un composant vulnérable ?	Trivy, Gype, Dependency-Check
Infrastructure en code	La ressource sera-t-elle créée de façon non sécurisée ?	Checkov, tfsec, Terrascan

A.2.4 Comparaison des solutions de supervision

Légende employée dans ce tableau : ● favorable, ◐ intermédiaire, ○ défavorable.

TAB. 30. Comparaison détaillée des cinq options de supervision

Critère	SIEM comm.	SIEM cloud	Pile libre	Libre intégrée	Entrepôt + code
Coût pour un faible volume	○	○	◐	●	●
Coût d'exploitation courante	●	●	○	◐	◐
Règles fournies au départ	●	●	◐	●	○
Interface d'analyste fournie	●	●	●	●	○
Détection versionnée et testable	◐	◐	◐	◐	●
Rétention longue maîtrisée	○	◐	○	◐	●
Absence de dépendance éditeur	○	○	●	●	●
Analyse sur les données	○	◐	◐	○	●
Maturité et support	●	●	●	◐	○

L'entrepôt avec détection en code est retenu pour son coût initial et l'analyse vectorielle sur place. Il impose en contrepartie de construire les règles, l'interface et les procédures.

A.2.5 Comparaison des modes d'exécution

TAB. 31. Comparaison des trois modes d'exécution étudiés

Légende : ● favorable, ◐ intermédiaire, ○ défavorable.

Critère	Machines virtuelles	Orchestrateur managé	Conteneurs sans serveur
Charge d'administration	○	○	●
Coût à faible trafic	◐	○	●
Système de fichiers persistant	●	●	○
Isolation réseau fine	◐	●	◐
Tâches longues	●	●	◐
Démarrage à froid	●	●	○

L'exécution de conteneurs sans serveur réduit la charge d'administration et le coût à faible trafic. Elle sacrifie l'isolation réseau fine et introduit le démarrage à froid mesuré au chapitre 5.

A.3 Choix de la plateforme et des briques techniques

Cette section détaille la comparaison condensée au § 2.5 du chapitre 2 : les six options d'hébergement évaluées sur dix critères, puis les douze briques techniques retenues à l'intérieur de la plateforme choisie.

A.3.1 Les six options d'hébergement sur dix critères

TAB. 32. Comparaison des six options d'hébergement sur dix critères

Légende : ● favorable, ◐ intermédiaire, ○ défavorable. « Forfait » désigne un serveur loué à prix fixe chez un hébergeur européen, comparable à l'existant ; « Local » un hébergeur mauritanien.

#	Critère	GCP	AWS	Azure	OVH	Forfait	Local
1	Palier gratuit couvrant l'entrepôt de supervision	●	◐	◐	○	○	○
2	Coût direct à périmètre de calcul comparable	○	○	○	◐	●	◐
3	Facturation nulle en l'absence de trafic	●	●	●	○	○	○
4	Proximité géographique de la Mauritanie	○	○	○	◐	◐	●
5	Région d'hébergement unique et documentée	●	●	●	●	◐	○
6	Briques de sécurité managées	●	●	●	○	○	○
7	Maturité de l'infrastructure en code	●	●	◐	◐	○	○
8	Charge d'apprentissage pour une personne seule	◐	○	○	◐	●	●
9	Réversibilité et absence d'enfermement	○	○	○	◐	●	◐
10	Fédération d'identité sans secret permanent	●	●	●	○	○	○

Lecture du tableau. L’option retenue perd sur les critères 2, 9 et 4 : elle n’est ni la moins chère en facturation directe, ni la plus réversible, ni la plus proche géographiquement. Ces trois lignes sont reprises telles quelles au chapitre 6, section « limites ». Le critère 8 doit être lu comme une appréciation et non comme une mesure : il n’a fait l’objet d’aucun protocole, et l’entreprise d’accueil déclare des compétences sur deux des trois grands fournisseurs, ce qui réduit d’autant l’écart entre les trois premières colonnes.

Le contrefactuel. Conserver l’hébergeur européen à forfait aurait maintenu un coût direct plus bas et une portabilité complète : l’architecture d’origine, faite de conteneurs et d’un fichier de composition, se déplaçait d’un hébergeur à l’autre. Le prix en aurait été d’installer et d’exploiter à la main le filtrage applicatif, le gestionnaire de clés, l’annuaire d’identités par charge de travail et l’entrepôt de journaux, puis de les maintenir à jour. C’est la contrainte d’une seule personne, et non une préférence technique, qui a fermé cette voie.

A.3.2 Les douze briques retenues à l’intérieur de la plateforme

TAB. 33. Briques techniques retenues, critère décisif et prix payé

Brique	Retenu	Critère décisif	Prix payé
Répartiteur et filtrage applicatif	Répartiteur global et politique de sécurité managée	Règles maintenues par l’éditeur, point d’entrée unique aligné sur les autorisations	Coût fixe indépendant du trafic ; contenu des signatures non lisible
Mode d’exécution	Conteneurs sans serveur	Voir la comparaison des modes d’exécution en § A.2.5	Démarrage à froid, pas de disque persistant
Base de données	Service managé PostgreSQL, adresse privée, haute disponibilité régionale	Restauration à un instant donné sans exploitant dédié	Le mode régional double le coût de calcul de l’instance
Entrepôt de supervision	Entrepôt généraliste avec recherche vectorielle native	Supprime la base vectorielle séparée	Minimum forfaitaire par table et par requête ; aucun moteur de conversion de règles
Gestion des secrets	Service managé, chiffré par clés gérées	Autorisation par version de secret, aucun serveur à exploiter	Palier gratuit étroit ; dépendance au fournisseur
Clés de chiffrement	Deux clés gérées, une régionale et une globale	Satisfait l’exigence réglementaire du chapitre 1 au coût le plus bas	Une clé indisponible rend les données illisibles
Registre d’images	Registre unique du fournisseur	Même périmètre d’autorisation que le déploiement	Palier gratuit de stockage étroit
Infrastructure en code	Outil déclaratif indépendant du fournisseur	Analyse statique avant création, plan lisible	État à protéger ; remplacements destructifs possibles au plan

TAB. 33. Briques techniques retenues, critère décisif et prix payé (suite)

Brique	Retenu	Critère décisif	Prix payé
Chaîne d'intégration	Forge externe et fédération d'identité	Aucun secret permanent dans le chemin de déploiement	Un tiers hors du périmètre cloud dans le chemin de déploiement
Sortie réseau	Connecteur managé et passerelle de sortie	Confort d'exploitation, écart assumé	Deux instances minimales en permanence : coût plancher
Rapprochement sémantique	Modèle de phrases spécialisé, exécution locale	Voir la comparaison des approches en § 2.4	Pas d'explication en langue naturelle ; qualité non mesurée
Interface de supervision	Interface web avec couche interne d'accès aux données	Aucun accès direct à l'entrepôt depuis le navigateur	Composant à écrire, tester et exploiter

A.3.3 Sources et dates de consultation

Les paliers gratuits (critères 1 et 3) et les implantations régionales (critères 4 et 5) reposent sur la documentation publique des fournisseurs, consultée le 27 août 2026 : paliers gratuits et régions de Google Cloud [15, 16], régions d'Amazon Web Services [6], implantations de Hetzner [18] et régions de Scaleway [29].

Les colonnes « Azure » et « OVH » n'ont pas pu être sourcées à cette date, les pages de documentation correspondantes étant dynamiques et inaccessibles depuis l'environnement de travail ; leurs valeurs relèvent donc de la connaissance générale de l'auteur et non d'une vérification documentaire.

Deux réserves supplémentaires encadrent la lecture du tableau 32. **Première réserve** : aucune mesure de latence depuis Nouakchott n'a été effectuée. Aucune valeur de latence n'est donc publiée, et le critère 4 est apprécié à partir des seules implantations régionales publiées par les fournisseurs. **Seconde réserve** : les grilles tarifaires n'ont pas été relevées à une date unique ni pour un dimensionnement identique. Aucun montant comparatif n'est donc publié, et le critère 2 est apprécié qualitativement à partir des modèles de facturation (usage contre forfait), non à partir de prix mesurés.

Annexe B Extraits techniques de la réalisation

Cette annexe rassemble des éléments techniques dont la reproduction dans le corps du chapitre 5 est proscrite par le guide pédagogique. Les extraits sont courts, localisés et issus du dépôt vérifié le 25/08/2026. Aucun secret ni identifiant de projet réel n’y figure.

B.1 Organisation réelle du dépôt d’infrastructure

Deux environnements contiennent une configuration Terraform effective : `dev` et `staging`. Le répertoire `prod` ne contient qu’un fichier d’amorçage ; la production reste une cible non provisionnée.

```
terraform/
├─ environments/
│   ├── dev/           configuration appliquée
│   ├── staging/       configuration appliquée, second locataire
│   └─ prod/           cible vide (.gitkeep)
├─ modules/
│   ├── app-service, cloud-run, dashboard, workflow
│   ├── vpc, load-balancer, cloud-sql, artifact-registry
│   ├── iam, kms, audit, logging, monitoring
│   └─ bigquery, detection, ml-pipeline
```

Le découpage transpose les niveaux L1–L7 en modules techniques, sans correspondance bijective : plusieurs contrôles traversent plusieurs modules. Le module `app-service` crée les ressources propres à une application ; `iam` porte la fédération ; `bigquery` et `detection` portent les données et les règles ; `ml-pipeline` porte l’encodage et l’enrichissement.

B.2 Trois extraits représentatifs

B.2.1 Deux rôles du compte applicatif

L’extrait suivant provient de `terraform/modules/app-service/main.tf`, lignes 26–36. Il montre les deux rôles observés lors du contrôle IAM du second locataire.

```
resource "google_project_iam_member" "app_cloudsql_client" {
  project = var.project_id
  role    = "roles/cloudsql.client"
  member  = "serviceAccount:${google_service_account.app.email}"
}

resource "google_project_iam_member" "app_log_writer" {
  project = var.project_id
  role    = "roles/logging.logWriter"
  member  = "serviceAccount:${google_service_account.app.email}"
}
```

B.2.2 Prévention de l'accès public au média

L'extrait suivant provient de `terraform/modules/app-service/main.tf`, lignes 133–143. La protection est imposée sur la ressource; elle ne dépend pas d'une politique d'organisation.

```
resource "google_storage_bucket" "media" {
  count      = var.create_bucket ? 1 : 0
  name      = "${var.project_id}-${var.app_name}-media"
  location  = var.region
  project   = var.project_id
  uniform_bucket_level_access = true
  public_access_prevention = "enforced"
  versioning {
    enabled = false
  }
}
```

B.2.3 Fenêtre et cadence de la règle R2

L'extrait de `terraform/modules/detection/main.tf`, lignes 103–114, montre la fenêtre SQL utilisée pour compter les refus WAF.

```
SELECT
JSON_VALUE(json_payload, "$.httpRequest.remoteIp") AS src_ip,
resource_name AS service,
COUNT(*) AS waf_blocks
FROM `${local.project}.${local.dataset}.raw_logs`
WHERE timestamp >= TIMESTAMP_SUB(CURRENT_TIMESTAMP(),
INTERVAL 15 MINUTE)
AND log_source = "armor"
AND UPPER(JSON_VALUE(json_payload,
"$.enforcedSecurityPolicy.outcome")) = "DENY"
GROUP BY src_ip, service
WHERE f.waf_blocks > 10
AND f.src_ip IS NOT NULL
```

La ressource de requête planifiée fixe séparément `schedule = "every 5 minutes"` à la ligne 410. La fenêtre de quinze minutes n'est donc pas la cadence d'exécution.

B.3 Sécurité de l'état d'infrastructure

Le tableau 34 détaille les cinq mesures appliquées au fichier d'état de l'infrastructure et la raison de chacune.

Ces mesures réduisent l'exposition de l'état. Leur résistance à une identité non autorisée reste à confirmer par le test T17, non exécuté dans la campagne actuelle.

TAB. 34. Sécurité du fichier d'état d'infrastructure

Élément	Mise en œuvre	Raison
Emplacement	Stockage objet dédié, versionné et non public	L'état cartographie le système
Séparation	Un préfixe d'état par environnement	Limiter le rayon d'impact d'une erreur
Accès	Identité de la chaîne d'infrastructure et administration	Moindre privilège
Verrouillage	Verrou natif du stockage	Éviter deux applications concurrentes
Secrets	Conteneurs créés en code ; valeurs injectées séparément	Éviter les valeurs sensibles dans l'état

Annexe C Modèle de menaces détaillé

Cette annexe détaille l'atelier 4 (scénarios opérationnels) et l'atelier 5 (appréciation et traitement du risque) de l'analyse EBIOS Risk Manager résumée au chapitre 3, section 3.3. Elle est appelée depuis les sections 3.3.3 et 3.3.4.

C.1 Rappel des flux et de la méthode

STRIDE est appliquée systématiquement aux sept flux de l'architecture, définis en détail à la section 4.2 : F1 (utilisateur → point d'entrée public → filtrage → charge de travail), F2 (charge de travail → réseau privé → base de données), F3 (dépôt → chaîne d'intégration → registre d'images → déploiement), F4 (toutes les couches → collecte de journaux → entrepôt de supervision), F5 (planificateur → tâche d'enrichissement → modèle → recherche vectorielle → alertes enrichies), F6 (vulnérabilités détectées à la livraison → encodage → rapprochement avec les techniques observées → priorisation) et F7 (dépôt → chaîne d'intégration → plan → contrôle → approbation → application). Les six catégories STRIDE sont : usurpation d'identité (S), altération (T), répudiation (R), divulgation d'information (I), déni de service (D), élévation de privilège (E).

C.2 Échelles employées

Le tableau 35 définit les quatre niveaux de gravité retenus et le critère qui permet de classer un scénario dans chacun d'eux.

TAB. 35. Échelle de gravité

Niveau	Libellé	Critère
G1	Mineure	Gêne interne, sans conséquence externe
G2	Significative	Interruption de service ou perte de données limitée et récupérable
G3	Grave	Perte d'intégrité durable, contestation, perte de confiance
G4	Critique	Divulgence de données personnelles ou perte de l'actif principal

Le tableau 36 définit symétriquement les quatre niveaux de vraisemblance, appréciés à partir de ce qui est observé sur des systèmes comparables.

C.3 Scénarios opérationnels

Le tableau 37 liste les vingt-quatre scénarios opérationnels obtenus en appliquant STRIDE aux sept flux, chacun rattaché à son scénario stratégique d'origine (section 3.3.2 du chapitre 3) et, lorsque c'est possible, à une technique de la matrice MITRE ATT&CK [21].

TAB. 36. Échelle de vraisemblance

Niveau	Libellé	Critère
V1	Minime	Suppose des moyens ou un accès préalable importants
V2	Significative	Réalisable par un attaquant motivé disposant d'un accès initial limité
V3	Forte	Régulièrement observé sur des systèmes comparables
V4	Maximale	Systématique, observé en continu sur tout service exposé

TAB. 37. Scénarios opérationnels

#	Flux	STRIDE	Scénario opérationnel	ATT&CK	G	V	Scén. stratégique
SO1	F1	I, E	Exploitation d'une vulnérabilité applicative exposée sur Internet	T1190	G3	V3	SS1
SO2	F1	S	Réutilisation d'identifiants valides obtenus ailleurs	T1078	G3	V3	SS5
SO3	F1	S	Recherche exhaustive de mot de passe sur des comptes existants	T1110	G2	V3	SS5
SO4	F1	D	Saturation du service exposé par un volume de requêtes anormal	T1498/99	G2	V3	SS6
SO5	F1	I	Balayage automatisé de la surface exposée	T1595	G1	V4	SS6
SO6	F2	I	Accès direct à la base de données depuis Internet	T1530	G4	V2	SS1
SO7	F2	E	Identité de service applicative lisant hors de son périmètre	T1078.004	G3	V2	SS1
SO8	F2	I	Jeton d'accès aux données non lié à une identité, transmissible	T1550	G4	V2	SS2
SO9	F3	S	Détournement de l'identité CI par une clé exportée	T1552.001	G4	V2	SS3
SO10	F3	T	Code malveillant via une dépendance ou image de base compromise	T1195.002	G4	V2	SS3
SO11	F3	E	Déploiement d'un artefact non contrôlé, portes contournées	T1195	G3	V2	SS3
SO12	F3	I	Divulgateion d'un secret versionné dans le dépôt ou son historique	T1552.001	G4	V3	SS7
SO13	F4	T	Altération ou suppression de journaux pour dissimuler une action	T1070	G3	V2	SS4
SO14	F4	D	Désactivation ou dégradation de la collecte de journaux	T1562	G3	V2	SS4
SO15	F4	R	Absence de trace permettant d'attribuer une action à un acteur	—	G3	V2	SS4

TAB. 37. Scénarios opérationnels (suite)

#	Flux	STRIDE	Scénario opérationnel	ATT&CK	G	V	Scén. stratégique
SO16	F5	T	Écriture du composant d'enrichissement dans les tables qu'il analyse	T1070	G3	V2	SS4
SO17	F5	E	Composant d'inférence utilisé comme rebond vers d'autres ressources	T1078.004	G3	V1	SS3
SO18	F5	D	Saturation du composant d'inférence par un volume d'alertes anormal	T1499	G2	V2	SS6
SO19	F6	T	Falsification du rattachement d'une vulnérabilité pour la déclasser	—	G2	V1	SS3
SO20	F7	E	Modification de l'infrastructure sans revue, accès direct au fournisseur	T1098	G4	V2	SS3
SO21	F7	I, T	Accès en lecture/écriture à l'état de l'infrastructure	T1530	G4	V2	SS3, SS7
SO22	F7	E	Création d'une identité ou d'un droit par un acteur ayant un premier accès	T1098.001	G4	V2	SS3
SO23	Tous	E	Détournement de ressources de calcul pour un usage illégitime	T1496	G2	V2	SS6
SO24	Tous	I	Exfiltration par un canal sortant légitime et non surveillé	T1567	G3	V2	SS1, SS2

Note de version

Les identifiants de techniques renvoient à la version 19 de la matrice MITRE ATT&CK. Deux techniques employées ici ont changé de tactique lors de cette version : la suppression d'indicateurs (T1070) relève désormais des techniques de discrétion, et la dégradation des défenses (T1562) d'une tactique distincte nouvellement créée. Cette précision conditionne la comparabilité de la mesure de couverture présentée au chapitre 6.

Trois scénarios — SO15, SO19 et l'aspect de répudiation en général — ne correspondent à aucune technique répertoriée. C'est attendu : la matrice ATT&CK décrit des comportements d'attaquants observés, non des défauts de conception ; un défaut de traçabilité n'est pas une technique d'attaque, c'est une condition qui rend les techniques d'attaque indétectables.

C.4 Cartographie du risque

Le croisement gravité × vraisemblance (tableau 38) place les scénarios selon leur niveau de risque **avant traitement**.

Lecture. La zone de risque la plus élevée regroupe huit scénarios, dont sept concernent la chaîne de livraison et le provisionnement de l'infrastructure (F3 et F7), ou l'accès direct aux

TAB. 38. Cartographie du risque avant traitement

	V1 Minimale	V2 Significative	V3 Forte	V4 Maximale
G4 Critique	—	SO6, SO8, SO9, SO10, SO20, SO21, SO22	SO12	—
G3 Grave	SO17	SO7, SO13, SO14, SO15, SO16, SO24	SO1, SO2	—
G2 Significative	SO19	SO18, SO23	SO3, SO4	—
G1 Mineure	—	—	—	SO5

données (F2). Ce résultat oriente toute la conception : le risque dominant ne provient pas de l'application exposée sur Internet — pourtant le seul point que le modèle périmétrique protégeait — mais des chemins d'administration et de livraison, qui disposent par nature de droits élevés et qui, dans l'existant décrit au chapitre 1, n'étaient soumis à aucun contrôle. Le scénario SO12, seul scénario critique de vraisemblance forte, correspond exactement au point bloquant B2 de l'audit du chapitre 1.

C.5 Décisions de traitement

Le tableau 39 récapitule la décision de traitement retenue pour chaque scénario et la justification de cette décision.

TAB. 39. Décisions de traitement du risque

Décision	Scénarios	Justification
Réduire	SO1, SO4, SO6 à SO14, SO16, SO18, SO20 à SO24	Traités par des contrôles d'architecture, détaillés en section 3.4
Réduire partiellement	SO2, SO3, SO5	Le socle limite l'exposition et détecte ; le traitement complet relève du code applicatif, hors périmètre
Réduire puis accepter le résiduel	SO17, SO19	Contrôles prévus sur l'inférence et F6 ; risque résiduel accepté faute de validation complète, décision révisable
Transférer	—	Aucun transfert (pas d'assurance ni de sous-traitance de sécurité dans le périmètre)

L'acceptation du risque résiduel SO17/SO19 ne signifie pas l'absence de contrôle : elle intervient après les mesures de réduction prévues et doit être réévaluée après les tests T14 et F6.

C.6 Formulation complète des vingt exigences de sécurité

Le tableau 40 donne la formulation complète des vingt exigences dérivées de l'analyse de risque. Chacune est rédigée comme une propriété vérifiable du système, et non comme une intention. La matrice de traçabilité du chapitre 3 les relie au scénario qui les impose, au contrôle qui les réalise et au test qui en établit l'efficacité.

TAB. 40. Formulation complète des exigences de sécurité

#	Exigence de sécurité
EX1	Toute requête empruntant le point d'entrée public est soumise aux règles de filtrage configurées
EX2	Les tentatives d'authentification anormales sont limitées et détectées
EX3	Le service reste disponible sous charge anormale et le balayage est tracé
EX4	La base applicative n'expose pas d'adresse publique et une connexion directe depuis Internet est refusée
EX5	Une identité applicative ne peut accéder qu'aux données de son périmètre
EX6	Tout accès aux données est lié à une identité vérifiée, sans jeton transmissible
EX7	Les comptes de service du périmètre n'utilisent pas de clé statique inventoriée ; toute exception est tracée
EX8	Un artefact présentant une vulnérabilité critique corrigeable détectée par la porte configurée est bloqué
EX9	Le déploiement ne peut tirer que du registre de confiance unique
EX10	Un secret reconnu par les règles du détecteur configuré bloque la chaîne avant livraison
EX11	Les identités d'exécution des composants d'analyse n'ont aucun droit d'écriture sur les tables de preuve
EX12	Toute interruption de la collecte de journaux est détectable
EX13	Toute action privilégiée est attribuable à un acteur identifié
EX14	Le composant d'inférence n'accepte que des appels internes ; sa sortie n'est ni restreinte ni journalisée dans la configuration déployée, et T14 n'est pas exécuté
EX15	Une charge anormale d'alertes ne compromet pas la chaîne d'enrichissement
EX16	Une modification hors code d'une ressource déjà gérée est détectée par rafraîchissement ; les ressources non gérées sont contrôlées par inventaire
EX17	L'état de l'infrastructure est privé, versionné et chiffré
EX18	Toute modification de droits est revue avant application
EX19	Une consommation de ressources anormale est détectée
EX20	Les sorties réseau devraient être limitées à des destinations connues et journalisées ; aucune règle de sortie n'est déclarée à ce jour, T20 n'est pas exécuté

Annexe D Conception détaillée

Cette annexe développe quatre ensembles condensés dans le corps du chapitre 4 : la conception détaillée couche par couche (section D.1, condensée dans le chapitre 4), le registre complet des décisions d'architecture avec leur justification (section D.2, condensé en tableau 12), et les composants évalués puis écartés avec leurs conditions de réévaluation (section D.3, condensé en section 4.8.2), enfin la prise en charge des vingt exigences par la conception (section D.4).

D.1 Conception détaillée par couche

La correspondance entre chaque capacité décrite au chapitre 4 et le service managé qui la réalise est donnée sous chaque couche, à la ligne « Produits employés ». Les capacités restent le vocabulaire du rapport ; les produits n'en sont que l'instanciation chez le fournisseur retenu par la décision D00.

Chaque couche est décrite selon le même gabarit : composants, produits employés, contrôles apportés, exigences couvertes, point de vigilance.

L1 — Périmètre d'entrée

Composants. Zone DNS publique, répartiteur de charge applicatif global, certificats gérés, moteur de filtrage applicatif.

Produits employés. Cloud Load Balancing (répartiteur global HTTPS, certificats gérés), Cloud Armor (politique de sécurité portant la géo-restriction, les règles applicatives préconfigurées et la limitation de débit à deux niveaux), Cloud DNS — ce dernier hors du périmètre décrit en code, comme l'indique le registre des écarts du chapitre 4.

Exposition et terminaison TLS. HTTPS exclusivement : le port 80 est redirigé de manière permanente vers le 443, le répartiteur applique une politique de chiffrement moderne dont la version minimale de TLS est fixée à 1.2, et les certificats sont gérés par le fournisseur, un par domaine. Deux domaines distincts sont exposés : un domaine applicatif et un domaine de supervision. En aval, le chiffrement est également imposé sur la connexion à la base de données.

Filtrage applicatif. Cinq familles de règles préconfigurées, appliquées en **blocage direct** et non en observation. Un moteur de filtrage laissé indéfiniment en mode observation enregistre ce qu'il aurait bloqué sans rien bloquer réellement ; c'est utile pour calibrer les règles, mais ne protège de rien à long terme. Le passage en blocage direct est une décision assumée, dont la contrepartie — le risque de faux positifs — est mesurée au chapitre 6.

Restriction géographique. Autorisation limitée aux zones où se trouvent les utilisateurs et l'entreprise, avec exceptions pour les sondes de disponibilité.

Limitation de débit à deux niveaux. Un seuil strict sur les seuls chemins d'authentification, avec bannissement temporaire, et un seuil global élevé contre la saturation. Un seuil unique appliqué à l'ensemble du trafic posait un problème non anticipé par la conception initiale :

lorsque le tableau de bord appelle l'API, les deux services partagent une adresse de sortie, et un seuil serré déclenchait un blocage collectif à partir de l'activité d'un seul utilisateur. La séparation en deux niveaux — strict sur l'authentification, permissif ailleurs — résout ce problème.

Exigences couvertes. EX1, EX2, EX3.

Point de vigilance. La limitation par adresse IP est peu discriminante dans un contexte où de nombreux abonnés partagent un petit nombre d'adresses publiques, ce qui est le cas de la zone géographique visée. Le seuil global est donc volontairement large, et la protection fine reste assurée par les limiteurs applicatifs. Aucun composant n'est ajouté pour traiter ce point, conformément au principe P1.

L2 — Identité et sécurité (plan transversal)

Composants. Annuaire d'identités de service, coffre de secrets, service de gestion de clés, fédération d'identité pour la chaîne d'intégration. Ce plan n'est pas une couche traversée : il est interrogé à chaque appel, quel que soit le niveau (principe P2).

Produits employés. Cloud IAM (sept comptes de service), Secret Manager (six secrets), Cloud KMS (deux trousseaux, deux clés, rotation de quatre-vingt-dix jours), Workload Identity Federation.

Exigences couvertes. EX5, EX6, EX7, EX10, EX11.

Point de vigilance. La politique d'organisation qui devait interdire toute création de clé de longue durée est inapplicable dans le périmètre administratif disponible (É7) ; la fédération d'identité reste le contrôle effectif, et T7 la preuve manquante.

L3 — Charges de travail

Composants. Quatre services d'exécution de conteneurs : l'application hébergée, l'API de supervision, le tableau de bord, le service d'encodage.

Produits employés. Cloud Run, avec entrée restreinte au répartiteur interne.

Entrée. Tous les services publics n'acceptent le trafic que depuis le répartiteur : les adresses directes du fournisseur sont neutralisées.

Identité. Une identité de service distincte par charge de travail.

Déploiement. Le chemin CI quotidien utilise une étiquette fondée sur le SHA du commit. Cette étiquette améliore la traçabilité, mais n'est pas un digest immuable. Le chemin d'amorçage/reprise résout un digest réel ; l'unification des deux chemins reste ouverte (É8).

Exigences couvertes. EX6, EX9.

Point de vigilance. La configuration d'entrée des services doit refuser le trafic qui ne provient pas du répartiteur. Cette propriété réduit les chemins d'accès, mais doit être contrôlée par un test négatif ; elle n'est pas qualifiée d'impossibilité absolue. Le rôle d'invocation est de surcroît accordé à tous sur l'API et sur le tableau de bord : la protection de ces deux services tient entièrement au paramètre d'entrée restreint au répartiteur, et une régression sur ce seul champ les exposerait publiquement, sans authentification de plateforme. Le choix est assumé dans le code, faute d'un service d'authentification en amont disponible hors organisation.

L4 — Réseau

Cette couche porte les exigences EX4 et EX20. Elle est la seule du modèle à ne disposer d’aucune preuve dynamique : ses trois tests (T4, T14, T20) sont non exécutés. Sa topologie est donc reconstituée depuis le code d’infrastructure, seule preuve disponible. Le tableau 41 l’expose ligne par ligne — plages déclarées, priorités des règles, état réellement observé — de sorte que chaque affirmation puisse être recoupée avec le dépôt. Les produits employés sont un VPC en mode personnalisé et deux sous-réseaux, Serverless VPC Access, Private Service Access, Cloud NAT et Cloud Router, et des règles de pare-feu en refus par défaut en entrée.

TAB. 41. Topologie et règles de filtrage réellement déclarées.

Élément	Plage	Prio.	État observé
Sous-réseau public	10.0.1.0/24	—	Aucune ressource : retrait décidé (É2)
Sous-réseau privé	10.0.2.0/24	—	Aucune ressource ; accès privé et journaux de flux actifs
Connecteur	10.0.3.0/28	—	Deux instances au minimum, dix au maximum ; seul occupant réel
Base de données	Plage en appairage	—	Adresse privée exclusive, aucune adresse publique
Refus général en entrée	0.0.0.0/0	65534	Journalisée ; alimente la détection de mouvement latéral
Autorisation interne	10.0.1.0/24 et 10.0.2.0/24	900	Tous ports TCP et UDP, plus ICMP, sans granularité
Autorisation HTTPS	0.0.0.0/0	1000	Étiquette cible jamais attribuée
Sondes de disponibilité	35.191.0.0/16 et 130.211.0.0/22	800	Étiquette cible jamais attribuée
Sortie	—	—	Aucune règle de sortie déclarée : sortie autorisée par défaut

Point de vigilance. La sortie n’est pas contrôlée : aucune règle de sortie, aucune liste d’autorisation, aucun périmètre de service n’est déclaré, de sorte que la règle implicite du fournisseur — qui autorise tout — s’applique sans être journalisée ; T20 reste la preuve manquante. Pour le service d’encodage, seule l’entrée est restreinte aux appels internes : le réglage « plages privées seulement » ne porte que sur le trafic empruntant le connecteur et laisse intacte la route Internet par défaut du service d’exécution, ce que T14, non exécuté, n’a pas démasqué. Le canal de détection des refus réseau est par ailleurs structurellement muet : l’export qui alimente la détection filtre les refus de pare-feu, or la seule règle qui journalise est le refus général *en entrée*, évalué uniquement sur du trafic entrant vers une ressource du sous-réseau privé. Comme aucune ressource n’y est joignable, cet export ne peut produire aucun enregistrement en l’état de la topologie : l’écart É1 est clos au sens de la configuration, non au sens de la preuve. Le principe de conception de cette couche reste néanmoins celui-ci : le réseau transporte, il n’autorise pas. Être situé à l’intérieur du réseau privé ne confère aucun droit ; chaque appel repasse par la vérification d’identité du plan L2.

L5 — Données

Cette couche héberge deux systèmes de nature très différente. **La base de données applicative** stocke les données métier de l’application hébergée : adresse privée, sauvegarde

avec restauration à un instant donné, accès réservé aux identités applicatives. **L'entrepôt de supervision** est le cœur du dispositif de détection ; sa chaîne de traitement compte quatre étapes : journaux bruts (alimentés par la collecte F4, partitionnés par jour, filtrés à la source, avec expiration automatique) → détectons (règles de détection versionnées, exécutées à intervalle régulier) → enrichissement (tâche F5 : encodage puis recherche vectorielle, rattachement à une technique d'attaque avec score) → scoring et présentation au tableau de bord de l'analyste.

Produits employés. Cloud SQL for PostgreSQL 15 (adresse privée seule, haute disponibilité régionale, restauration à un instant donné sur sept jours), BigQuery (jeu de données de supervision et dix tables), Cloud Storage (espace média chiffré par clé gérée, prévention d'accès public).

Contrôles. Intégrité des preuves : droits d'écriture sur les journaux bruts et les détectons réservés à la collecte et aux règles, aucune identité applicative ou d'analyse n'y a accès (EX11). Maîtrise du coût : partitionnement par jour ; expiration à quatre-vingt-dix jours sur les seules tables de journaux ; filtrage à la source lors de la collecte (BNF3). Aucune expiration par défaut n'est fixée au niveau du jeu de données : sur les dix tables, deux portent une expiration et deux ne sont pas partitionnées. Seuil de rattachement déclaré explicitement en tête de requête, donc auditable et modifiable sans redéploiement (BNF6).

Point de vigilance. Il aurait été possible d'abaisser le seuil de rattachement jusqu'à ce que toute alerte reçoive un rattachement — produisant un tableau de bord entièrement rempli et entièrement faux. Le choix inverse a été fait : afficher le taux d'alertes non rattachées comme un indicateur de qualité. Un système qui avoue ne pas savoir est plus utile qu'un système qui devine.

L6 — Enrichissement sémantique

Modèle. Modèle de représentation de phrases spécialisé en cybersécurité, révision figée, format de poids refusant l'exécution de code, empreintes consignées.

Produits employés. Cloud Run en entrée interne seule, modèle embarqué dans l'image et exécuté hors ligne, recherche vectorielle native de BigQuery.

Optimisation. Un export quantifié a été testé puis rejeté après 0 correspondance de premier rang sur 5 requêtes. Le format fp32 est conservé en recette ; ce test limité ne valide pas sa qualité générale.

Service d'encodage. Poids embarqués dans l'image, aucun téléchargement à l'exécution, appel authentifié obligatoire et entrée interne. La sortie effective reste à vérifier par T14.

Tâche d'enrichissement. Déclenchée à intervalle fixe, traite les détectons non enrichies par lots.

Chaîne d'approvisionnement. L'image traverse les mêmes contrôles que toute autre : les poids d'un modèle sont un artefact tiers non fiable.

Exigences couvertes. EX14, EX15.

Trois décisions de sécurité structurent cette couche. Les poids du modèle sont traités comme un artefact non fiable : ils proviennent d'un tiers et sont chargés par un processus disposant de droits ; le format retenu exclut l'exécution de code à la désérialisation, les

empreintes sont vérifiées, et l'image passe par les mêmes contrôles de vulnérabilité que le code applicatif. Le service est configuré sans chemin public direct, mais l'absence de sortie n'est pas déclarée vérifiée tant que T14 n'est pas joué. Les poids sont embarqués dans l'image plutôt que téléchargés à l'exécution : un téléchargement au démarrage introduirait une dépendance externe dans le chemin critique et un point d'injection dans la chaîne d'approvisionnement.

L7 — Observabilité

Sources. Journaux d'audit du fournisseur, journaux des charges de travail, verdicts du filtrage applicatif, journaux réseau (EX13).

Produits employés. Cloud Logging (quatre exports) et Cloud Monitoring (politiques d'alerte, objectifs de service, sonde de disponibilité).

Collecte. Vers l'entrepôt de supervision, avec filtres d'exclusion appliqués à la source (EX12, BNF3).

Supervision. Sondes de disponibilité sur les points de santé des services (BNF1).

Politiques d'alerte. Taux d'erreurs, latence du service d'encodage, échec de la tâche d'enrichissement, pic de blocages au périmètre, échec de connexion aux données (EX12, EX19).

Procédures. Une procédure d'incident par famille de technique d'attaque, accessible directement depuis le tableau de bord (BNF4).

Indicateurs. Délai de détection, part des détections issues du rattachement sémantique, taux d'alertes non rattachées, latence, version du modèle (BNF6).

Point de vigilance. Le lien entre le tableau de bord et les procédures d'incident est ce qui rend le dispositif utilisable par une personne seule. Une alerte affichée sans conduite à tenir transfère intégralement la charge d'interprétation à l'analyste — c'est précisément ce que le besoin BNF4 cherche à éviter.

D.2 Registre complet des décisions d'architecture

Chaque décision structurante figure ci-dessous avec son statut — **validée** (conservée telle quelle), **retouchée** (ajustée par rapport à la conception initiale), **ajoutée**, ou **écartée** — et sa justification complète.

D00 — Google Cloud comme fournisseur unique du socle (validée). La contrainte humaine écarte l'auto-hébergement des briques de sécurité ; la contrainte économique écarte la facturation au forfait. Entre les trois fournisseurs restants, le critère décisif est la présence, dans un même entrepôt, du stockage, du langage de détection et de la recherche vectorielle appelée par les décisions D04 et D06 : elle supprime la base vectorielle séparée qu'imposeraient les deux autres. La comparaison des six options d'hébergement sur dix critères, et celle des douze briques retenues, figurent en annexe A.3. Cette décision est la moins réversible du registre : elle conditionne D01 à D07 et D11.

D01 — Exécution de conteneurs sans serveur comme unique plateforme (validée). Aucun système d'exploitation à durcir, chiffrement interne natif, identité par service, réduction à zéro hors trafic. Un orchestrateur apporterait une souplesse dont ce périmètre n'a pas besoin, au prix d'un cluster à exploiter.

D02 — Point d'entrée unique avec filtrage applicatif (validée). Un point d'entrée unique est un point de contrôle unique. Le filtrage managé couvre les risques applicatifs courants sans composant à maintenir.

D03 — Base de données managée, adresse privée, restauration à un instant donné (validée). Correspond au besoin de l'application hébergée. L'instance de recette a été basculée en haute disponibilité régionale le 08/08/2026 (voir D13).

D04 — Entrepôt de données généraliste comme système de supervision (validée). Le système de supervision est *construit*, non acheté : c'est l'apport du projet. L'entrepôt fournit le stockage, le langage de détection, et — point décisif — la recherche vectorielle nécessaire à L6 sans base spécialisée.

D05 — Modèle de représentation non génératif pour l'enrichissement (validée). Sortie plus facilement reproductible qu'une génération libre et exécution sur processeur généraliste. Ce choix réduit la surface d'injection par instruction, sans supprimer les risques liés aux entrées, au modèle ou à sa chaîne d'approvisionnement.

D06 — Recherche vectorielle déportée dans l'entrepôt (validée). Supprime un composant entier. Cohérent avec le principe P1.

D07 — Registre d'images unique, retrait du second registre (retouchée). Deux registres constituent deux surfaces de chaîne d'approvisionnement et une ambiguïté sur la source de vérité. Les images de base restent accessibles par un dépôt miroir en lecture.

D08 — Fédération d'identité pour la chaîne d'intégration (ajoutée). Évite une clé de longue durée dans le chemin CI. La politique d'organisation censée interdire toute création de clé est inapplicable dans le périmètre administratif disponible (É7).

D09 — Détection de secrets en tête de chaîne (ajoutée). Coût quasi nul, gain élevé. L'audit du chapitre 1 démontre précisément le coût d'un secret mal géré.

D10 — Autorisation applicative par rôles conservée (validée). L'autorisation applicative reste dans l'application ; l'autorisation d'infrastructure protège l'infrastructure. Les deux plans ne se substituent pas l'un à l'autre.

D11 — Sortie réseau par le chemin contrôlé (réserve). Zero Trust ne signifie pas absence de sortie. Le routage est configuré ; les tests dynamiques T14 et T20 restent à exécuter.

D12 — Infrastructure en code comme standard unique de provisionnement (validée, renforcée). Réponse directe au point bloquant B5. Trois gains : reproductibilité, contrôle avant création, détection de dérive.

D13 — Haute disponibilité régionale appliquée (révision de D03, 08/08/2026). La bascule a été appliquée en recette et confirmée en direct le 08/08/2026, en 11 min 2 s ; le point de défaillance zonal de la base de données est fermé, et le code d'infrastructure décrit désormais cet état. Limite subsistante : le basculement de zone n'a jamais été provoqué ni chronométré en conditions réelles.

Un second registre, tenu au fil de la réalisation, enregistre les décisions prises face aux contraintes rencontrées — quinze entrées à la date de référence, la plus ancienne du 30/07/2026 et la plus récente du 19/08/2026, portant notamment sur la généralisation multi-application, la cadence réelle de l'enrichissement, la restriction géographique et la limitation de débit à

deux niveaux. Les deux registres sont complémentaires : le premier documente le *pourquoi* de l'architecture cible, le second le *pourquoi* de chaque évolution.

D.3 Composants évalués puis écartés

Sept éléments ont été évalués puis écartés en application du principe P1. Les documenter a autant de valeur que documenter ce qui est retenu : cela démontre que leur absence est une décision et non une lacune.

Périmètre de protection contre l'exfiltration. Mécanisme puissant mais lourd à exploiter (exceptions, diagnostic complexe), disproportionné pour un périmètre à projet unique. *Condition de réévaluation* : passage en production multi-équipes avec données réglementées.

Orchestrateur de conteneurs et maillage de services. La plateforme retenue fournit déjà le chiffrement interne et l'identité par service ; un maillage ajouterait un plan de contrôle entier sans couvrir de menace résiduelle identifiée. *Condition de réévaluation* : besoin de charges longues, à état, ou de politiques fines entre services.

Cache distribué. Nécessaire uniquement pour des limitations de débit distribuées et un cache multi-instances — exigence de mise à l'échelle explicitement hors objectif (BNF7). *Condition de réévaluation* : montée en charge réelle.

Déploiement multi-région. Coût doublé, complexité triplée, valeur de démonstration nulle. Les sauvegardes couvrent le risque de perte de données. *Condition de réévaluation* : exigence contractuelle de disponibilité.

Vérification de signature des images au déploiement. Contrôle excellent, mais son apport marginal après le contrôle de vulnérabilité, le registre unique et la fédération d'identité est faible à ce stade. *Condition de réévaluation* : première extension recommandée après le projet.

Passerelle d'authentification devant le tableau de bord. L'autorisation applicative par rôles couvre le besoin du périmètre ; une passerelle ajouterait une fédération d'entreprise redondante ici. *Condition de réévaluation* : ouverture du tableau de bord à des identités d'entreprise.

Modèle de langue génératif pour l'analyse d'incidents. Écarté **par conception** : sortie non déterministe et surface d'injection par le contenu des journaux, inacceptables dans une chaîne de preuve. *Condition de réévaluation* : aucune — le choix non génératif est un contrôle de sécurité, pas une contrainte subie.

Les six premiers écarts sont des arbitrages de coût ou de complexité, révisables. Le septième est un choix de sécurité : il ne sera pas révisé si le contexte change, parce que la raison de l'écart ne dépend pas du contexte.

D.4 Prise en charge des vingt exigences par la conception

Le tableau 42 donne, exigence par exigence, la ou les couches qui la prennent en charge et son état de validation à la date de référence. Le corps du rapport (§ 4.7) n'en retient que la synthèse et les trois réserves. L'intitulé complet de chaque exigence figure dans la matrice de traçabilité du chapitre 3 et en annexe C.

Trois exigences seulement portent une réserve de conception, et elles sont nommées comme telles dans le corps : EX7, EX9 et le couple EX16 / EX18. Les autres sont prises en charge par la conception ; leur état de validation dépend de l'exécution du test associé, non de l'architecture.

TAB. 42. Prise en charge des exigences par la conception et état de validation

Exigence	Couche(s)	Statut
EX1	L1	Prévue ; T1 partiellement conforme
EX2	L1, L5	Prévue ; T2 conforme
EX3	L1, L7	Prévue ; T3 partiellement conforme
EX4	L4, L5	Prévue ; T4 non exécuté
EX5	L2	Prévue ; T5 conforme
EX6	L2, L3	Prévue ; T6 non exécuté
EX7	L2	Réserve : politique d'organisation inapplicable (écart É7)
EX8	F3	Prévue ; T8 non exécuté
EX9	L2, F3	Réserve : déploiement par étiquette de commit, empreinte stricte non prouvée (écart É8)
EX10	L2, F3	Prévue ; T10 non exécuté
EX11	L2, L5	Prévue ; T11 conforme
EX12	L7	Prévue ; T12 non exécuté
EX13	L7	Prévue ; T13 non exécuté
EX14	L4, L6	Prévue ; T14 non exécuté
EX15	L6	Prévue ; T15 non exécuté
EX16	F7	Réserve : bornée aux ressources déjà gérées ; T16 partiellement conforme
EX17	F7	Prévue ; T17 non exécuté
EX18	F7	Réserve : revue manuelle, sans porte d'approbation outillée ; T18 partiellement conforme
EX19	L7	Prévue ; T19 non exécuté
EX20	L4	Journalisation des refus déployée le 19/08/2026 ; T20 non exécuté

Annexe E Protocoles et preuves de validation

Cette annexe donne le détail intégral de la campagne de vingt tests introduite au chapitre 6 : les paramètres de mesure, le modèle de fiche appliqué à chaque test, puis le protocole complet des vingt tests avec leur résultat à la date de rédaction. Elle sert de base de reproduction : un tiers disposant du même environnement peut rejouer les protocoles, à condition de consigner les paramètres encore absents des sources (limite L5, chapitre 6).

E.1 Paramètres de la campagne

Le tableau 43 récapitule les conditions de mesure de la campagne et signale explicitement les paramètres que les sources ne permettent pas d'établir.

TAB. 43. Conditions de mesure de la campagne

Paramètre	Valeur
Environnement	Recette (topologie identique à la cible, chapitre 5 §5.1.1)
Période d'observation	Preuves ponctuelles datées jusqu'au 19/08/2026 ; fenêtre unique non définie
Durée d'observation continue	Non établie par les sources
Version de la matrice de techniques d'attaque employée	Non consignée ; aucun taux publié
Version du référentiel d'infrastructure employé	Non consignée ; aucun taux publié

E.2 Modèle de fiche de test

Chaque test ci-dessous suit systématiquement le même modèle à cinq champs, pour rendre la campagne reproductible par un tiers : un identifiant (**Ti**) renvoyant à l'exigence et à la menace du chapitre 3 (**EXi**) qu'il vérifie ; un **protocole**, décrivant l'action tentée ; un **critère d'acceptation**, formulé avant l'exécution et non révisé après coup ; un **résultat**, exprimé selon la convention à quatre valeurs du chapitre 6 (§6.1) ; et, lorsqu'il est disponible, un renvoi vers la preuve associée (capture, extrait de journal). Les protocoles ci-après sont ceux dérivés du chapitre 3, antérieurs à la conception de l'architecture.

E.3 Protocoles détaillés

T1 — Filtrage des attaques applicatives (EX1, SO1). Envoyer, depuis l'extérieur, des charges d'attaque correspondant aux cinq familles de règles activées au périmètre. *Critère* : toutes les requêtes sont rejetées avant d'atteindre la charge de travail, verdict journalisé.

Résultat : partiellement conforme — les charges SQLi/XSS/LFI ont été bloquées, mais un motif WAF brut a reçu une redirection 302 au lieu du refus attendu.

T2 — Limitation des tentatives d'authentification (EX2, SO2/SO3). Générer des échecs d'authentification répétés depuis une adresse unique jusqu'au franchissement du seuil. *Critère* : blocage temporaire déclenché, alerte présente dans l'entrepôt. *Résultat* : conforme — 11 requêtes POST ont produit 10 réponses 422 puis une réponse 429 le 19/08/2026.

T3 — Comportement sous charge et traçabilité du balayage (EX3, SO4/SO5). Générer une charge supérieure au seuil global puis un balayage de la surface exposée. *Critère* : le service reste disponible, les deux activités apparaissent dans les journaux. *Résultat* : partiellement conforme — le balayage est tracé, mais l'essai de charge complet n'est pas documenté.

T4 — Inaccessibilité des données depuis Internet (EX4, SO6). Depuis un hôte externe, tenter une connexion directe à la base de données ; vérifier par inventaire qu'aucune adresse publique n'est attribuée. *Critère* : aucune adresse publique, connexion en échec. *Résultat* : non exécuté.

T5 — Cloisonnement des identités applicatives (EX5, SO7). Avec l'identité d'une application hébergée, tenter une lecture de l'entrepôt de supervision. *Critère* : refus d'autorisation. *Résultat* : conforme : deux rôles exacts et usurpation refusée le 23/08/2026 ; l'identité ML était sans rôle BigQuery le 19/08/2026.

T6 — Authentification des appels entre services (EX6, SO8). Appeler le service d'encodage sans jeton d'identité, depuis l'intérieur du réseau privé. *Critère* : refus — être « à côté » ne doit rien accorder. *Résultat* : non exécuté.

T7 — Absence de clés de longue durée (EX7, SO9). Inventorier les clés existantes pour toutes les identités de service ; tenter d'en créer une. *Critère* : inventaire vide et absence de clé exportée dans la chaîne. *Résultat* : partiellement conforme : la fédération sans clé est utilisée, mais la politique d'organisation initialement prévue est inapplicable et l'inventaire exhaustif n'est pas archivé.

T8 — Blocage d'un artefact vulnérable (EX8, SO10). Soumettre à la chaîne une image contenant une vulnérabilité critique connue. *Critère* : arrêt à l'étape d'analyse de vulnérabilité [23]. *Résultat* : non exécuté.

T9 — Registre de confiance unique (EX9, SO11). Tenter un déploiement depuis une source d'images externe, puis par référence mutable au lieu d'un digest. *Critère* : les deux tentatives échouent [23]. Une étiquette contenant un SHA de commit ne constitue pas un digest d'image immuable. *Résultat* : non exécuté selon ce critère corrigé.

T10 — Blocage d'un secret versionné (EX10, SO12). Soumettre un secret factice de format reconnaissable ; vérifier séparément qu'aucun secret du système n'est dérivé d'un autre. *Critère* : arrêt à la première étape, indépendance confirmée par inventaire. *Résultat* : non exécuté.

T11 — Intégrité de la chaîne de preuve (EX11, SO13/SO16) — *test le plus discriminant*. Avec l'identité de la tâche d'enrichissement, tenter une écriture puis une suppression dans les tables de journaux bruts et de détections. *Critère* : refus sur les deux tables, écriture restant possible sur la seule table d'enrichissement. *Résultat* : conforme selon la vérification des droits table par table du 19/08/2026 après séparation de l'identité.

T12 — Détection d'une interruption de collecte (EX12, SO14). Interrompre volontairement la collecte au-delà du seuil d'alerte. *Critère* : une alerte est émise. *Résultat* : non exécuté.

T13 — Attribution des actions privilégiées (EX13, SO15). Exécuter une action privilégiée identifiable, la retrouver dans les journaux d'audit avec son auteur. *Critère* : action retrouvée, auteur identifié, horodatage cohérent. *Résultat* : non exécuté.

T14 — Sortie du composant d'inférence (EX14, SO17). Depuis le composant d'encodage, tenter une connexion sortante vers une destination externe. *Critère* : échec de connexion. *Résultat* : non exécuté. La configuration déployée restreint l'entrée aux appels internes, mais ne restreint pas la sortie : le réglage employé ne porte que sur le connecteur réseau et laisse intacte la route par défaut. Ce test reste le seul moyen d'établir la propriété.

T15 — Comportement de la chaîne d'enrichissement sous charge (EX15, SO18). Injecter un volume de détections nettement supérieur au volume nominal. *Critère* : la tâche se termine sans perte, coût et durée mesurés. *Résultat* : non exécuté.

T16 — Détection de dérive (EX16, SO20). Modifier hors code un attribut réversible d'une ressource déjà gérée dans l'état, puis exécuter une planification avec rafraîchissement. *Critère* : la planification signale la différence et les journaux d'audit identifient l'auteur [17]. Une ressource nouvelle absente de l'état exige un contrôle d'inventaire séparé. *Résultat* : partiellement conforme ; l'incident CMEK du 08/08 et un plan sans différence du 19/08 corroborent le mécanisme, mais ce protocole corrigé n'a pas été rejoué.

T17 — Protection de l'état de l'infrastructure (EX17, SO21). Tenter un accès en lecture à l'état avec une identité non autorisée. *Critère* : refus. *Résultat* : non exécuté.

T18 — Revue avant modification de droits (EX18, SO22). Soumettre une modification élargissant les droits d'une identité. *Critère* : blocage en attente d'approbation, aucune application sans validation humaine. *Résultat* : partiellement conforme : revue de demande de fusion et application manuelle présentes, mais approbation non outillée.

T19 — Détection d'une consommation anormale (EX19, SO23). Provoquer une consommation de ressources nettement supérieure au profil habituel. *Critère* : alerte émise. *Résultat* : non exécuté.

T20 — Restriction des sorties réseau (EX20, SO24). Depuis une charge de travail applicative, tenter une connexion sortante vers une destination non autorisée. *Critère* : échec de connexion et trace de refus exploitable. La journalisation É1 est activée depuis le 19/08/2026 ; il reste à provoquer le refus et à rapprocher la trace. *Résultat* : non exécuté.

E.4 Synthèse

La synthèse des vingt tests et de leur statut figure au tableau 17 du chapitre 6 et n'est pas reproduite ici : ce tableau porte, exigence par exigence, un commentaire plus détaillé et davantage de preuves datées que le rappel qui figurait auparavant à cet endroit. L'annexe n'ajoute donc au chapitre 6 que le protocole complet de chaque test, avec son critère d'acceptation formulé avant exécution, exposé section par section ci-dessus.

Annexe F Jeu d'évaluation de l'enrichissement sémantique

Cette annexe donne le détail complet de l'évaluation condensée au chapitre 6, §6.4.1 : constitution du jeu de test, méthode d'annotation, méthodes comparées et résultats par méthode.

F.1 Constitution du jeu d'évaluation

Le tableau 44 précise la spécification retenue pour le jeu d'évaluation : source, taille visée, mode d'échantillonnage et règle d'annotation.

TAB. 44. Spécification du jeu d'évaluation

Élément	Spécification
Source prévue	Alertes produites par le système sur une période d'observation définie
Taille visée	100 alertes, minimum 50
Échantillonnage	Aléatoire parmi les alertes distinctes, pour éviter la sur-représentation des règles bruyantes
Annotation	Rattachement manuel de chaque alerte à la technique attendue, ou à l'étiquette « aucune technique applicable »
Annotateur	Non désigné dans les sources disponibles

Point de vigilance

Une annotation réalisée par une seule personne, également auteure du système évalué, introduit un biais (B1, chapitre 6 §6.8). Deux atténuations sont retenues : annoter **avant** de consulter les sorties du modèle, et faire réannoter un sous-ensemble par une seconde personne. Cette seconde annotation et le taux d'accord ne sont pas disponibles ; l'évaluation comparative est donc considérée comme non exécutée.

F.2 Méthodes comparées

Le tableau 45 présente les trois méthodes de rattachement mises en regard et le rôle que chacune tient dans la comparaison.

F.3 Métriques

Exactitude au premier rang : part des alertes dont la technique attendue est proposée en première position. **Exactitude aux trois premiers rangs** : part des alertes dont la technique attendue figure parmi les trois propositions. **Taux d'abstention** : part des alertes laissées sans rattachement, sous le seuil de similarité. **Taux d'erreur silencieuse** : part des alertes rattachées à une technique *incorrecte* avec un score supérieur au seuil — la métrique la plus importante et la moins souvent rapportée. Une abstention est visible et sans danger : l'analyste sait que le

TAB. 45. Méthodes de rattachement comparées

Méthode	Description	Rôle
M0 — correspondance par mots-clés	Table de correspondance écrite à la main entre termes fréquents et techniques	Référence basse
M1 — pondération de termes et similarité	Représentation statistique du texte, similarité cosinus contre les descriptions de techniques	Référence intermédiaire, sans apprentissage de domaine
M2 — modèle de représentation spécialisé	Méthode retenue par le projet [5, 2]	Méthode évaluée

système ne sait pas. Un rattachement erroné présenté avec un score élevé est trompeur : il oriente vers la mauvaise procédure. **Un système qui s'abstient souvent mais se trompe rarement est préférable à l'inverse**, et cette préférence doit rester visible dans la mesure.

F.4 Résultats par méthode

Le tableau 46 donne la grille de résultats à renseigner pour les trois méthodes ; aucune de ses cellules n'est mesurée à ce jour.

TAB. 46. Résultats détaillés par méthode — cellules non mesurées à ce jour, cf. note

Méthode	Rang 1	Rang 3	Abst.	Err. sil.	Latence	Coût/1000
M0 — mots-clés	Non mesuré	n/a	Non mesuré	Non mesuré	Non mesuré	Non mesuré
M1 — pondération de termes	Non mesuré	Non mesuré	Non mesuré	Non mesuré	Non mesuré	Non mesuré
M2 — modèle spécialisé	Non mesuré	Non mesuré	Non mesuré	Non mesuré	Non mesuré	Non mesuré

Le tableau est conservé comme spécification du protocole, sans résultat anticipé. Il devra être rempli seulement après constitution d'un jeu de 50 à 100 alertes annotées et exécution des trois méthodes sur le même échantillon.

Trois questions guident l'interprétation, quelle que soit la direction du résultat : le gain de M2 sur M1 existe-t-il (le chapitre 2 a admis par avance un résultat négatif, objectif O5, qui doit être rapporté tel quel s'il se confirme) ; ce gain justifie-t-il le coût d'un composant supplémentaire à exploiter (colonnes de latence et de coût, à relever) ; et sur quel type d'alerte le gain se concentre-t-il, une analyse par type d'alerte étant plus informative qu'un chiffre global.

F.5 Validation distincte déjà exécutée — porte de qualité sur le modèle

Indépendamment de la comparaison M0/M1/M2, une porte de qualité a déjà été exécutée sur le modèle M2 lui-même, avant son emploi en recette : un test de bascule vers une version quantifiée (int8) a comparé les rapprochements produits à ceux du modèle de référence (fp32) sur cinq requêtes de type SOC. Résultat : 0 correspondance de premier rang identique sur 5, ce qui a conduit à rejeter cet export quantifié et à conserver le modèle non quantifié en recette, au prix d'une empreinte mémoire plus élevée. Ce test, réel et daté (1^{er} août 2026), ne se substitue pas à la comparaison M0/M1/M2 : il montre seulement que cet export int8 précis n'est pas acceptable sur le petit échantillon retenu ; il ne valide pas la qualité générale de fp32.

Annexe G Glossaire technique complémentaire

Terme	Définition
Chaîne d'attaque (kill-chain)	Séquence d'actions menées par un attaquant, couvrant plusieurs tactiques du référentiel MITRE ATT&CK, qui devient plus significative lorsqu'elle est reconstituée que lorsque chaque action est observée isolément.
Dérive de configuration	Écart entre l'état déclaré dans le code d'infrastructure et l'état réellement observé sur la plateforme cloud, révélé par une nouvelle planification de changement qui n'aboutit pas à un résultat vide.
Empreinte de contenu (digest)	Identifiant cryptographique unique d'une image logicielle, utilisé pour référencer précisément une version au lieu d'une étiquette modifiable.
Fédération d'identité	Mécanisme permettant à un système externe (par exemple un pipeline de livraison) de s'authentifier sans détenir de clé d'accès statique, sur la base d'une confiance établie entre fournisseurs d'identité.
Micro-segmentation	Contrôle fin des communications entre composants, réalisé ici par l'identité (comptes de service) plutôt que par un découpage réseau traditionnel.
Modèle non génératif	Modèle produisant une sortie déterministe (par exemple un vecteur numérique) plutôt qu'un texte librement généré, retenu pour ses propriétés d'auditabilité.
Montée à zéro (scale-to-zero)	Capacité d'un service à ne consommer aucune ressource de calcul en l'absence de trafic, et à redémarrer à la demande.
Point d'application de politique	Composant qui intercepte une requête et applique la décision d'accès prise en amont, plutôt que de faire confiance à la requête elle-même.
Similarité sémantique	Mesure de proximité entre deux vecteurs numériques représentant des textes, utilisée pour rattacher un événement à une technique d'attaque connue sans correspondance exacte de motif.

Annexe H Preuves d'exécution complémentaires

Le corps du rapport ne retient que les preuves les plus démonstratives, celles qui étayent directement un résultat de la campagne de validation. Cette annexe rassemble les preuves complémentaires réellement obtenues, et précise le protocole de preuve des captures qui restent à produire. Les protocoles déclarés non exécutés au chapitre 6 n'y figurent délibérément pas : aucune case n'est ouverte pour une mesure qui n'a jamais eu lieu.

Deux distinctions sont donc à tenir à la lecture de la section suivante. Les deux résultats qu'elle rapporte ont bien été relevés et datés en recette ; ce qui manque n'est pas la mesure mais son image. Chacun apparaît de ce fait dans un cadre réservé portant l'identifiant de la capture attendue, sous une légende qui énonce déjà la valeur relevée et sa date : le cadre marque un fichier à livrer, non un résultat à obtenir. La section H.2, elle, ne rapporte aucun résultat : elle fixe à l'avance le critère de recevabilité des captures dont le protocole reste à rejouer.

H.1 Preuves complémentaires disponibles

La figure 22 montre l'état des indicateurs de l'enrichissement sémantique en recette, relevé le 19/08/2026.

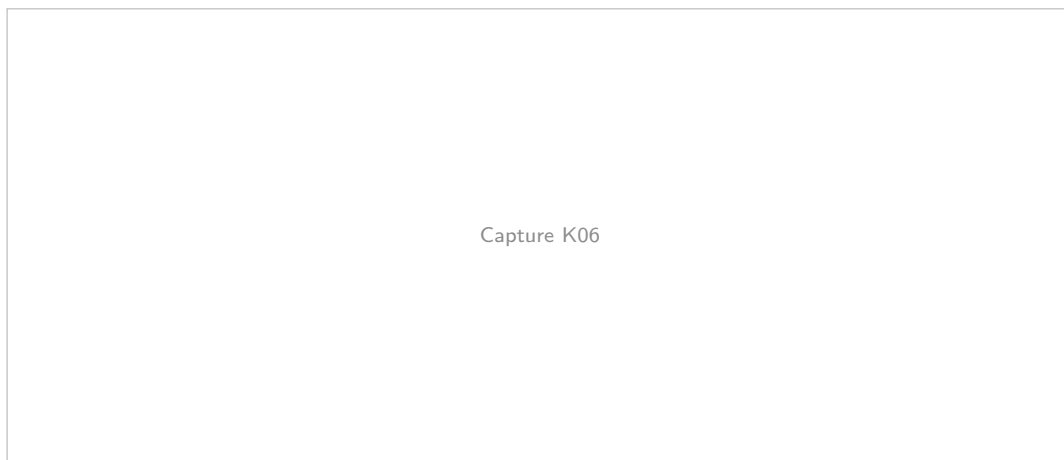


FIG. 22. Indicateurs de l'enrichissement sémantique en recette, le 19/08/2026 : dernier rattachement automatique produit à 12:16:15 UTC, technique T1556.003, similarité 0,698.

La figure 23 montre le retour arrière applicatif par bascule de révision, mesuré le 07/08/2026.

H.2 Preuves à produire au rejeu des protocoles

Le tableau 47 documente, pour chaque protocole restant à rejouer, la capture attendue, ce qu'elle doit rendre visible et ce qu'elle doit masquer. Il tient lieu de protocole de preuve : il fixe à l'avance le critère de recevabilité de chaque capture, sans prétendre à une preuve qui n'existe pas encore.

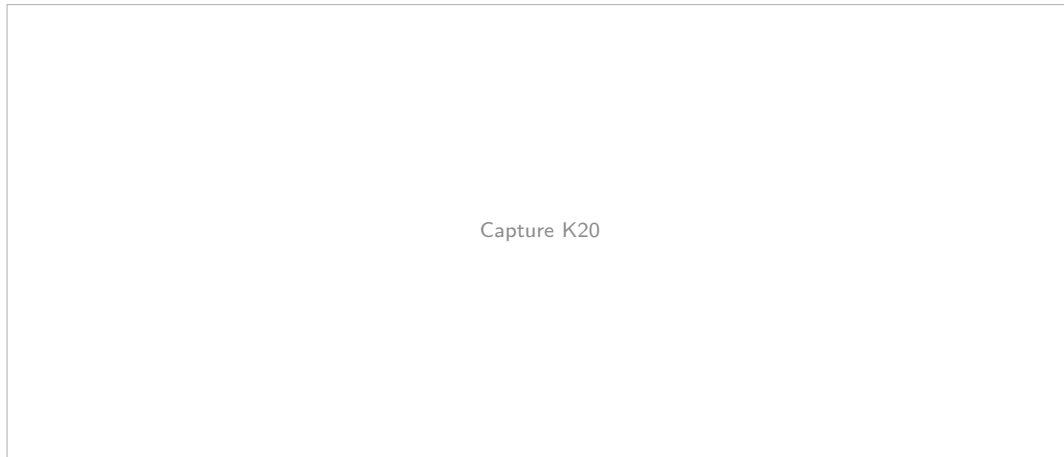


FIG. 23. Retour arrière applicatif par bascule de révision, mesuré le 07/08/2026 : 11,6 s pour la bascule vers la révision précédente, 16,5 s pour le retour vers la dernière révision.

TAB. 47. Captures à produire au rejeu des protocoles

Test	Capture	Ce qui doit être visible	Ce qui doit être masqué
T10 — secret versionné	K01	Étape de détection de secrets en échec, règle déclenchée, chemin du fichier, code de retour non nul, chaîne arrêtée avant livraison	Valeur du secret factice, même inoffensive ; nom du dépôt et de l'organisation
T8 — artefact vulnérable	K03	Étape d'analyse de vulnérabilité en échec, identifiant de la vulnérabilité, gravité critique, seuil appliqué, déploiement non atteint	Empreinte d'image au-delà de douze caractères, nom du registre, identifiant de projet
Chaîne d'infrastructure	K04	Refus d'une ressource mal configurée avant application : règle violée, fichier et ligne concernés, plan non appliqué	Identifiant de projet, noms de ressources réels, emplacement du fichier d'état
T4 — accès direct aux données	K10	Inventaire ne montrant aucune adresse publique sur l'instance, puis tentative de connexion depuis un hôte externe se terminant en échec, avec horodatage	Adresses IP réelles, identifiant d'instance et de projet
T11 — intégrité de la preuve	K11	Refus d'écriture et refus de suppression sur les tables de journaux bruts et de détections, avec l'identité employée ; écriture acceptée sur la seule table d'enrichissement	Courriel complet du compte de service, identifiant de projet et de jeu de données
T7 — clés de longue durée	K12	Inventaire des clés vide pour chaque identité de service, et refus explicite lors d'une tentative de création	Courriels et domaines des comptes de service, identifiant de projet
T16 — dérive de configuration	K13	Planification avec rafraîchissement signalant l'écart sur l'attribut modifié hors code, et entrée d'audit nommant l'auteur de la modification	Identifiant de projet, courriel de l'auteur, noms de ressources réels

TAB. 47. Captures à produire au rejeu des protocoles (suite)

Test	Capture	Ce qui doit être visible	Ce qui doit être masqué
Reconstruction chronométrée	K19	Horodatage de début et de fin de la reconstruction, durée totale, service à nouveau disponible et réponse applicative correcte	Identifiant de projet, noms complets de révision, adresses IP réelles

H.3 Règles de production et de masquage

Les dix règles ci-dessous s'appliquent à toute capture livrée, y compris à celles déjà disponibles. Elles visent un seul objectif : qu'une capture soit vérifiable par un tiers sans exposer d'élément exploitable.

1. Capturer **pendant** l'exécution, jamais après coup ni à partir d'une exécution rejouée pour la circonstance.
2. Produire une image d'au moins 1600 px de large, dans un format sans perte.
3. Faire figurer l'horodatage dans le cadre capturé, et non en légende seule.
4. Faire figurer le code de retour, ou à défaut le statut explicite de l'étape.
5. Cadrer sur le bloc utile : ni barre des tâches, ni onglets, ni fenêtre voisine.
6. Masquer par rectangle noir opaque, jamais par floutage : un flou reste réversible.
7. Masquer systématiquement l'identifiant complet de projet cloud, les courriels et domaines de comptes de service, les jetons et valeurs de secrets même factices, les adresses IP réelles, les noms de dépôt et d'organisation, et les empreintes d'images au-delà de douze caractères.
8. Nommer le fichier livré exactement `figures/<IDENTIFIANT>.png` : la macro d'insertion le charge sous ce nom et sous aucun autre.
9. Conserver la sortie brute à côté de chaque capture, afin qu'un tiers puisse recouper le contenu de l'image.
10. Contrôler dans le PDF final, à fort grossissement, qu'aucune valeur masquée ne reste lisible sous le rectangle.



Je valide le dépôt du rapport PFE relatif à l'étudiant nommé ci-dessous
I validate the submission of the student's report :

Nom & Prénom / *Name & Surname* : **Mansour HABIBOULLAH**

Encadrant Entreprise / *Business site Supervisor*

Nom & Prénom / *Name & Surname* : **Houssein Ezzedine**

Cachet & Signature / *Stamp & Signature* :

Encadrant Académique / *Academic Supervisor*

Nom & Prénom / *Name & Surname* : **Rihem Matoussi**

Signature / *Signature* :

*Ce formulaire doit être rempli, signé et scanné
This form must be completed, signed and scanned.*

ECOLE SUPÉRIEURE PRIVÉE D'INGÉNIERIE ET DE TECHNOLOGIES

www.esprit.tn - E-mail : contact@esprit.tn

Siège Social : 18 rue de l'Usine - Charguia II - 2035 - Tél. : +216 71 941 541 - Fax. : +216 71 941 889

Annexe : Z.I. Chotrana II - B.P. 160 - 2083 - Pôle Technologique - El Ghazala - Tél. : +216 70 685 685 - Fax. : +216 70 685 454